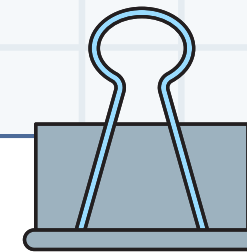


GitHub 특강

- 심화 -



강의 자료 다운로드

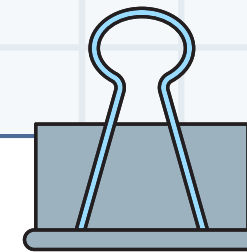


목표

자동화와 보안 기능을 활용하여

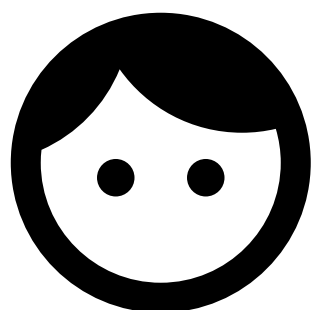
중/소규모 프로젝트를 효율적이고

안전하게 관리할 수 있다.

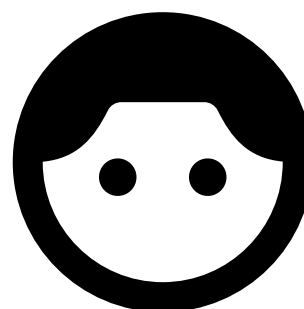


프로젝트 내 문제점

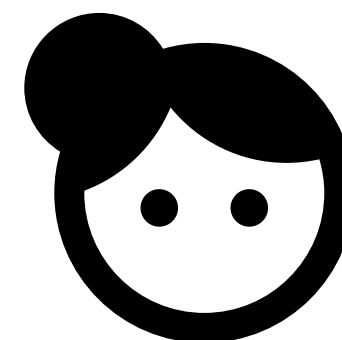
git push --force



내일이 마감이에요??



API 키 그냥
적고 커밋했는데요





목차

01 Branch 안전하게 보호하기

02 Issue 와 Milestone

03 Dependabot과 CodeQL

04 Actions로 자동화하기

05 Secrets로 안전하게 보호하기

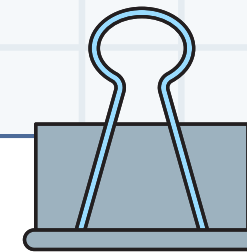
06 Q&A

|

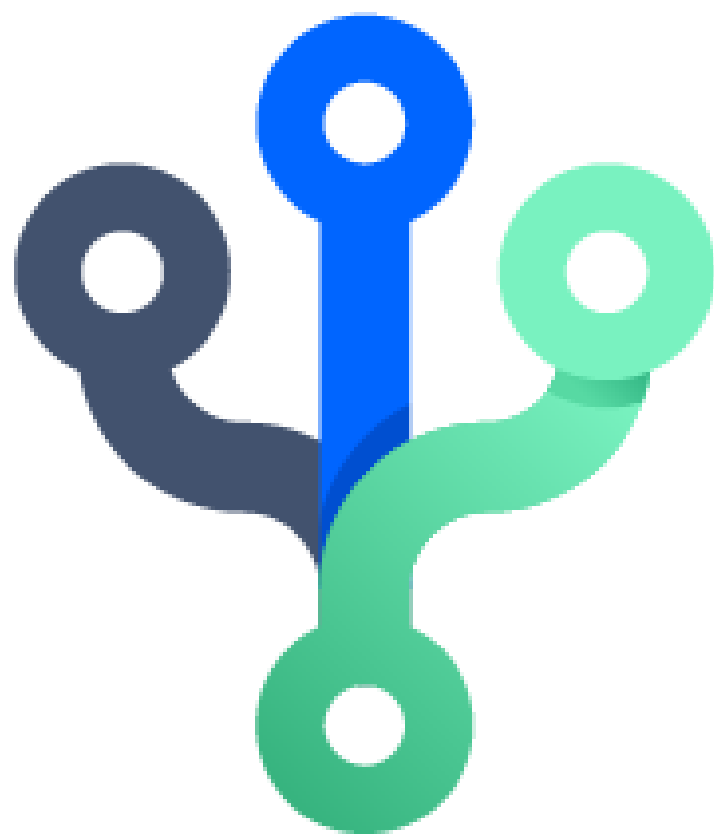
01

Branch 안전하게 보호하기

|



01 Branch 안전하게 보호하기

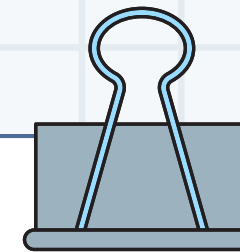


브랜치 관리 기법

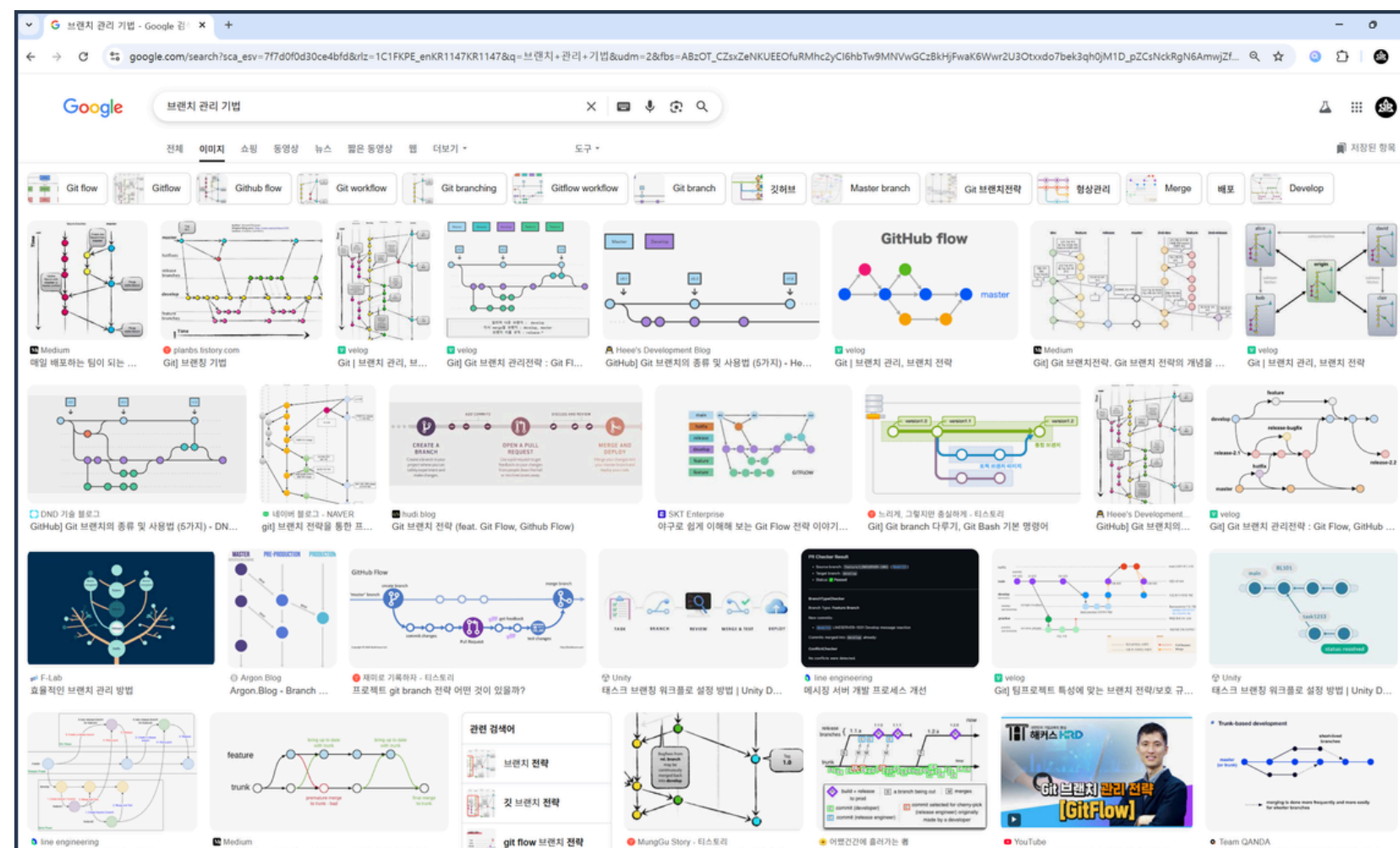
브랜치를 안전하게 다루는 기법

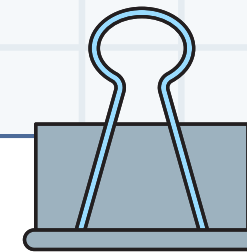
프로젝트 내 협업이 수월하게
이루어지도록 시행하는 조치

충돌을 최소화하고 브랜치를 보호하는 기법



01 Branch 안전하게 보호하기





01 Branch 안전하게 보호하기

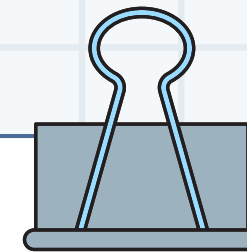


브랜치 관리 기법의 목표

병합 충돌 최소화

팀원간 협업 원활화

브랜치를 목적에 따라 효과적으로 분리



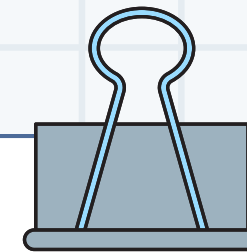
01 Branch 안전하게 보호하기



다른 사람의 push를 막을 수 없나?

아무나 merge 할 수 없게 만들 수 있나?

브랜치를 삭제할 수 없도록 할 수 있나?



01 Branch 안전하게 보호하기

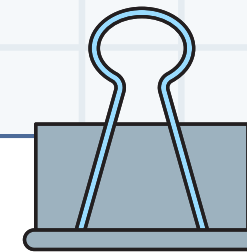


브랜치 보호 설정

브랜치에 특정 조건을 추가하는 것

설정된 조건을 충족해야만
작업들이 처리될 수 있음

브랜치를 보호할 수 있는 조건을 추가하는 것



01 Branch 안전하게 보호하기



브랜치 보호 설정

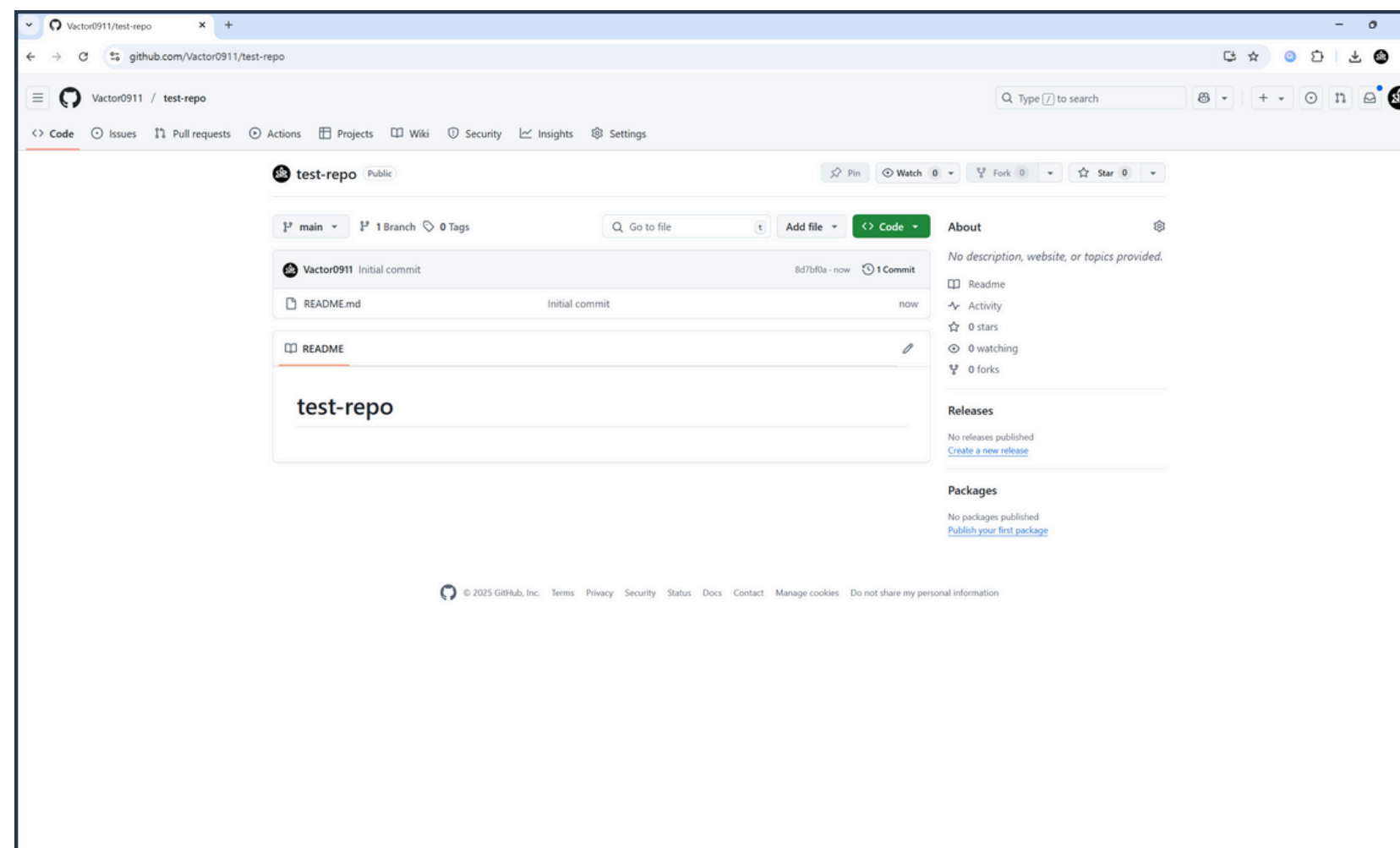
생성, 수정, 삭제 금지

병합시 PR / 코드 리뷰 요구

소스코드 보안 검사 결과 요구



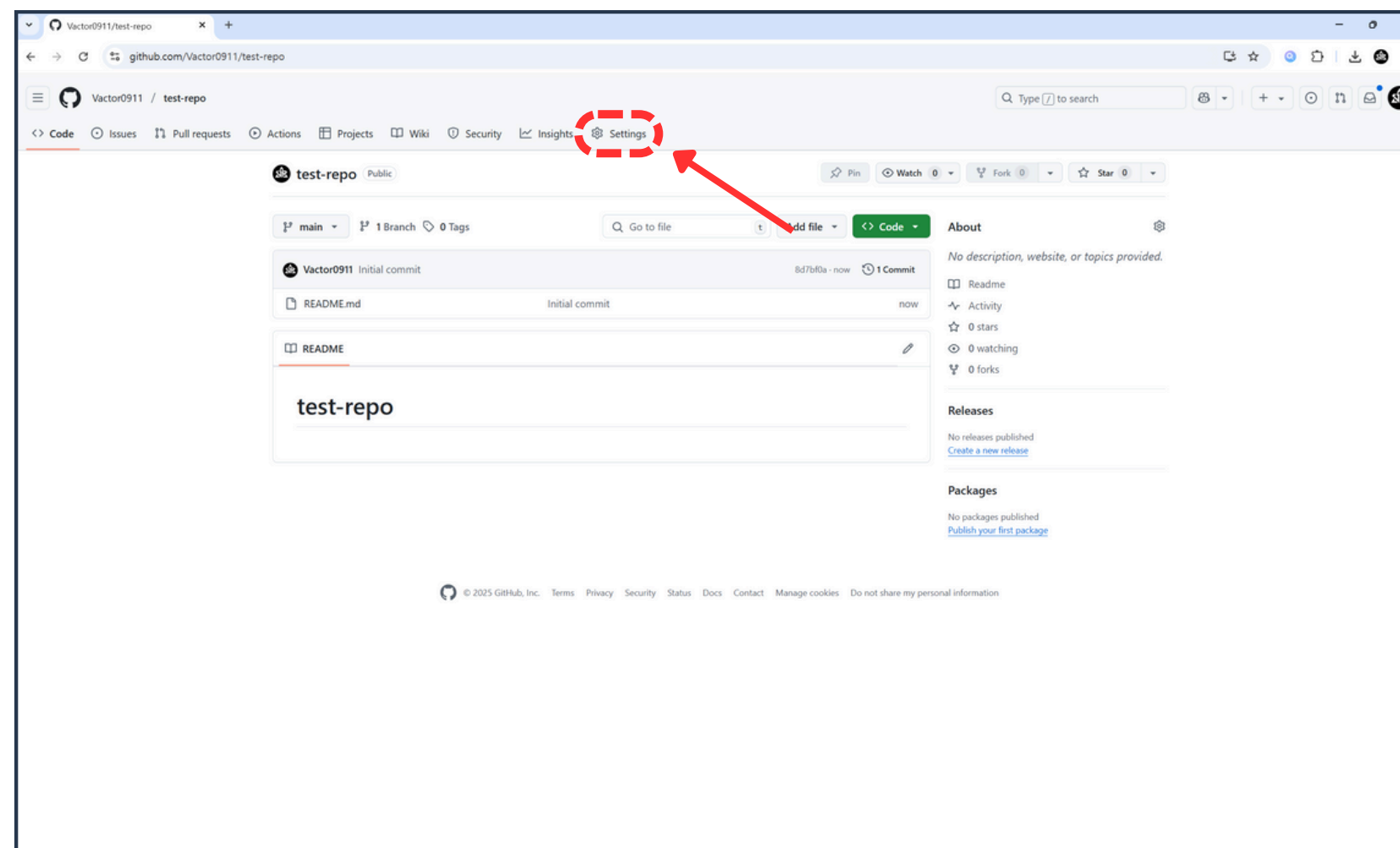
01 Branch 안전하게 보호하기



1. GitHub 리포지토리 생성 후 접속



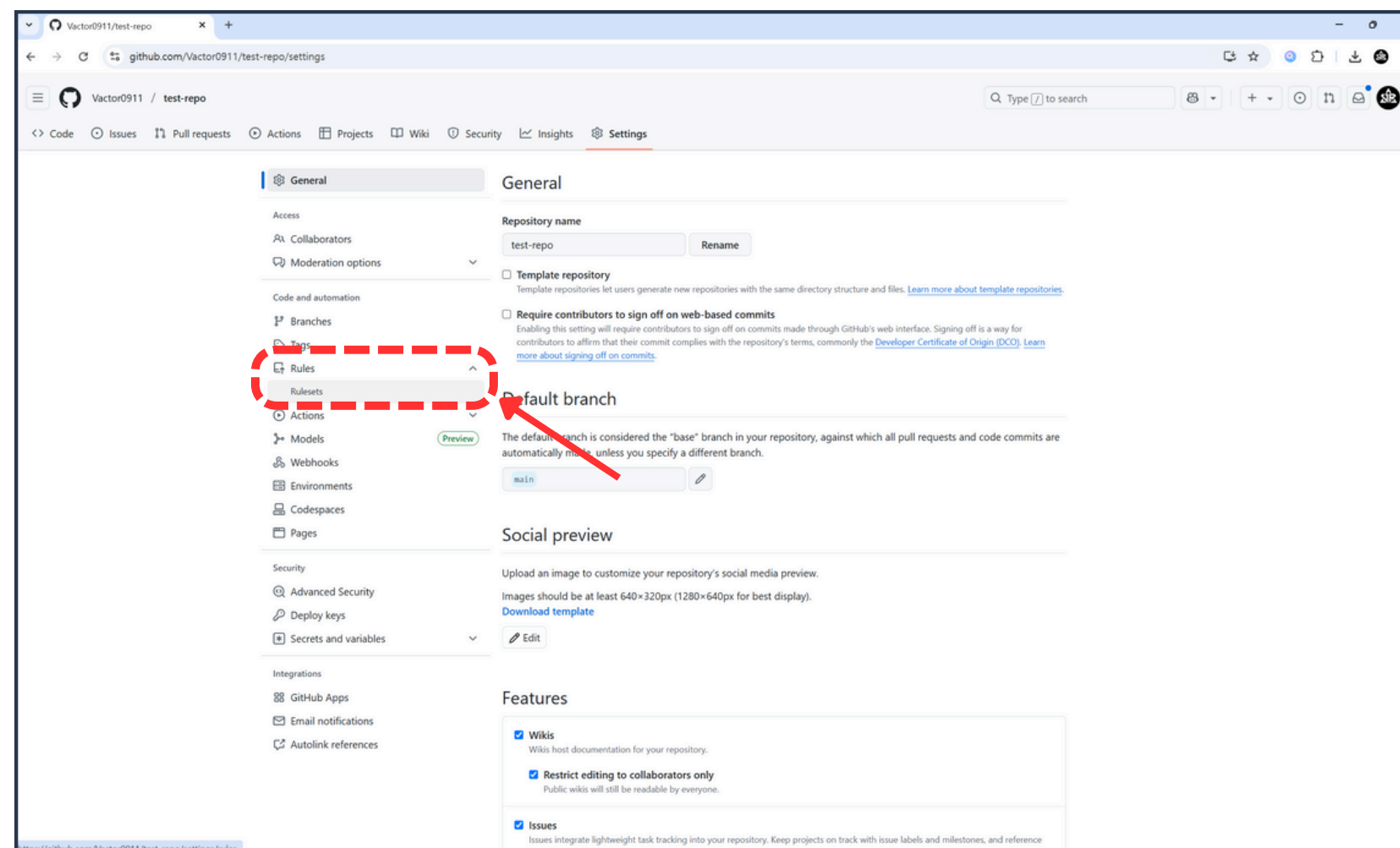
01 Branch 안전하게 보호하기



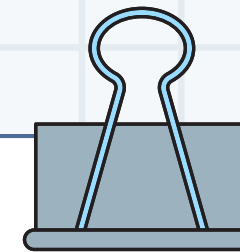
2. Settings 버튼 클릭



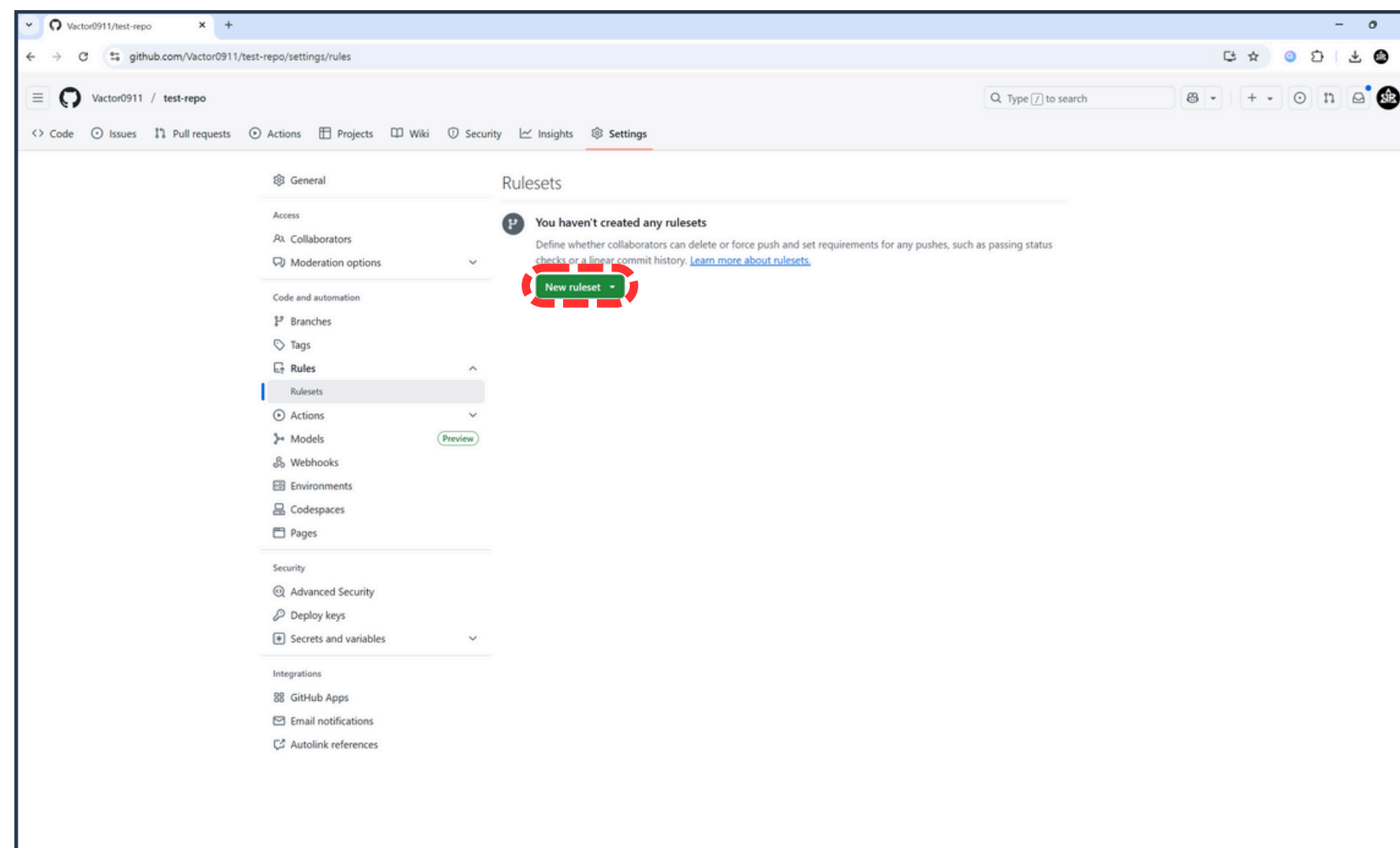
01 Branch 안전하게 보호하기



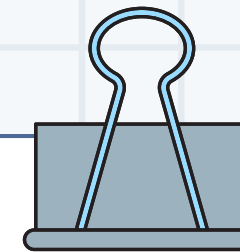
3. Rules > Rulesets 버튼 클릭



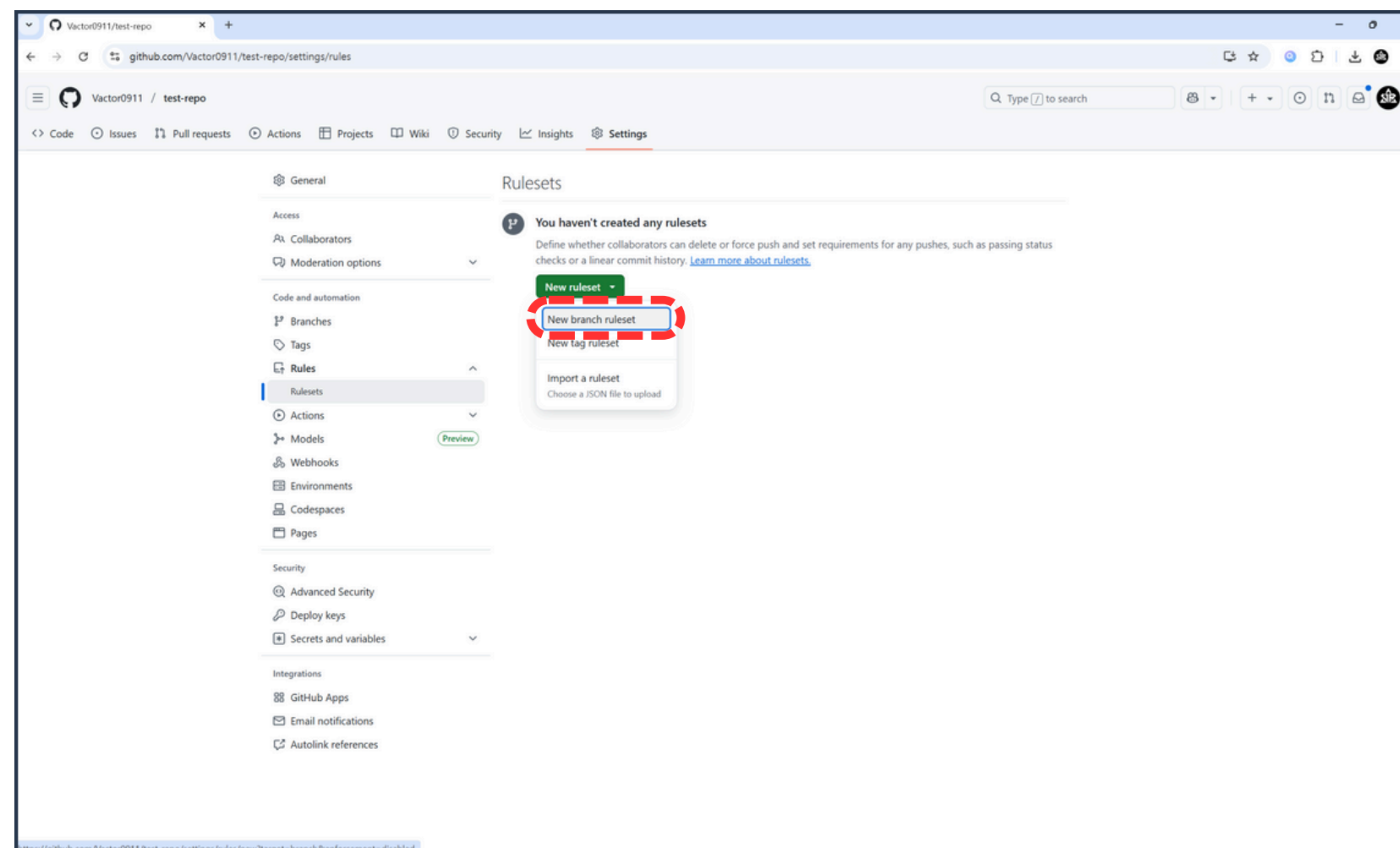
01 Branch 안전하게 보호하기



4. New ruleset 버튼 클릭



01 Branch 안전하게 보호하기



5. New branch ruleset 버튼 클릭



01 Branch 안전하게 보호하기

The screenshot shows the GitHub 'New branch ruleset' configuration page. The left sidebar contains navigation links for various repository settings. The main content area is divided into sections for 'Ruleset Name', 'Enforcement status', 'Bypass list', 'Targets', and 'Target branches'. Annotations in Korean are placed over the interface to identify key components:

- 규칙 제목** (Rule Title): Points to the 'Ruleset Name' input field.
- 활성화 여부** (Activation Status): Points to the 'Enforcement status' dropdown menu.
- 규칙 무시 대상 목록** (Rule Ignore Target List): Points to the 'Bypass list' section.
- 규칙 적용 브랜치 목록** (Rule Apply Branch List): Points to the 'Target branches' section.



01 Branch 안전하게 보호하기

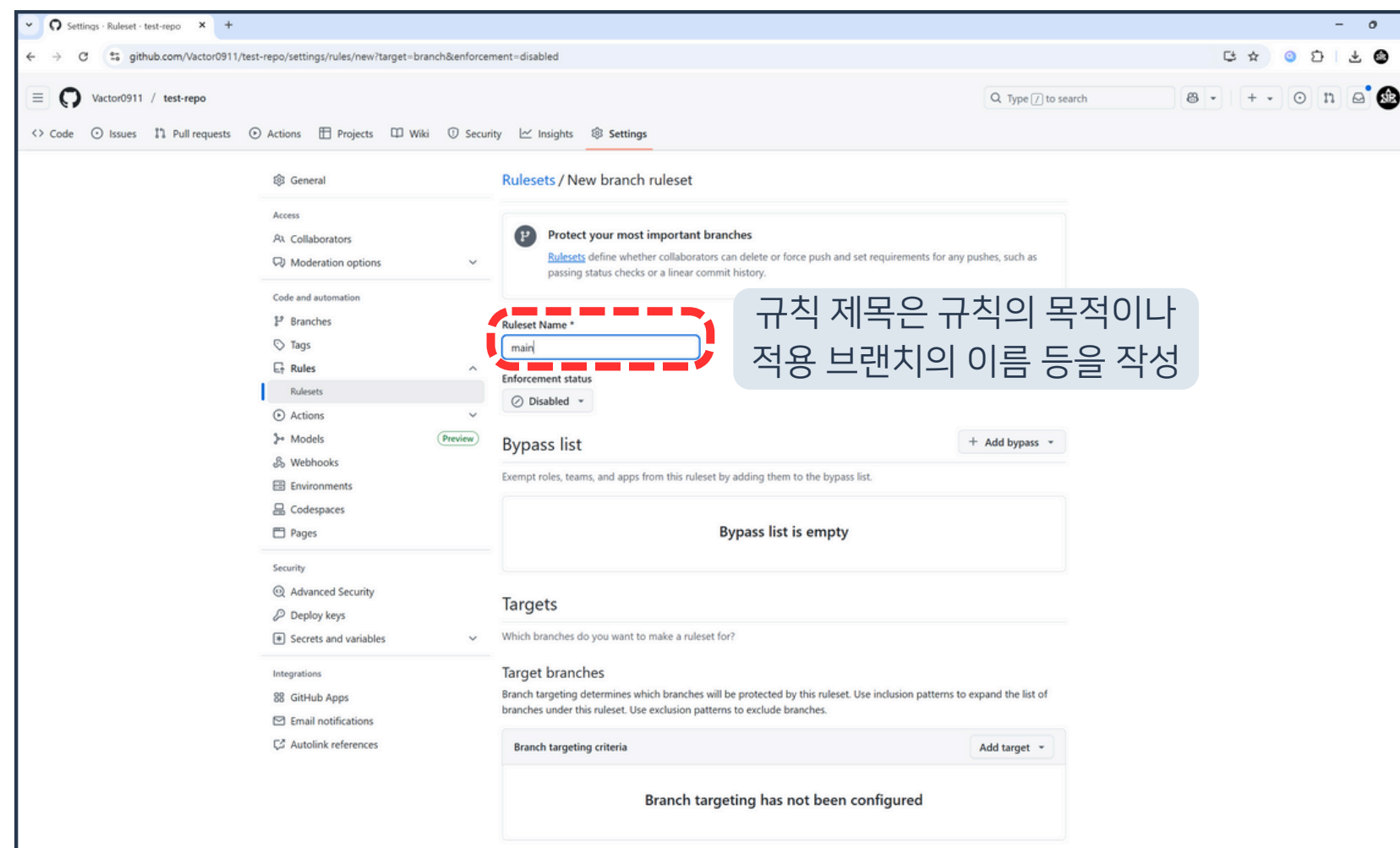
The screenshot shows the GitHub 'Ruleset - test-repo' settings page for a new branch rule. The page is titled '규칙 목록' (Rules List) and 'Rules'. It lists various branch rules with checkboxes and corresponding Korean annotations in blue boxes:

- ☐ Restrict creations: 브랜치 생성 금지
- ☐ Restrict updates: 브랜치 수정 금지
- ☒ Restrict deletions: 브랜치 삭제 금지
- ☐ Require linear history: squash, rebase 외 병합 금지
- ☐ Require deployments to succeed: 병합 전 배포 성공 여부 필요
- ☐ Require signed commits: 전자 서명된 커밋 요구
- ☐ Require a pull request before merging: 병합 전 PR 요구
- ☐ Require status checks to pass: 병합 전 테스트 통과 여부 요구
- ☒ Block force pushes: 강제 push 금지
- ☐ Require code scanning results: 코드 검사 결과 요구

A green 'Create' button is at the bottom left of the form.



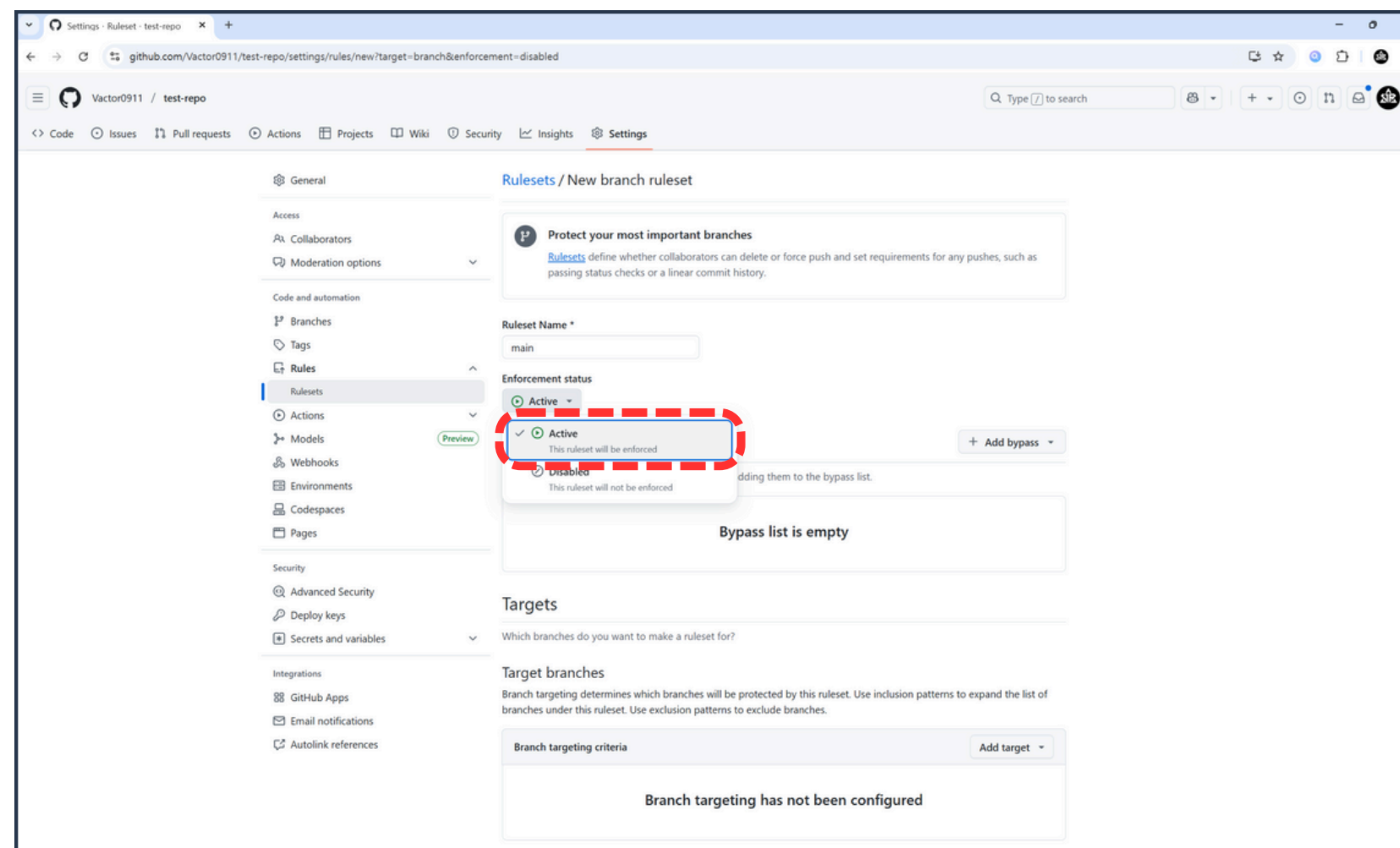
01 Branch 안전하게 보호하기



6. 규칙 제목 입력



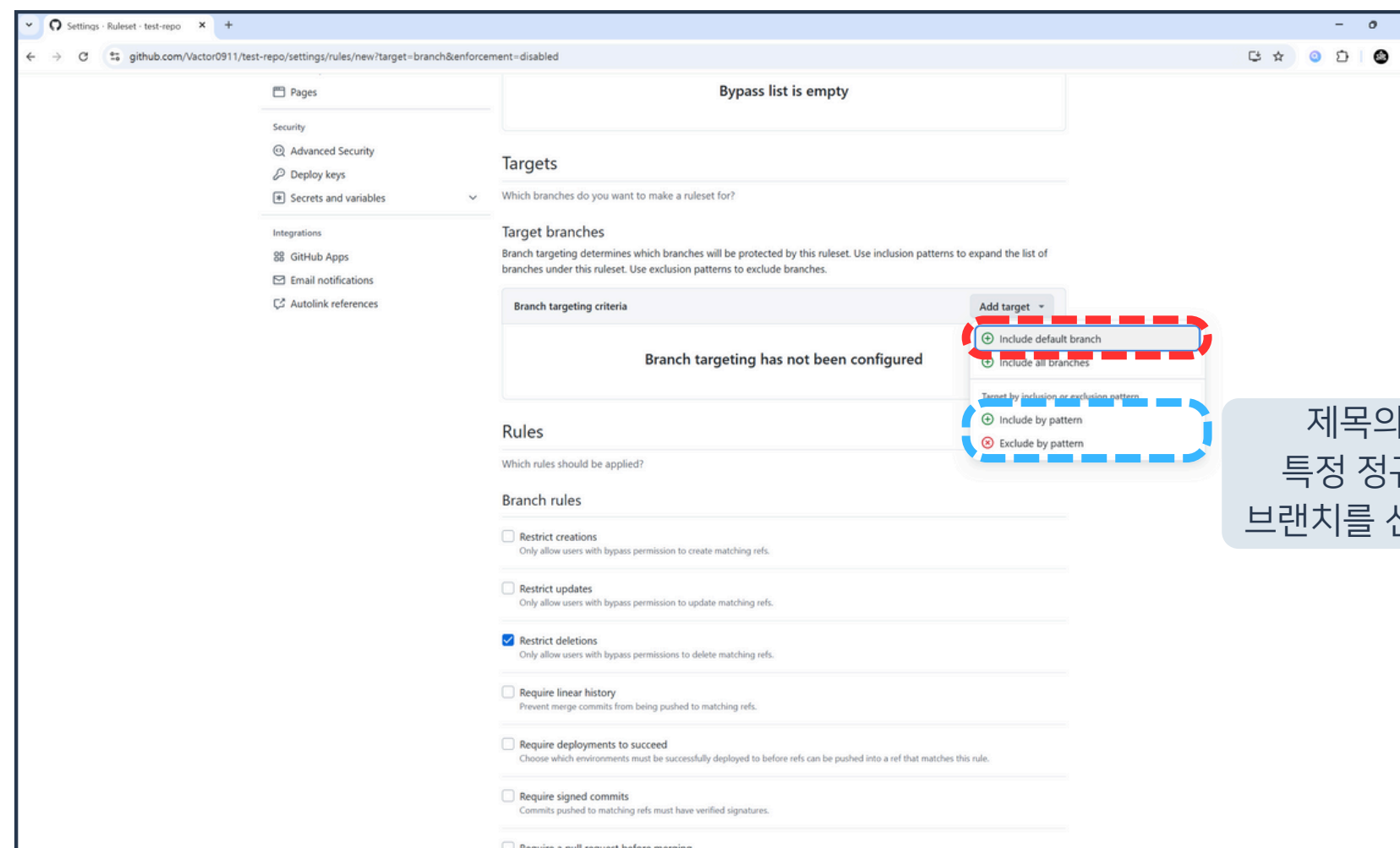
01 Branch 안전하게 보호하기



7. 규칙 활성화 버튼 클릭



01 Branch 안전하게 보호하기

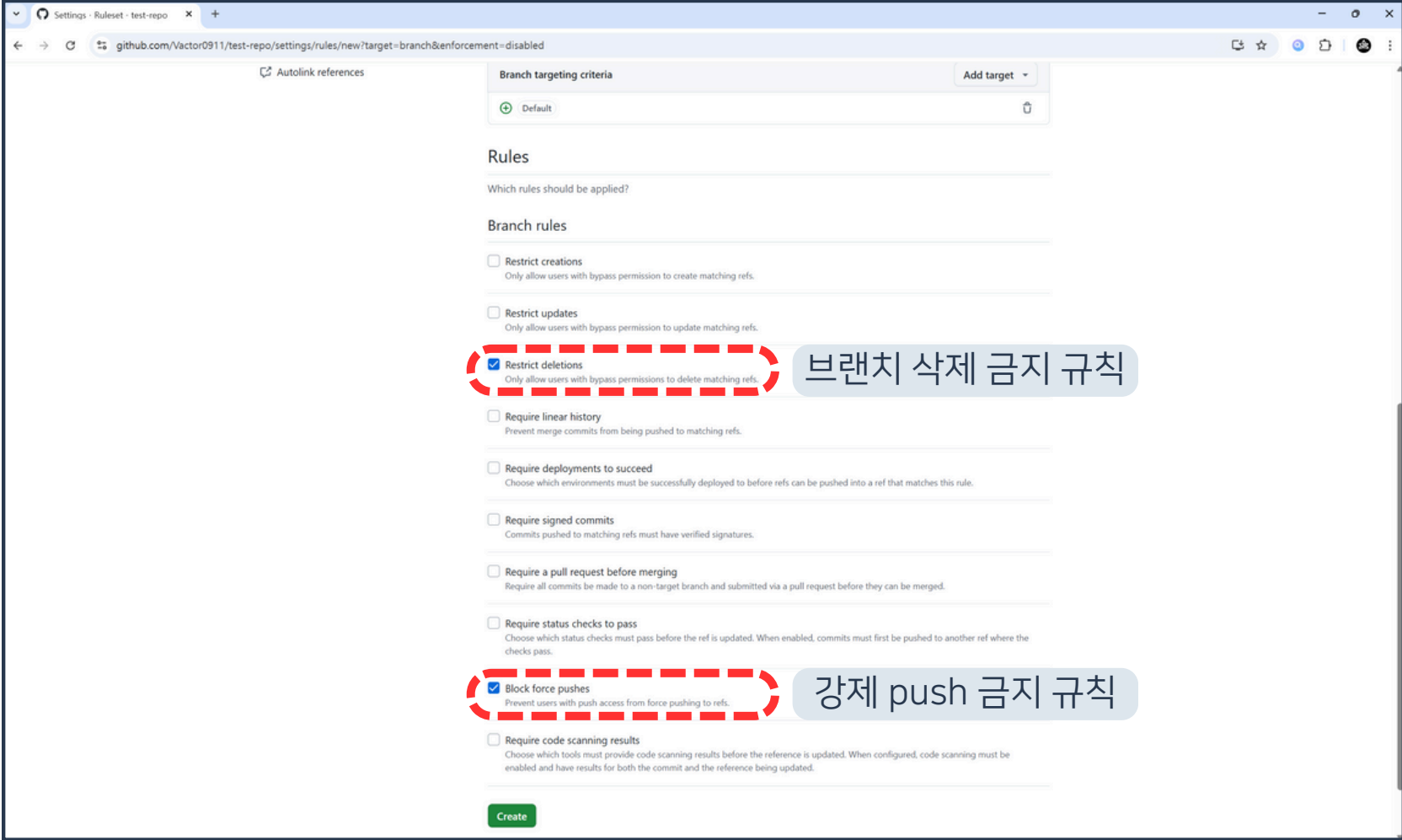


제목의 pattern으로
특정 정규식을 만족하는
브랜치를 선택하는 것도 가능

8. Include default branch 버튼 클릭



01 Branch 안전하게 보호하기



The screenshot shows the GitHub 'New branch rule' configuration page. The 'Branch targeting criteria' section has 'Default' selected. Under 'Branch rules', several options are listed with checkboxes. Two options are highlighted with red dashed boxes and blue callouts: 'Restrict deletions' (labeled '브랜치 삭제 금지 규칙') and 'Block force pushes' (labeled '강제 push 금지 규칙'). Both are currently checked. Other rules like 'Restrict creations', 'Restrict updates', 'Require linear history', 'Require deployments to succeed', 'Require signed commits', 'Require a pull request before merging', 'Require status checks to pass', and 'Require code scanning results' are unchecked. A 'Create' button is at the bottom.

Branch targeting criteria

Default

Rules

Which rules should be applied?

Branch rules

☐ Restrict creations
Only allow users with bypass permission to create matching refs.

☐ Restrict updates
Only allow users with bypass permission to update matching refs.

☒ Restrict deletions
Only allow users with bypass permissions to delete matching refs. 브랜치 삭제 금지 규칙

☐ Require linear history
Prevent merge commits from being pushed to matching refs.

☐ Require deployments to succeed
Choose which environments must be successfully deployed to before refs can be pushed into a ref that matches this rule.

☐ Require signed commits
Commits pushed to matching refs must have verified signatures.

☐ Require a pull request before merging
Require all commits be made to a non-target branch and submitted via a pull request before they can be merged.

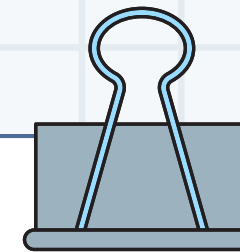
☐ Require status checks to pass
Choose which status checks must pass before the ref is updated. When enabled, commits must first be pushed to another ref where the checks pass.

☒ Block force pushes
Prevent users with push access from force pushing to refs. 강제 push 금지 규칙

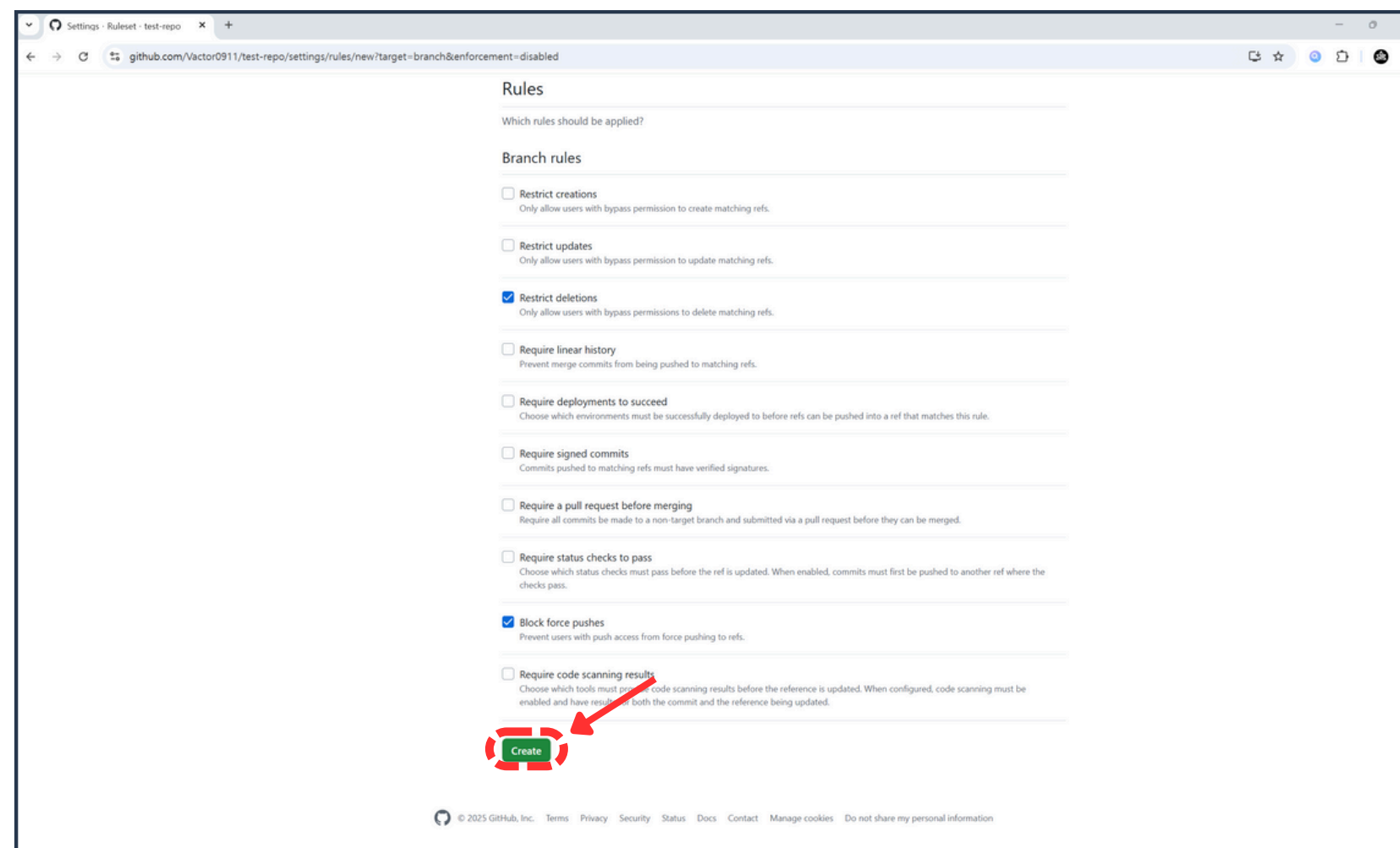
☐ Require code scanning results
Choose which tools must provide code scanning results before the reference is updated. When configured, code scanning must be enabled and have results for both the commit and the reference being updated.

Create

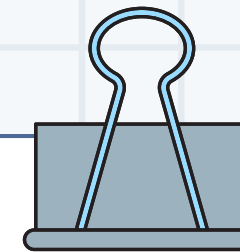
9. 삭제 방지 및 강제 push 금지 규칙 활성화



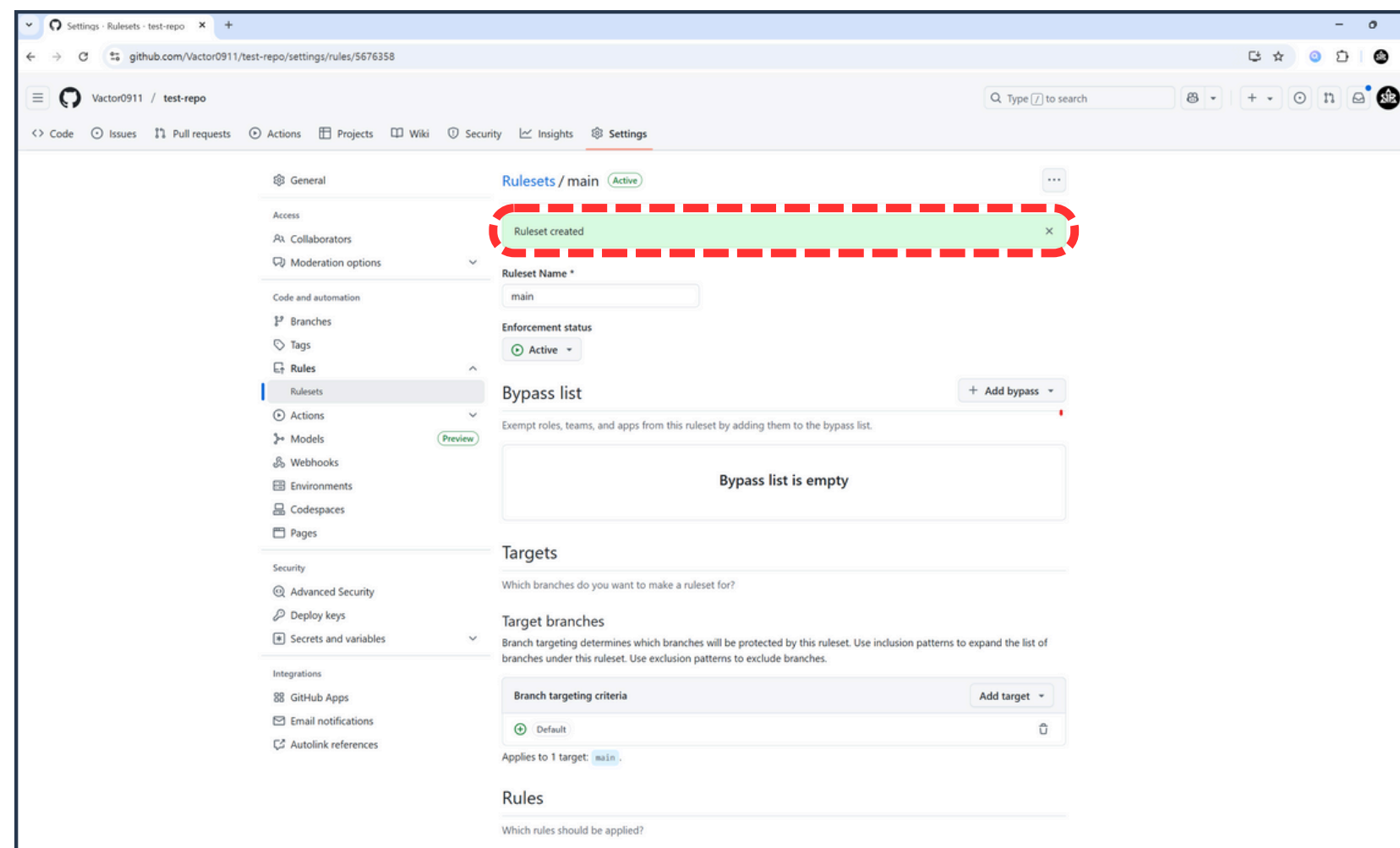
01 Branch 안전하게 보호하기



10. Create 버튼 클릭



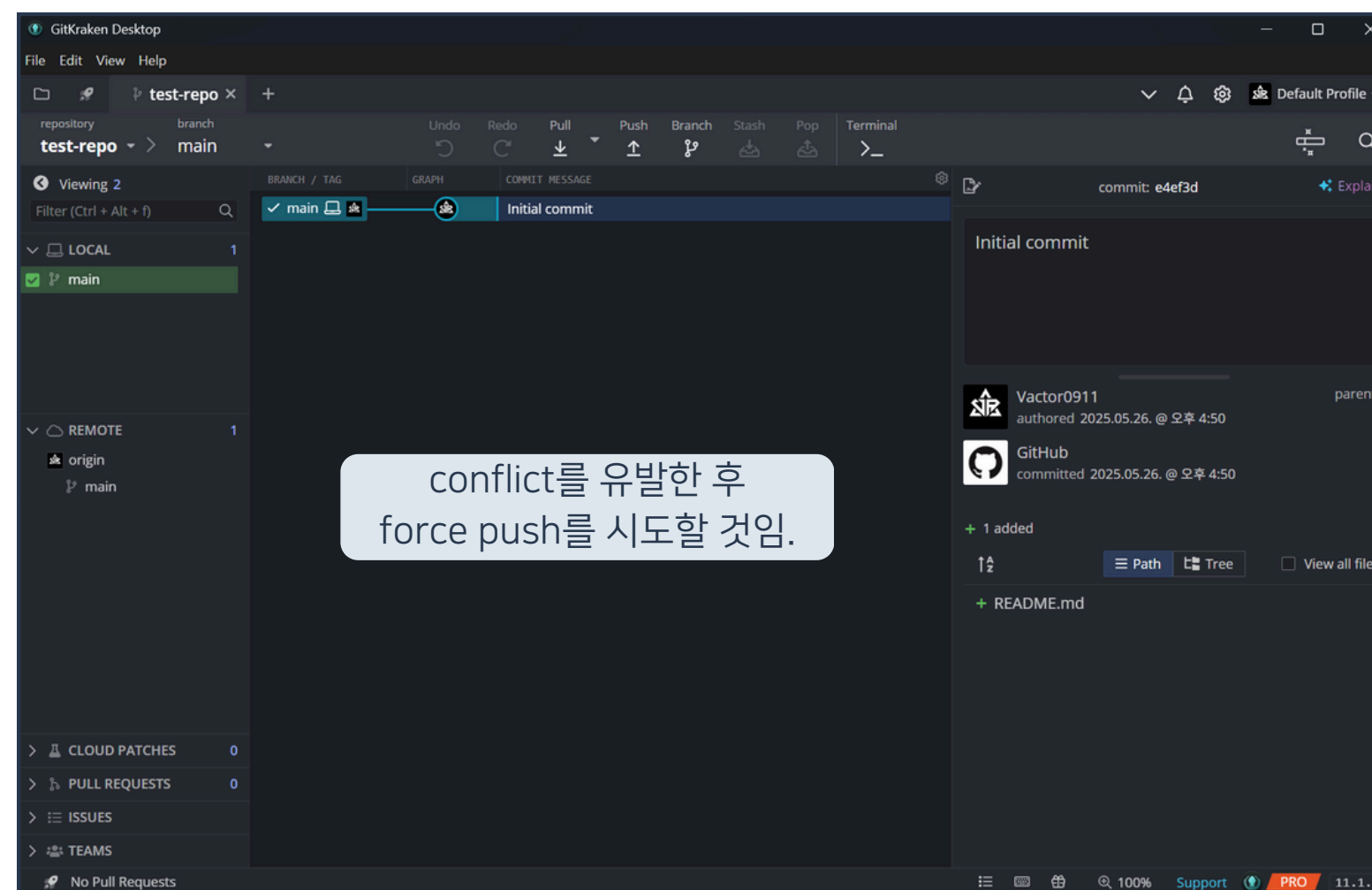
01 Branch 안전하게 보호하기



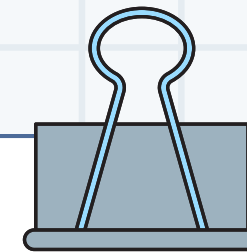
11. 규칙 생성 여부 확인



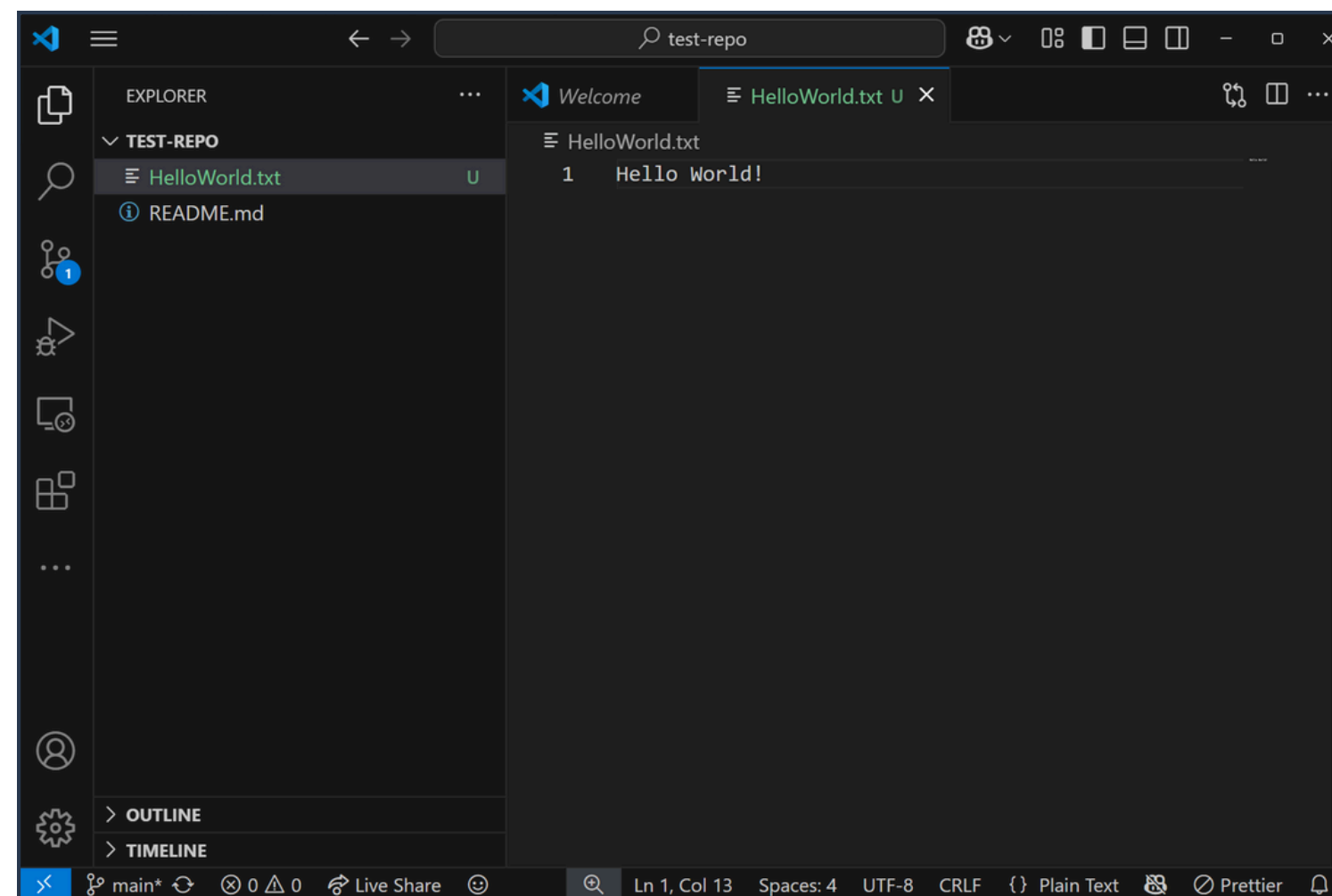
01 Branch 안전하게 보호하기



12. GitKraken에서 리포지토리 클론



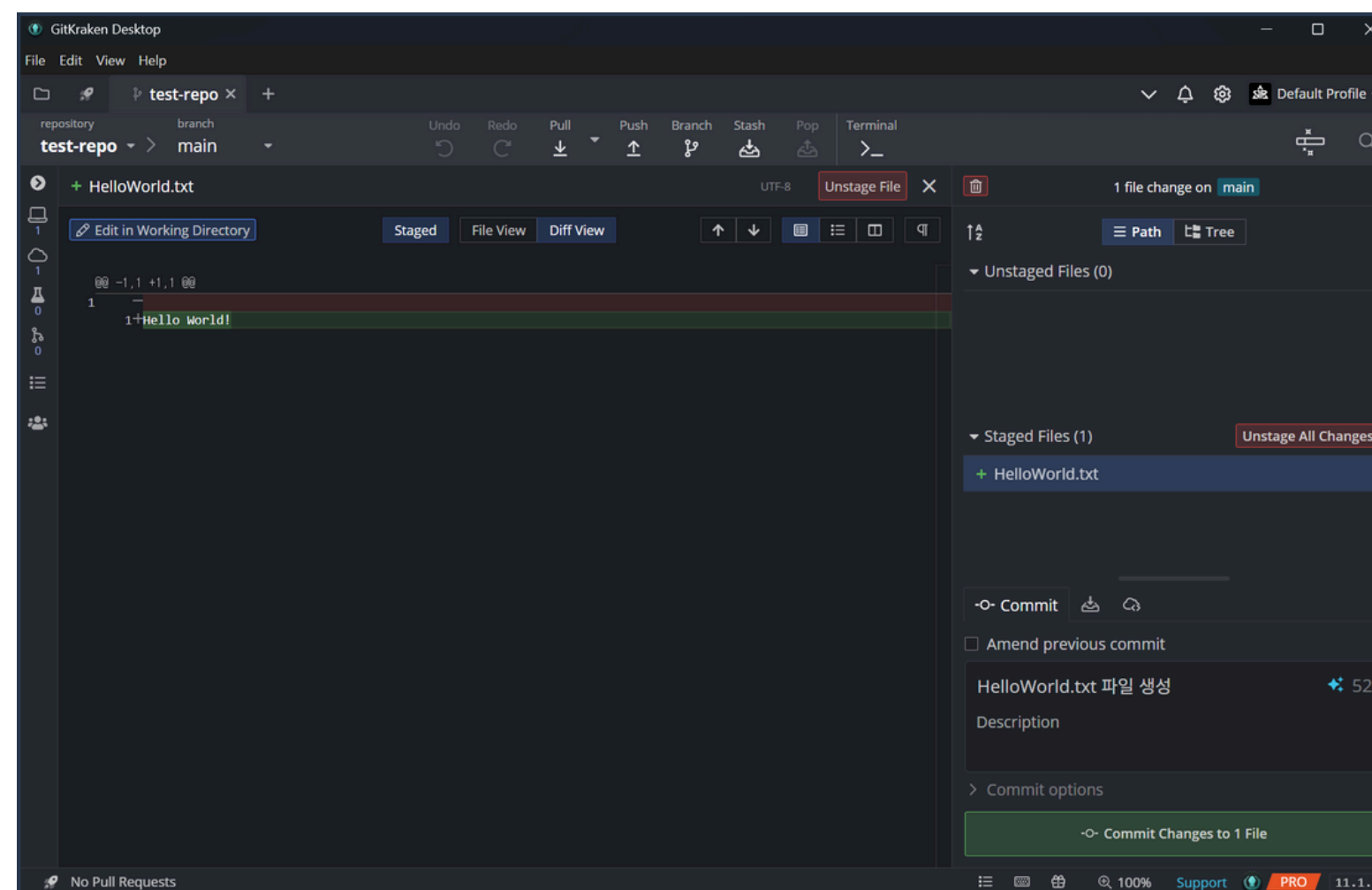
01 Branch 안전하게 보호하기



13. HelloWorld.txt 파일 생성



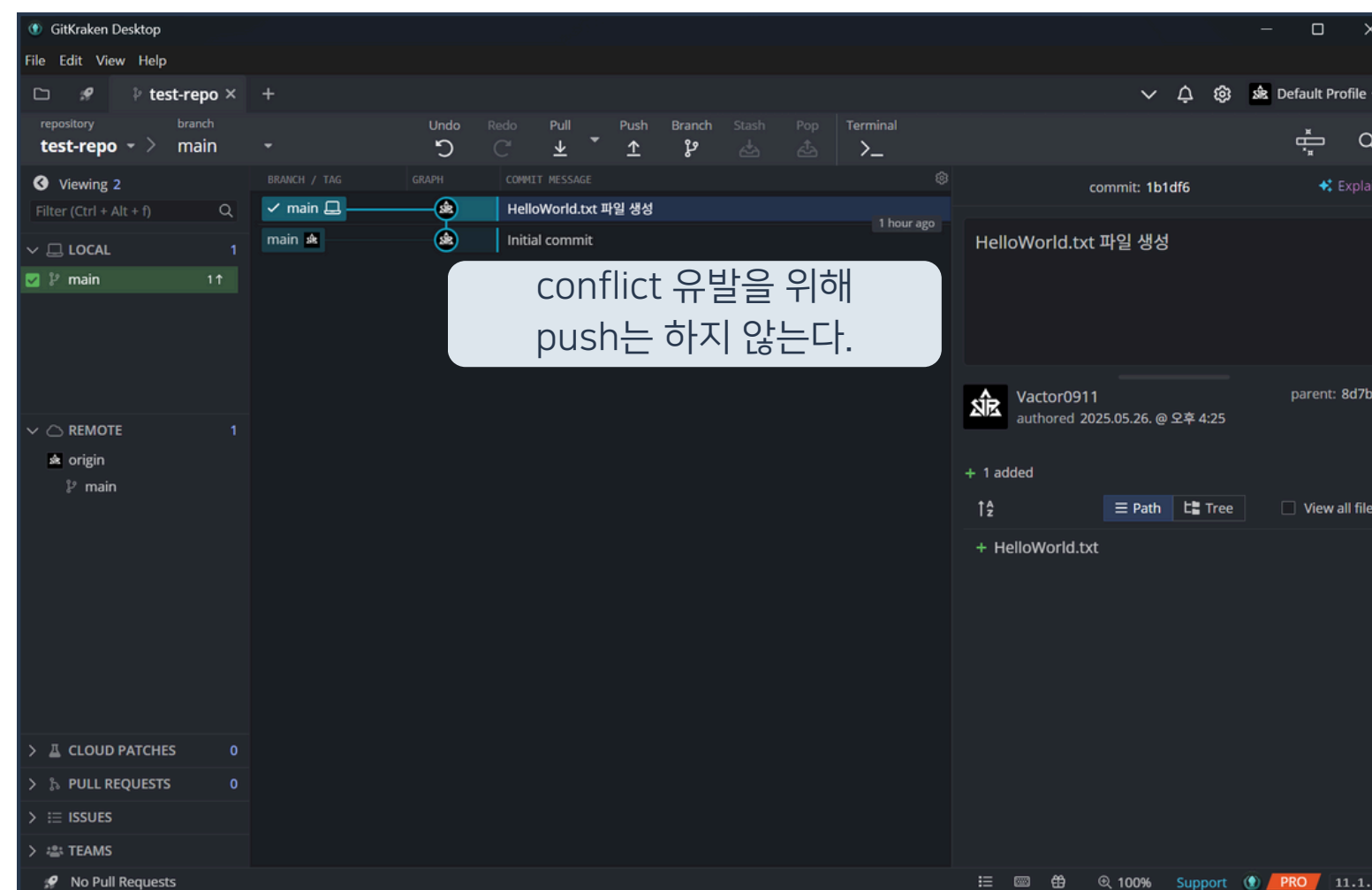
01 Branch 안전하게 보호하기



14. 변경점 커밋



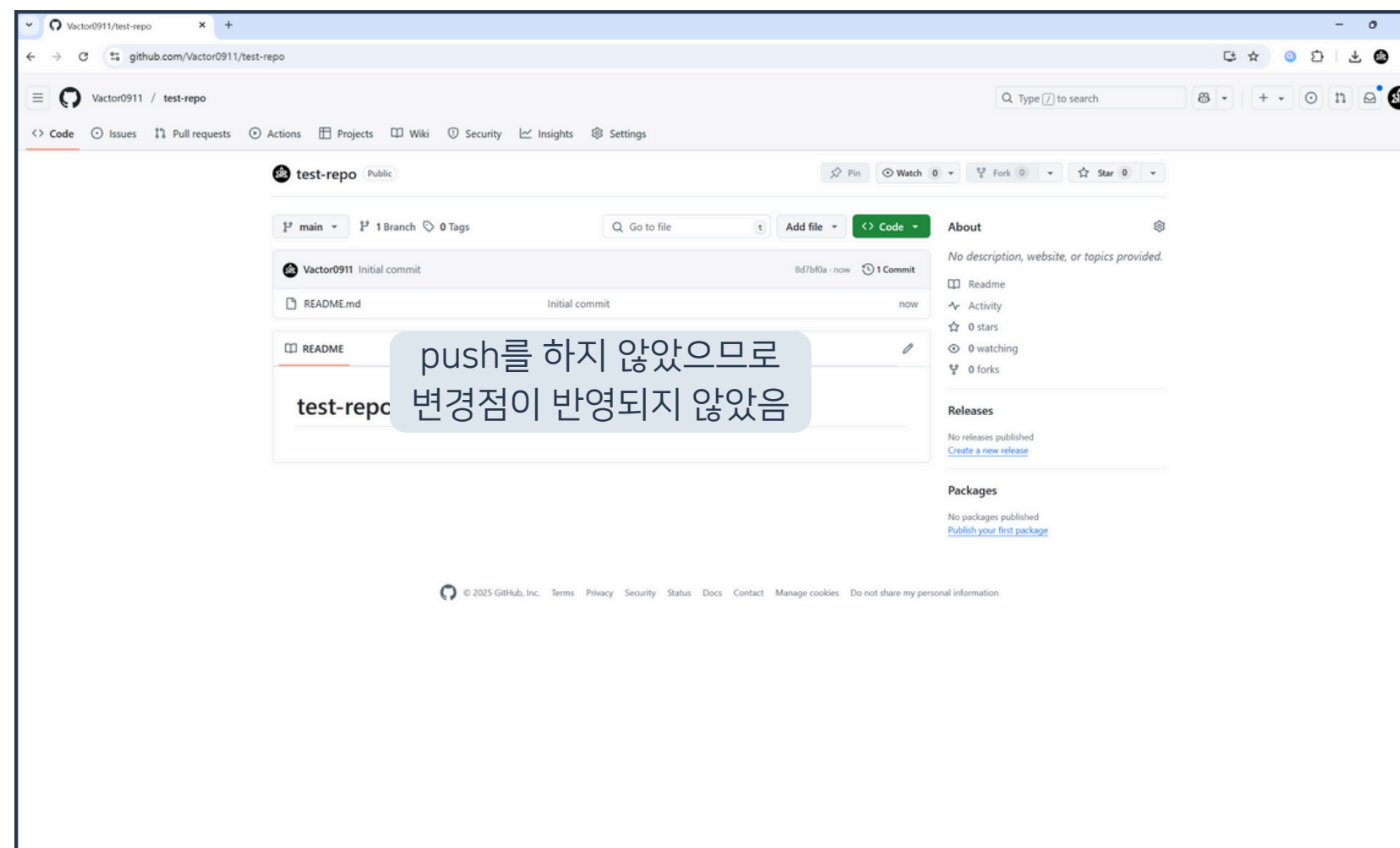
01 Branch 안전하게 보호하기



15. 커밋 결과 확인



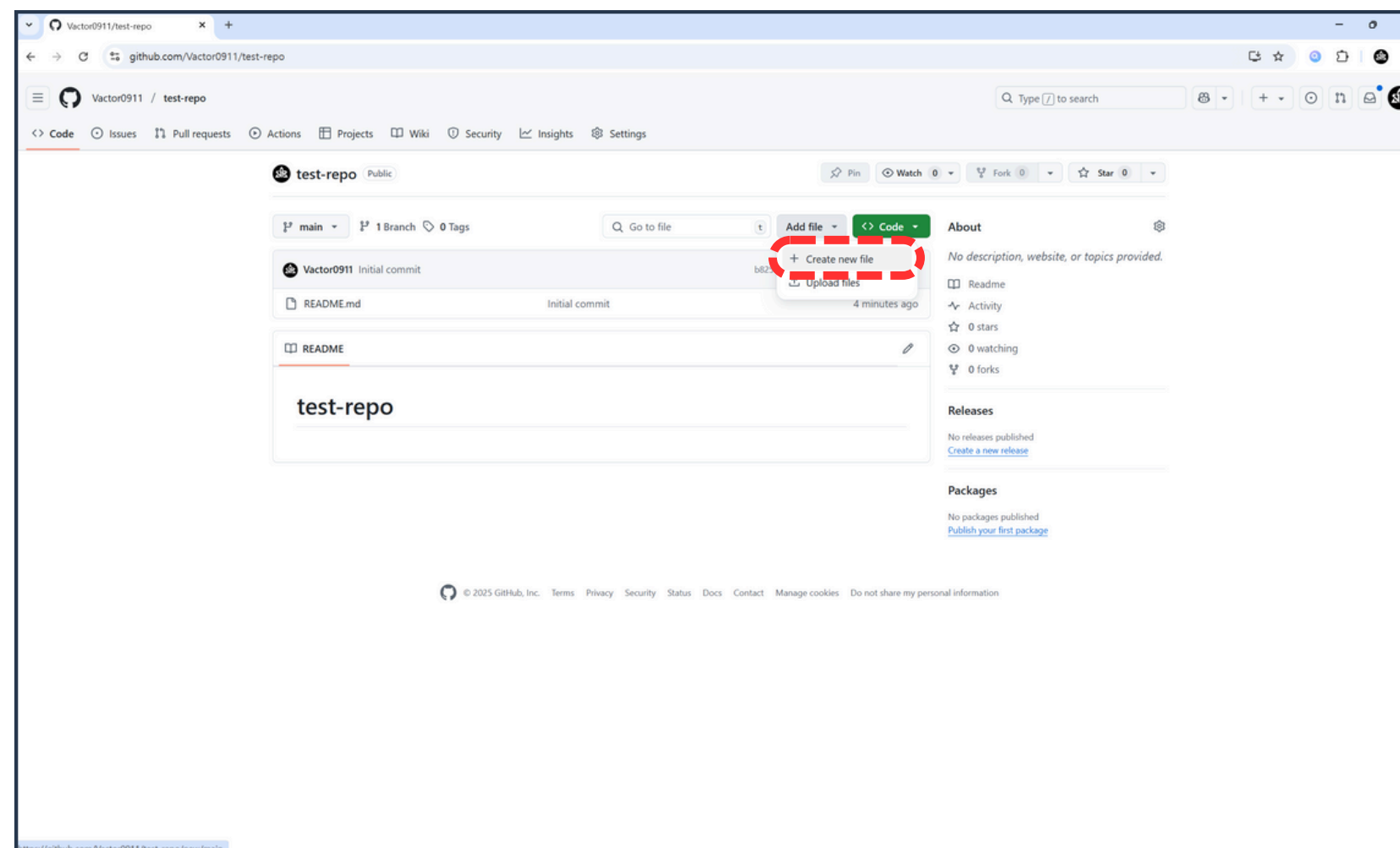
01 Branch 안전하게 보호하기



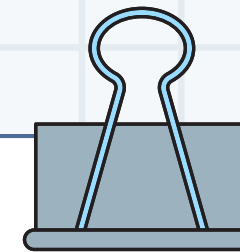
16. GitHub 리포지토리 접속



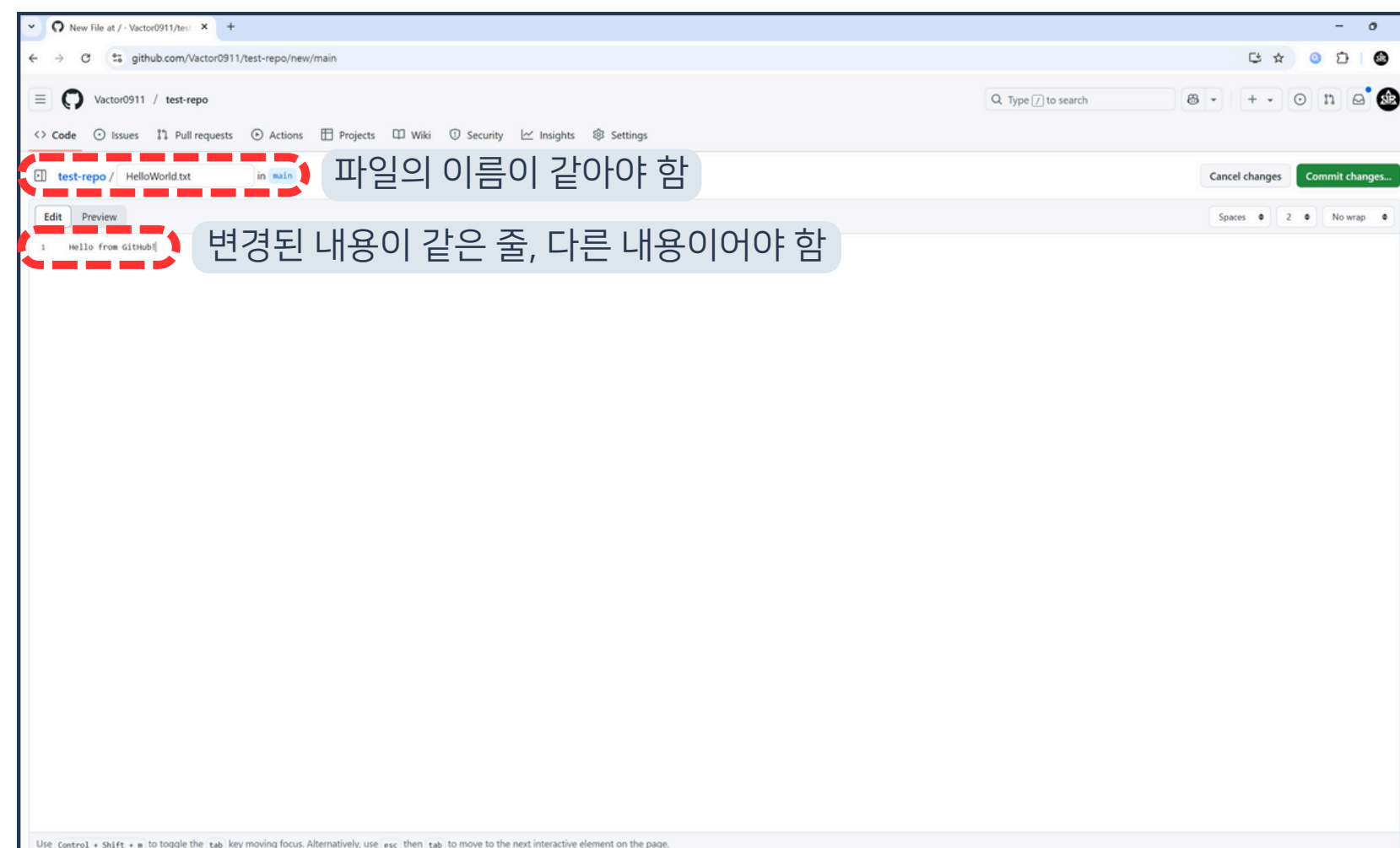
01 Branch 안전하게 보호하기



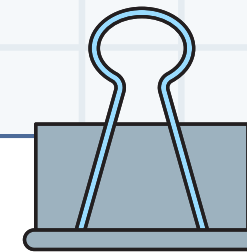
17. Add file > Create new file 버튼 클릭



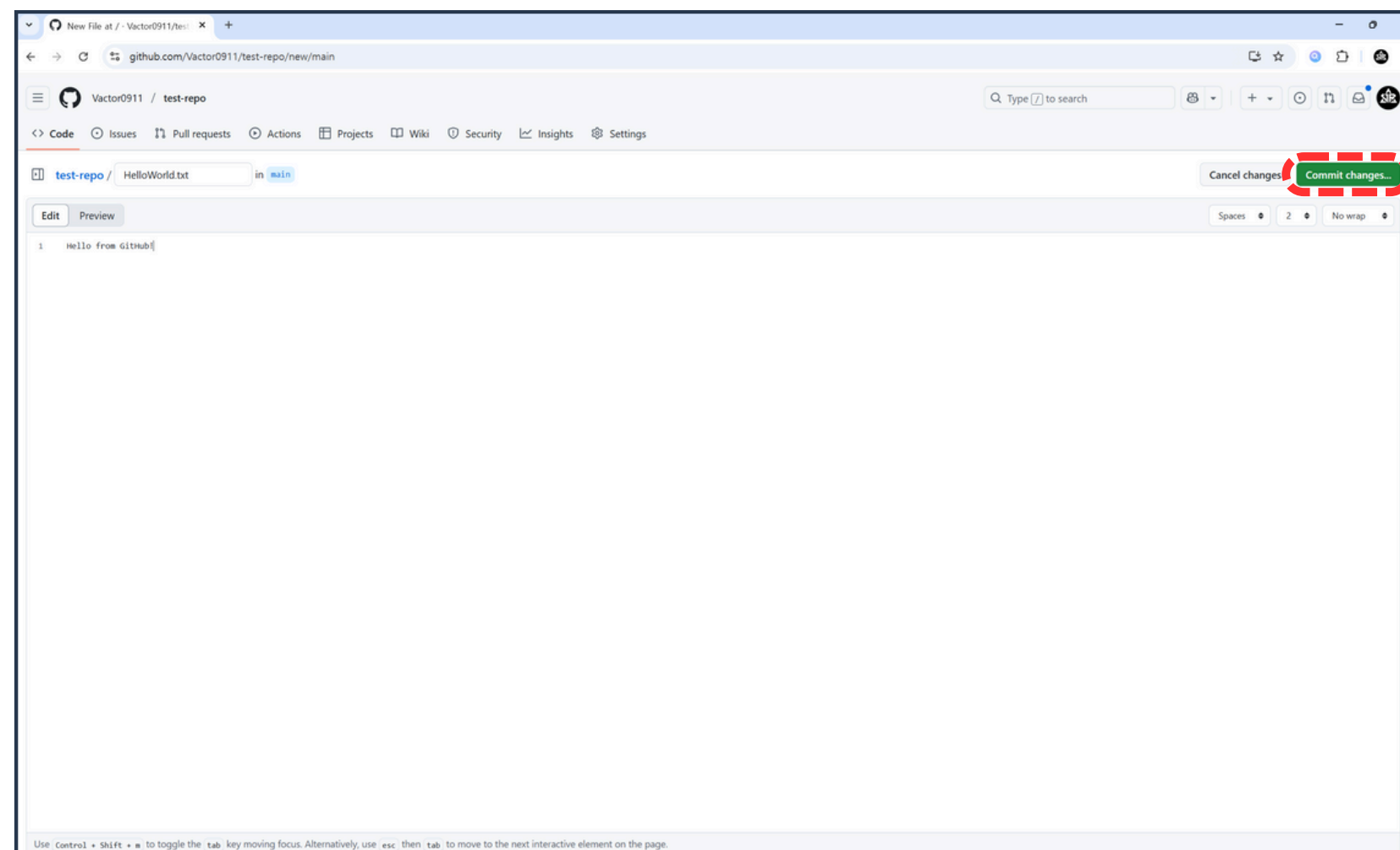
01 Branch 안전하게 보호하기



18. 같은 제목의 파일에 다른 변경점 생성



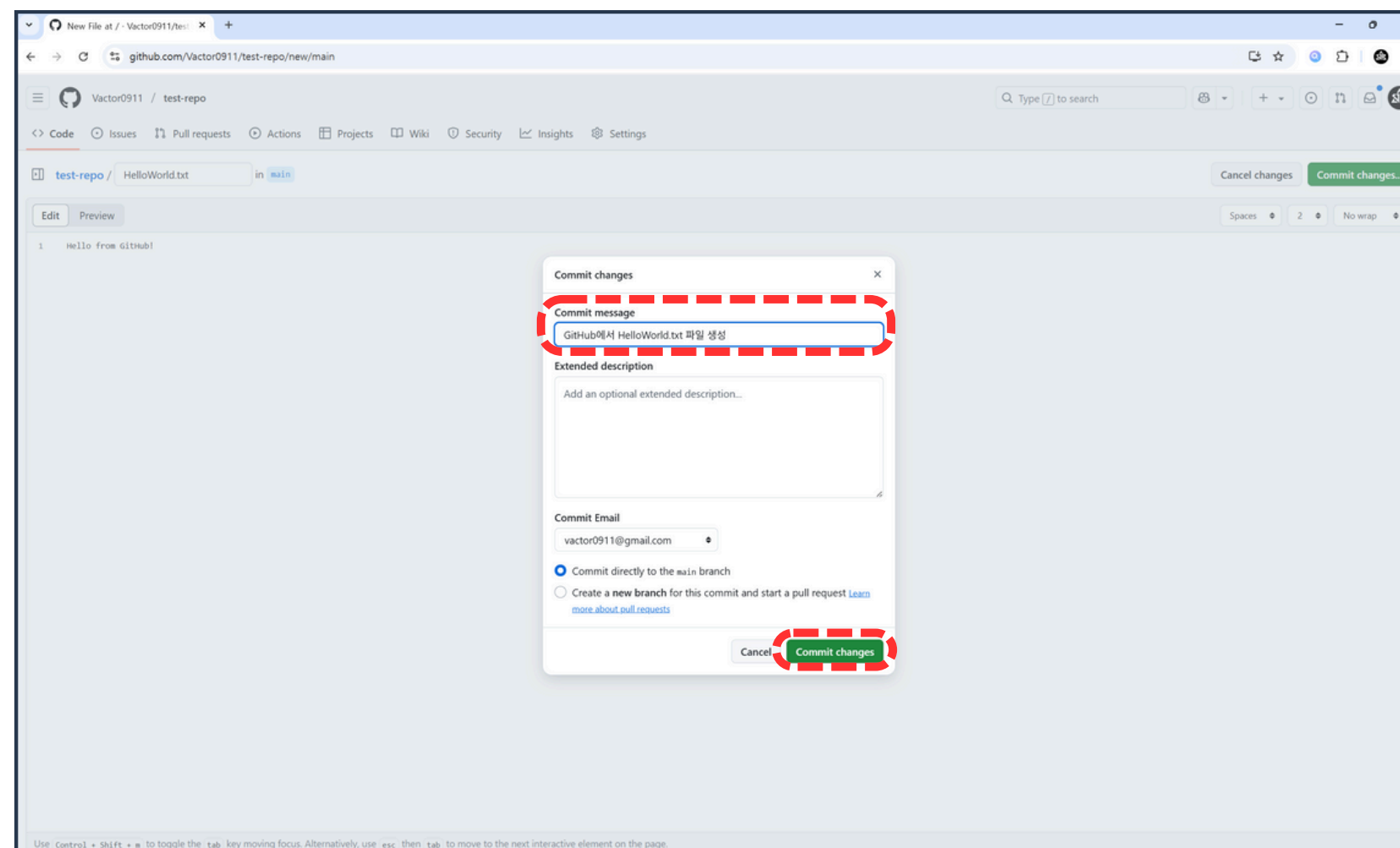
01 Branch 안전하게 보호하기



19. Commit changes 버튼 클릭



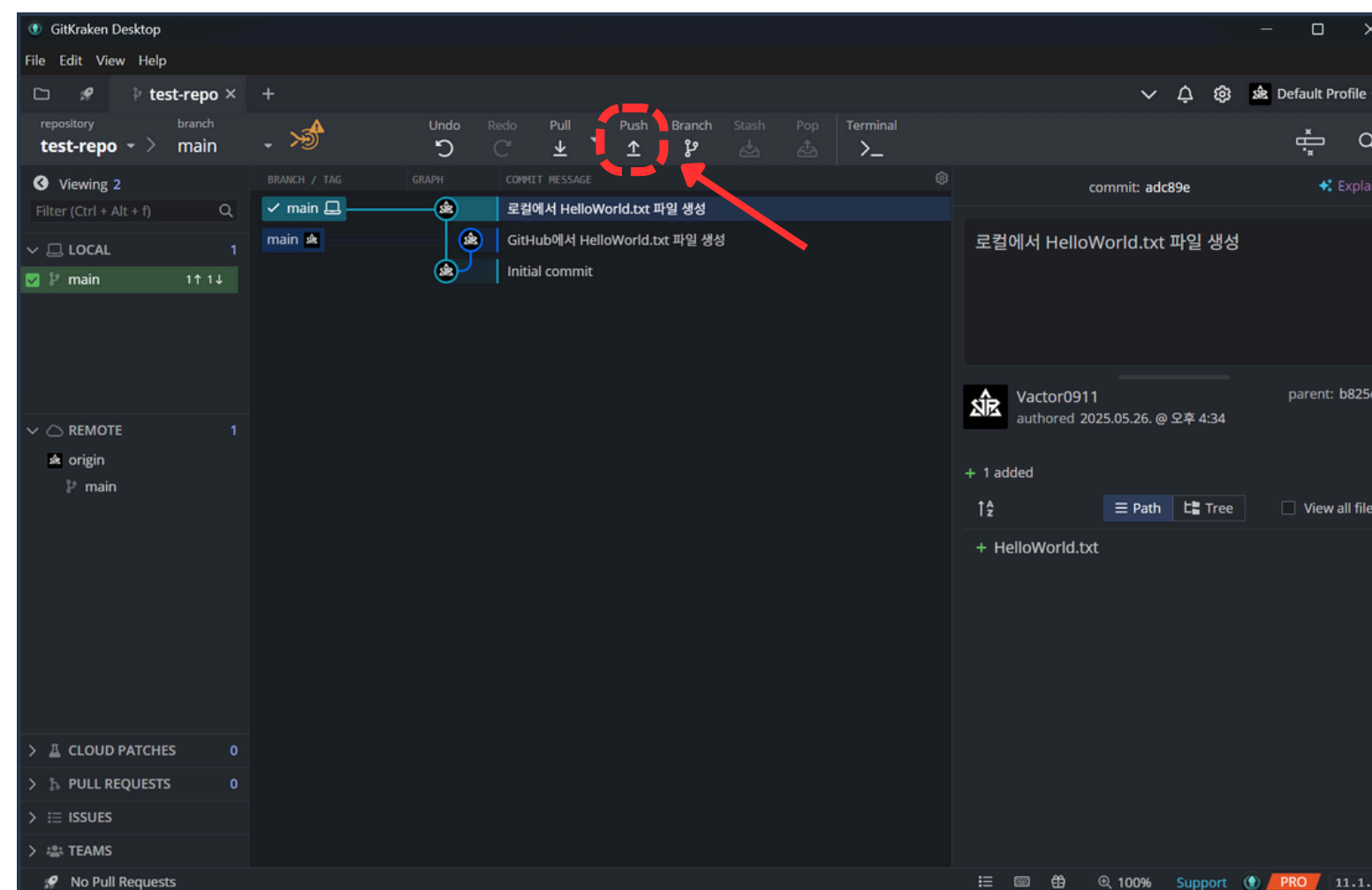
01 Branch 안전하게 보호하기



20. 커밋 메시지 작성 후
Commit changes 버튼 클릭



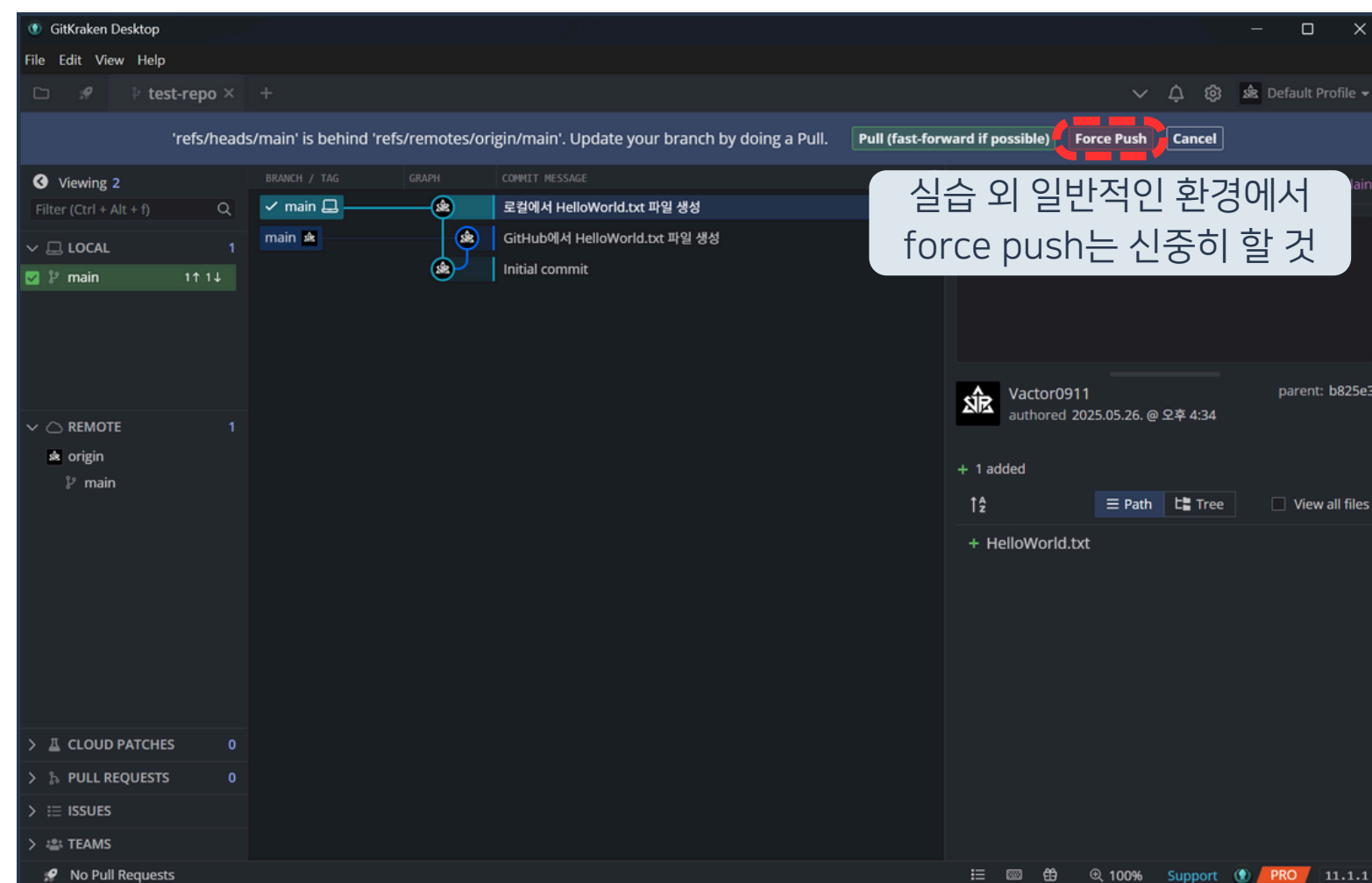
01 Branch 안전하게 보호하기



21. fetch 후 push 버튼 클릭



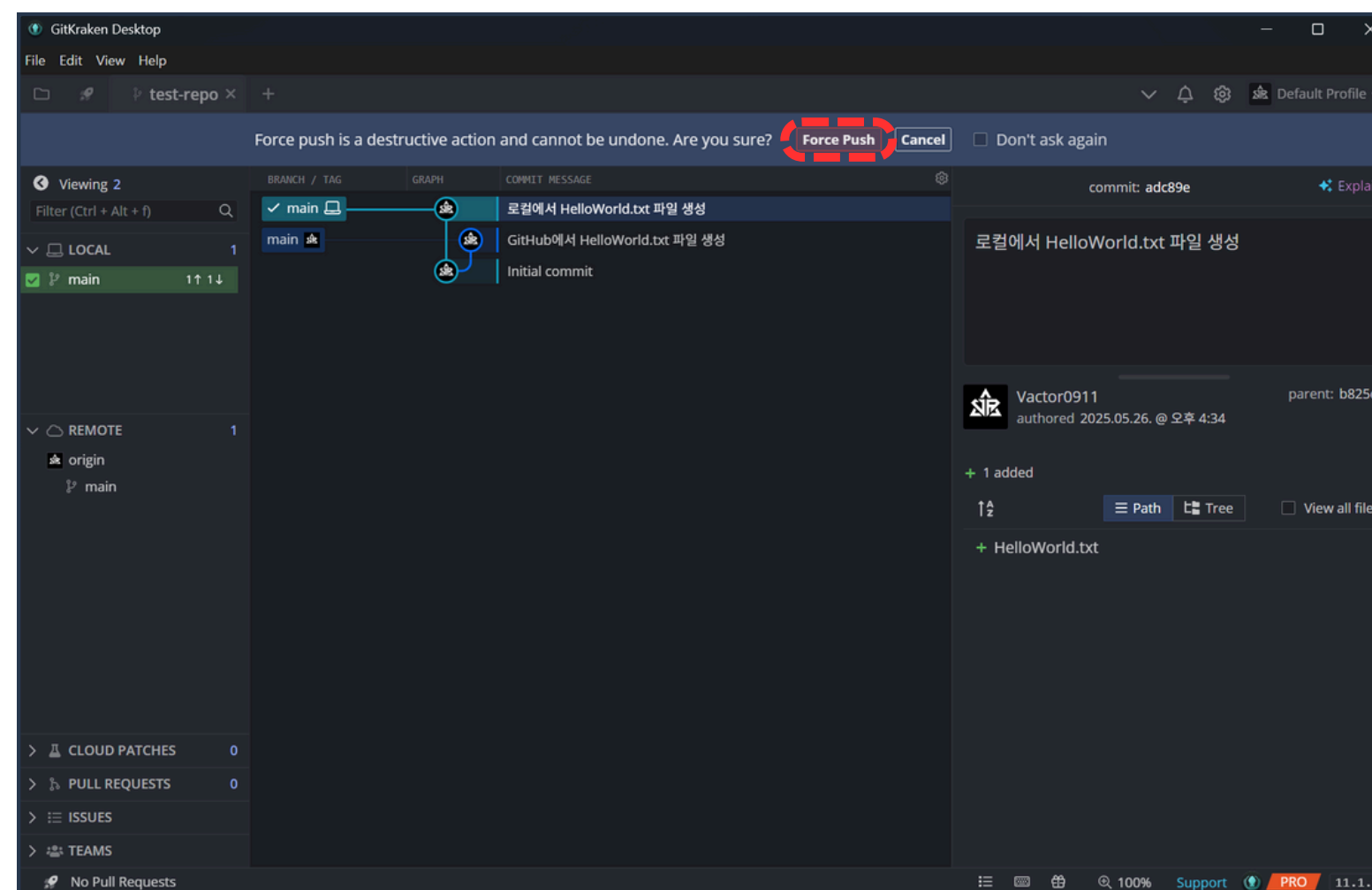
01 Branch 안전하게 보호하기



22. Force Push 버튼 클릭



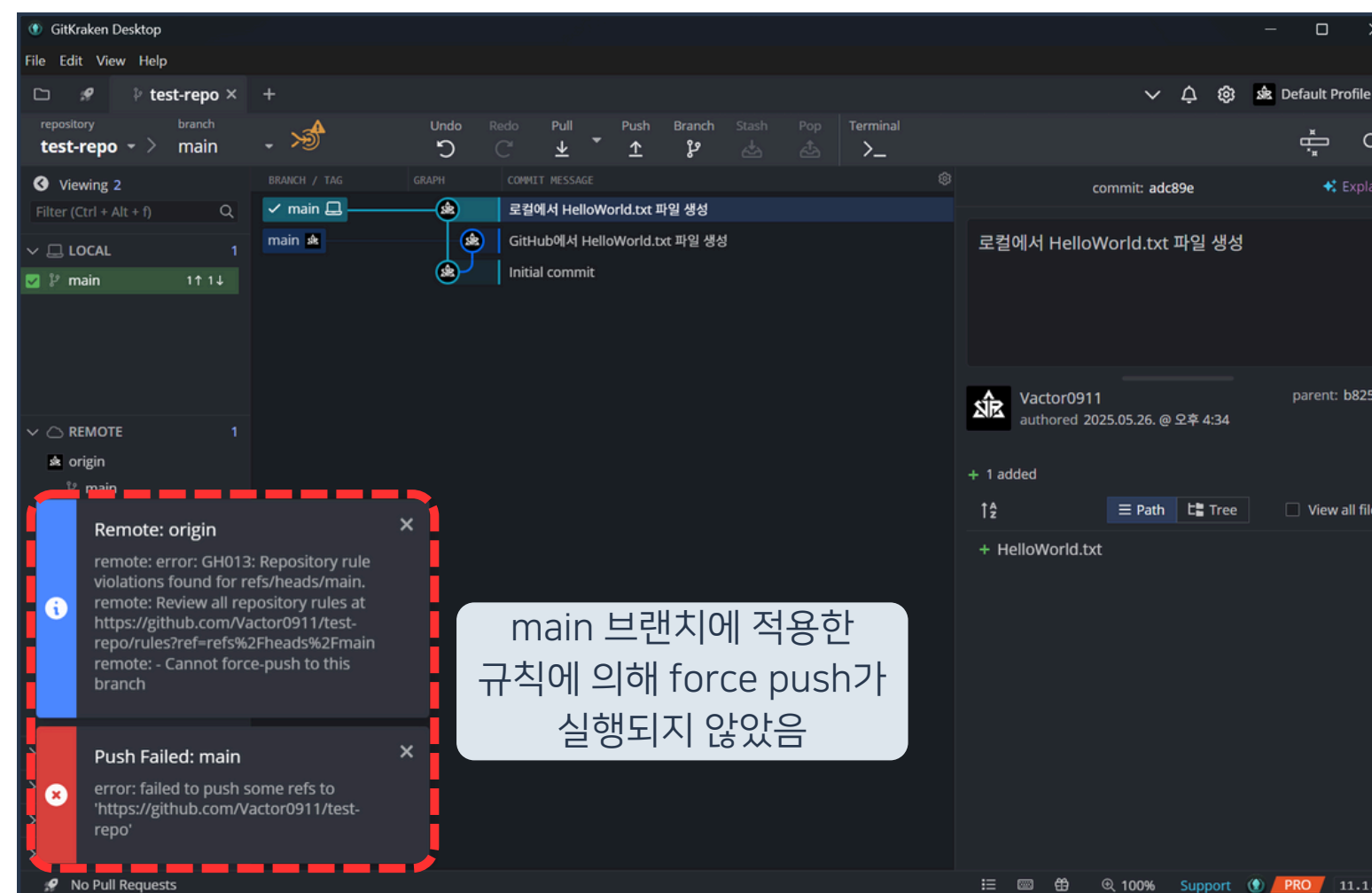
01 Branch 안전하게 보호하기



23. Force Push 버튼 클릭



01 Branch 안전하게 보호하기



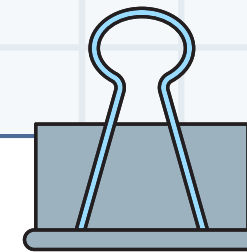
24. Force Push 실패 메시지 확인

|

02

Issue 와 Milestone

|



02 Issue 와 Milestone

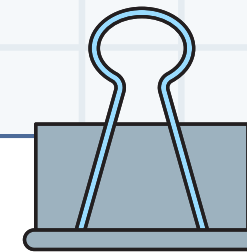


Issue란?

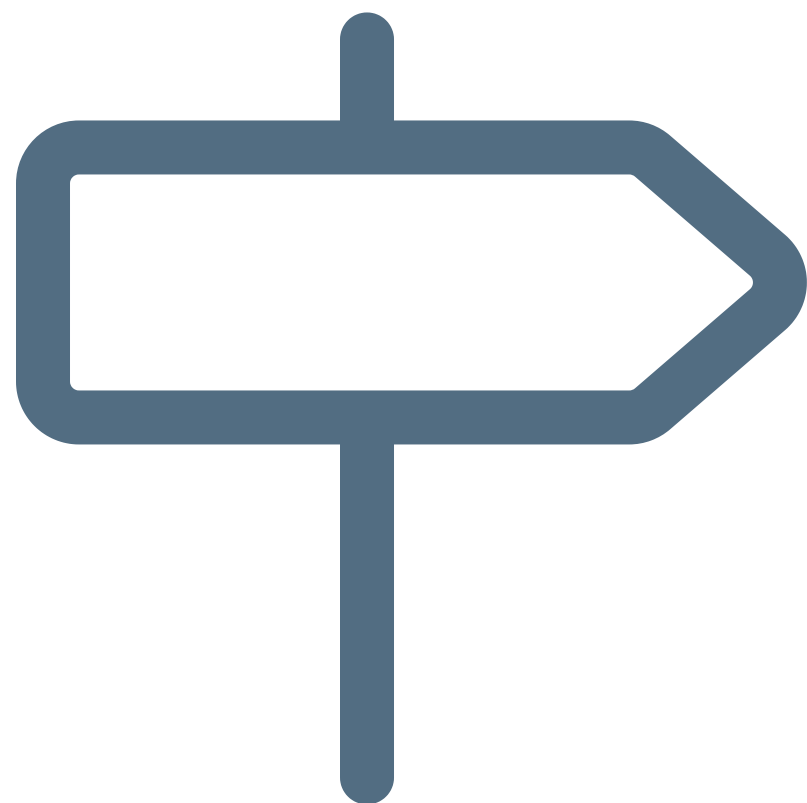
기획, 작업, 버그 수정 등의 활동

프로젝트를 진행하며 발생하는
모든 활동에 대해 이슈를 등록

프로젝트에서 일어나는 모든 활동



02 Issue 와 Milestone



Milestone이란?

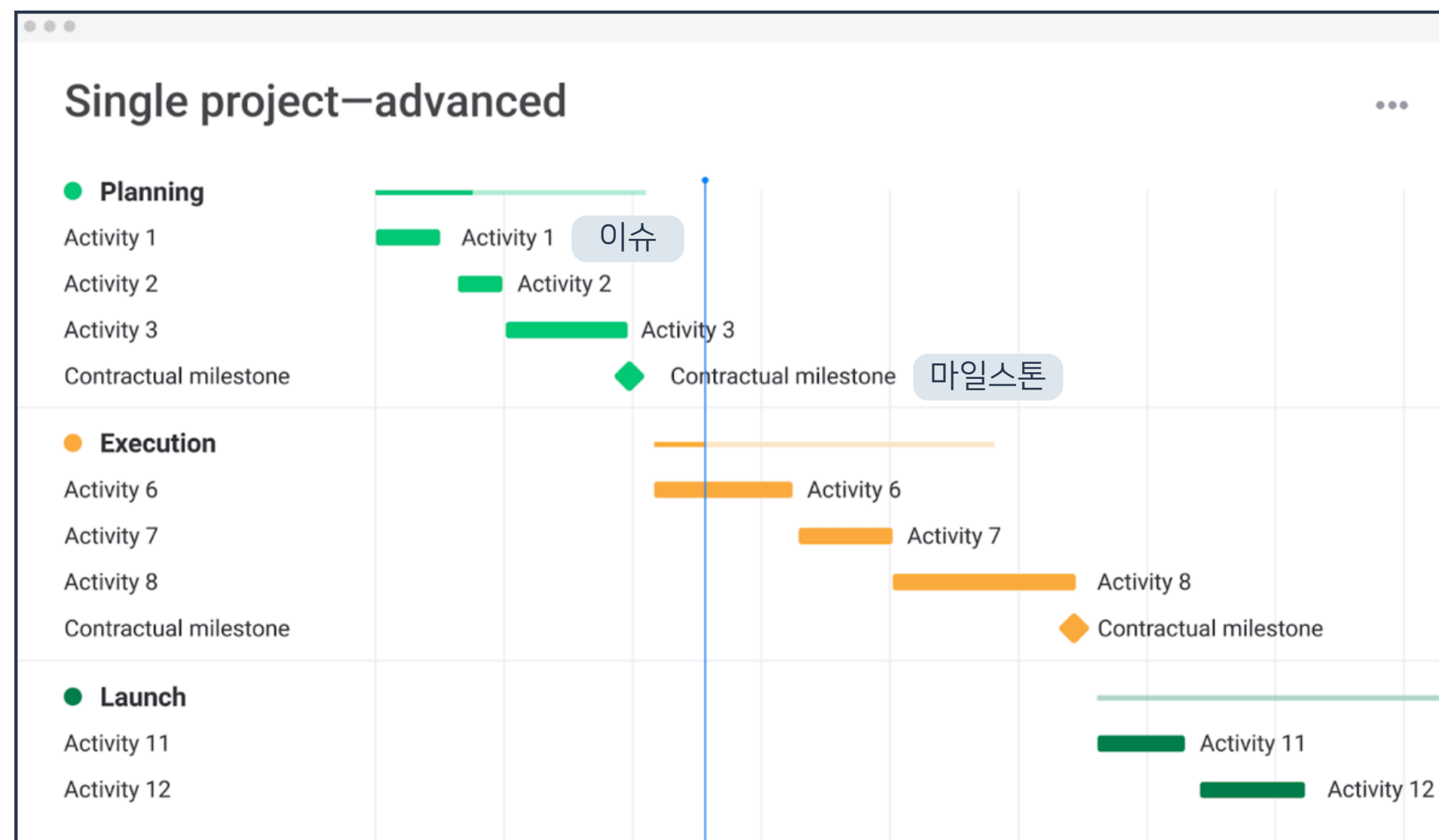
프로젝트 내 작업 방향의 이정표

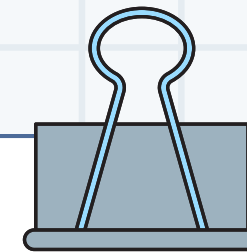
특정 이벤트마다 마일스톤을 등록해
프로젝트가 얼마나 진행됐는지 확인

프로젝트의 진행도를 나타내는 기준점

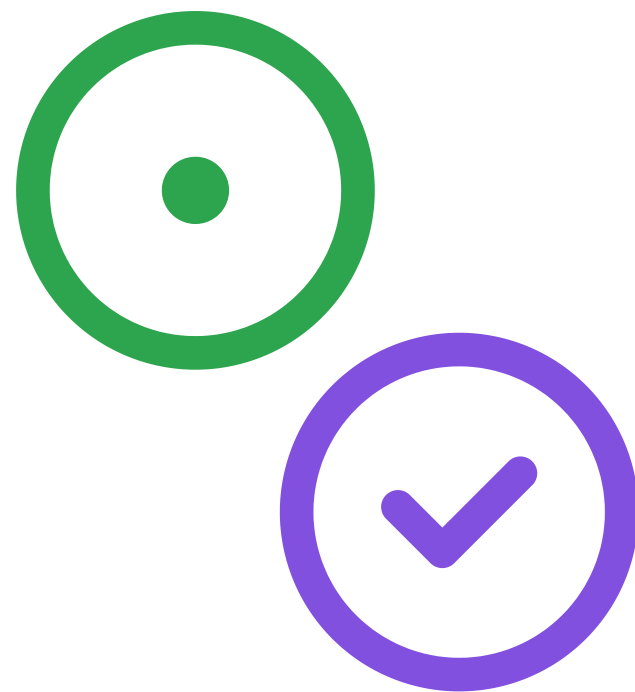


02 Issue 와 Milestone

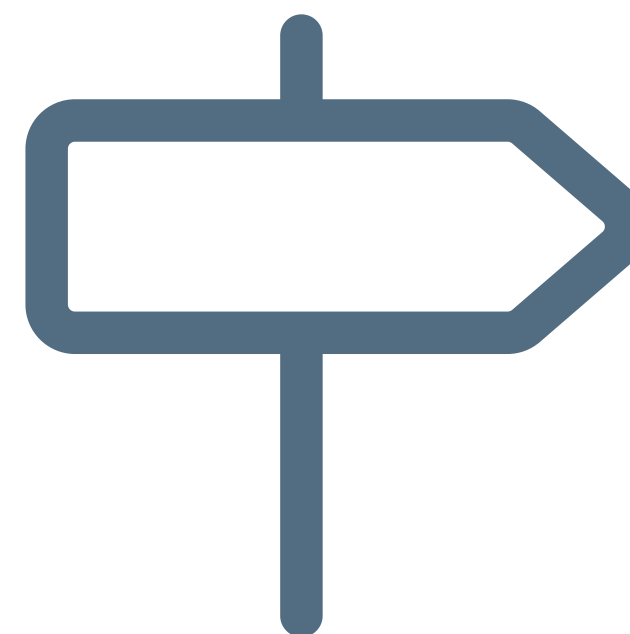




02 Issue 와 Milestone



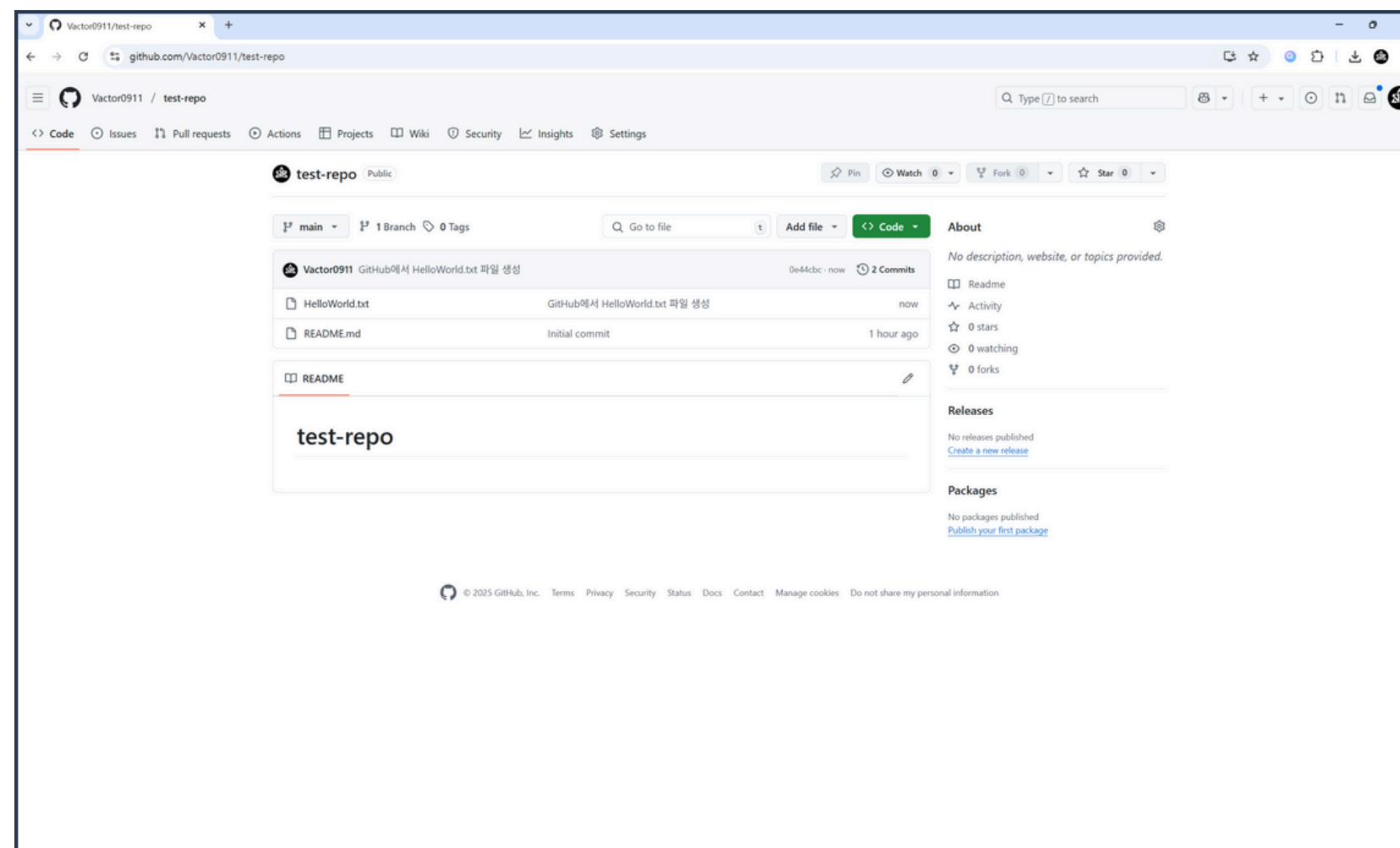
개별 작업을 명시하기 위함



중간 목표를 표시하기 위함



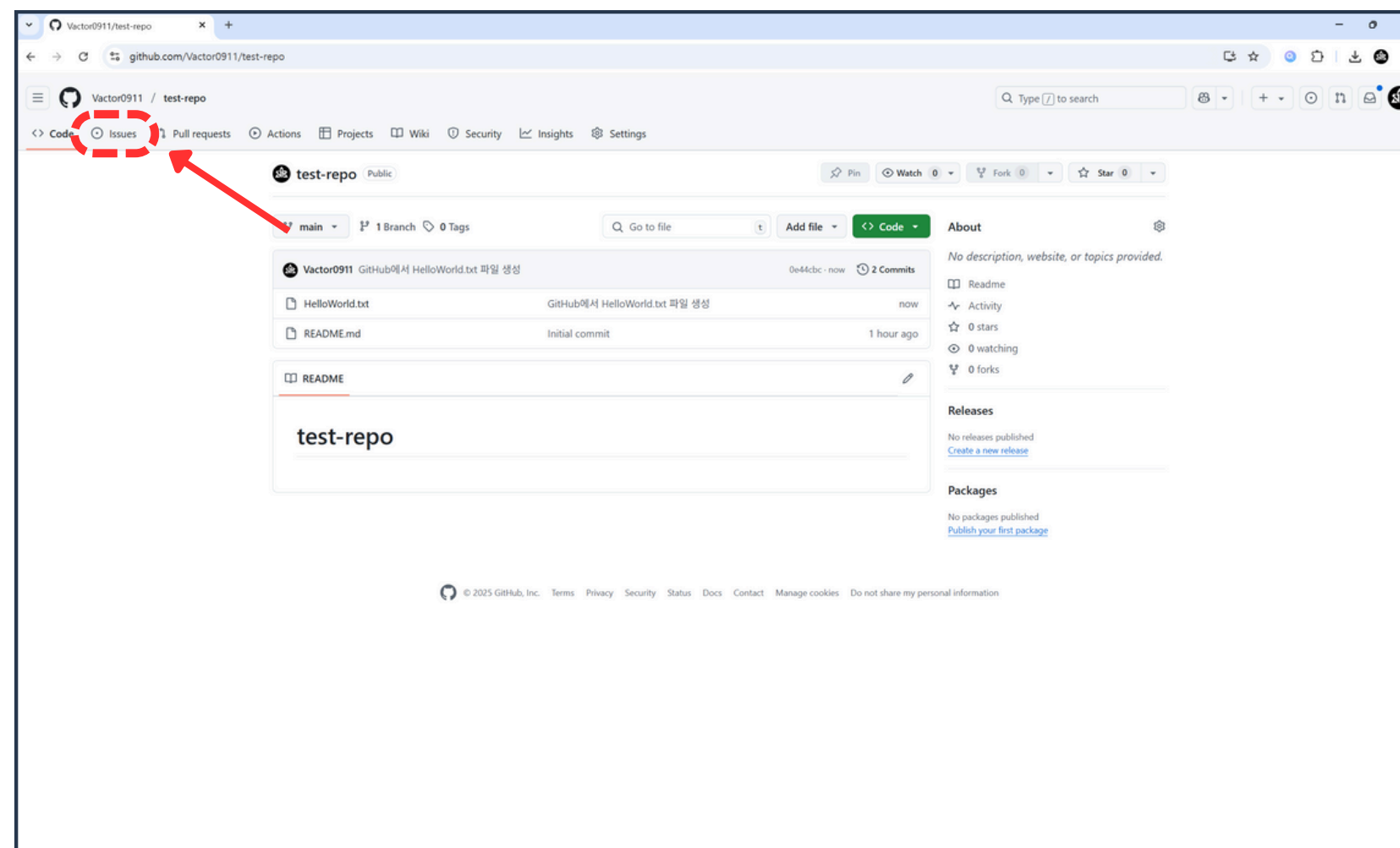
02 Issue 와 Milestone



1. GitHub 리포지토리 접속



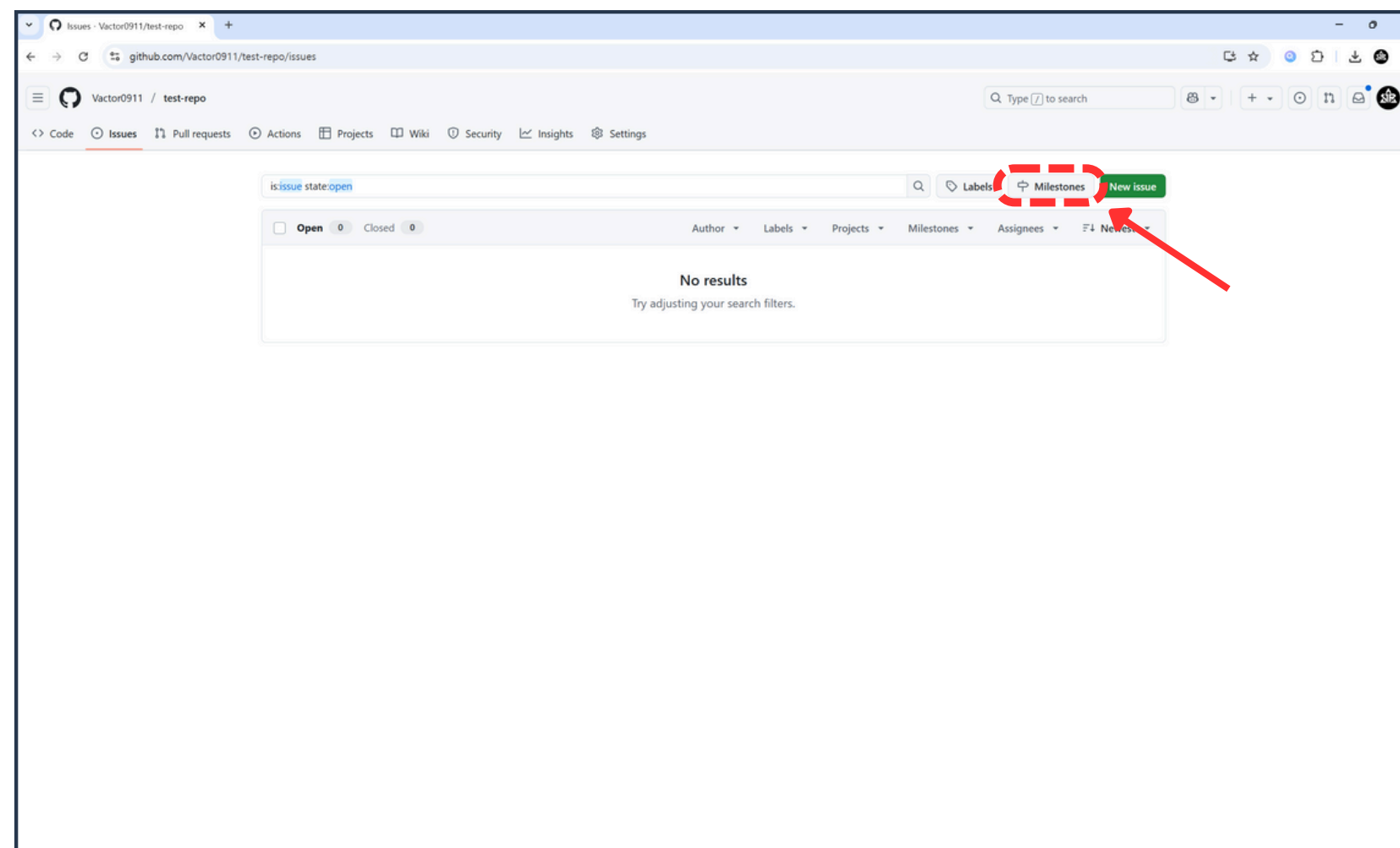
02 Issue 와 Milestone



2. Issues 버튼 클릭



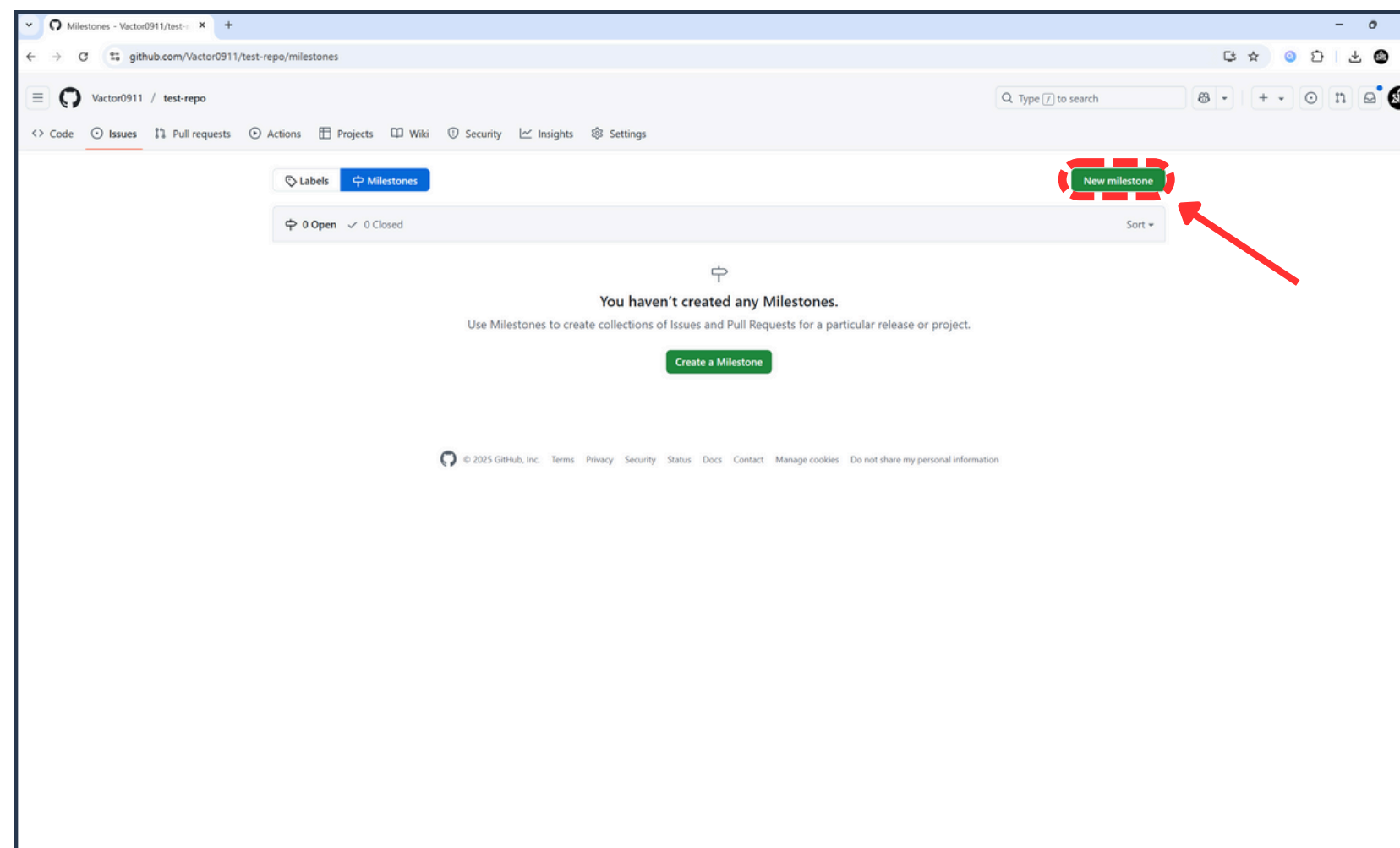
02 Issue 와 Milestone



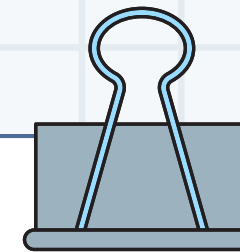
3. Milestones 버튼 클릭



02 Issue 와 Milestone

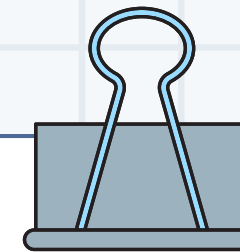


4. New milestone 버튼 클릭

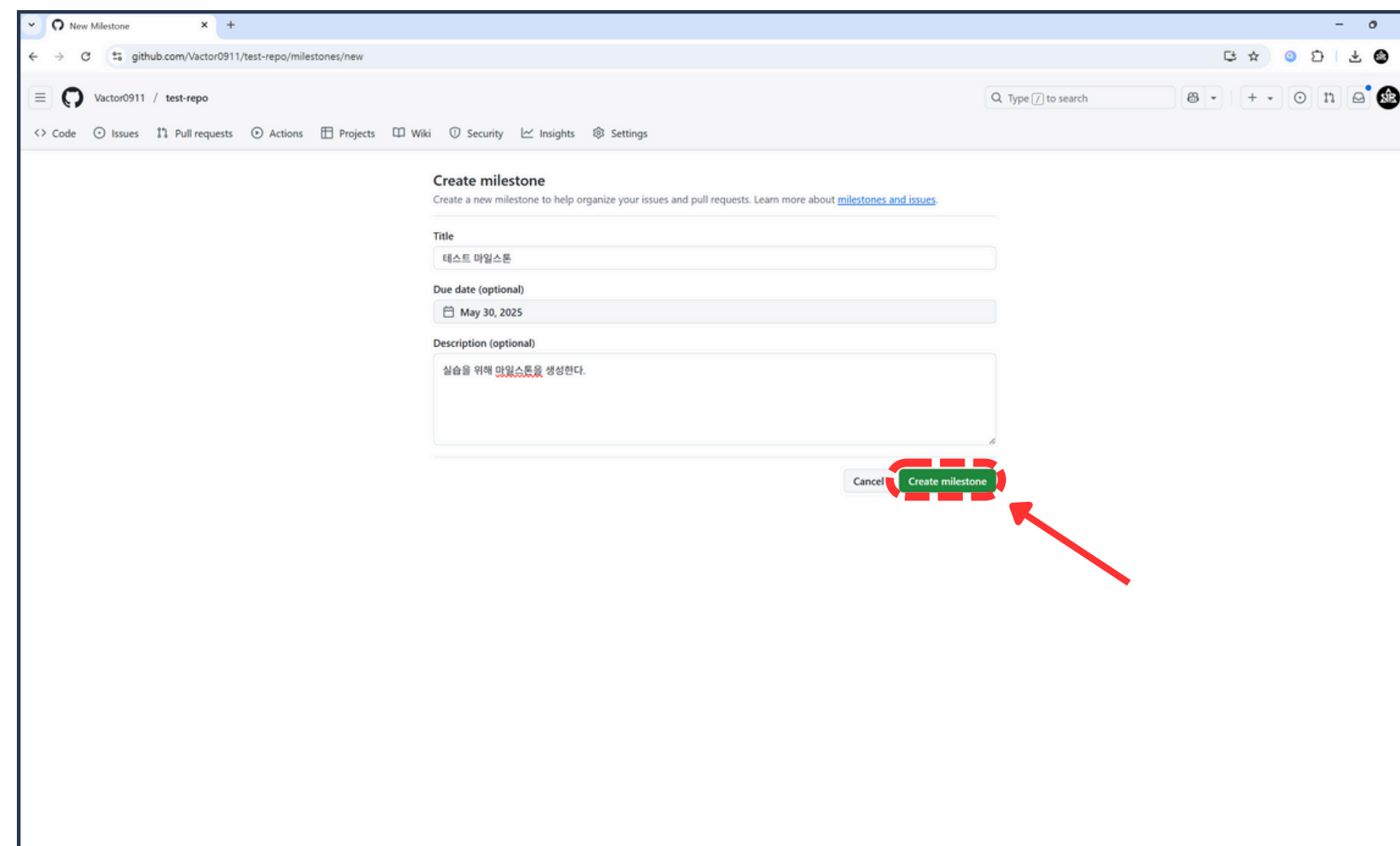


02 Issue 와 Milestone

The screenshot shows the GitHub 'New Milestone' form. The form is titled 'Create milestone' and includes a subtitle: 'Create a new milestone to help organize your issues and pull requests. Learn more about [milestones and issues](#).' The form has three main sections: 'Title' with a text input field labeled '마일스톤 제목' (Milestone title), 'Due date (optional)' with a date picker button labeled '마감 기한' (Due date), and 'Description (optional)' with a text area labeled '마일스톤 설명' (Milestone description). At the bottom right, there are two buttons: 'Cancel' and 'Create milestone'.



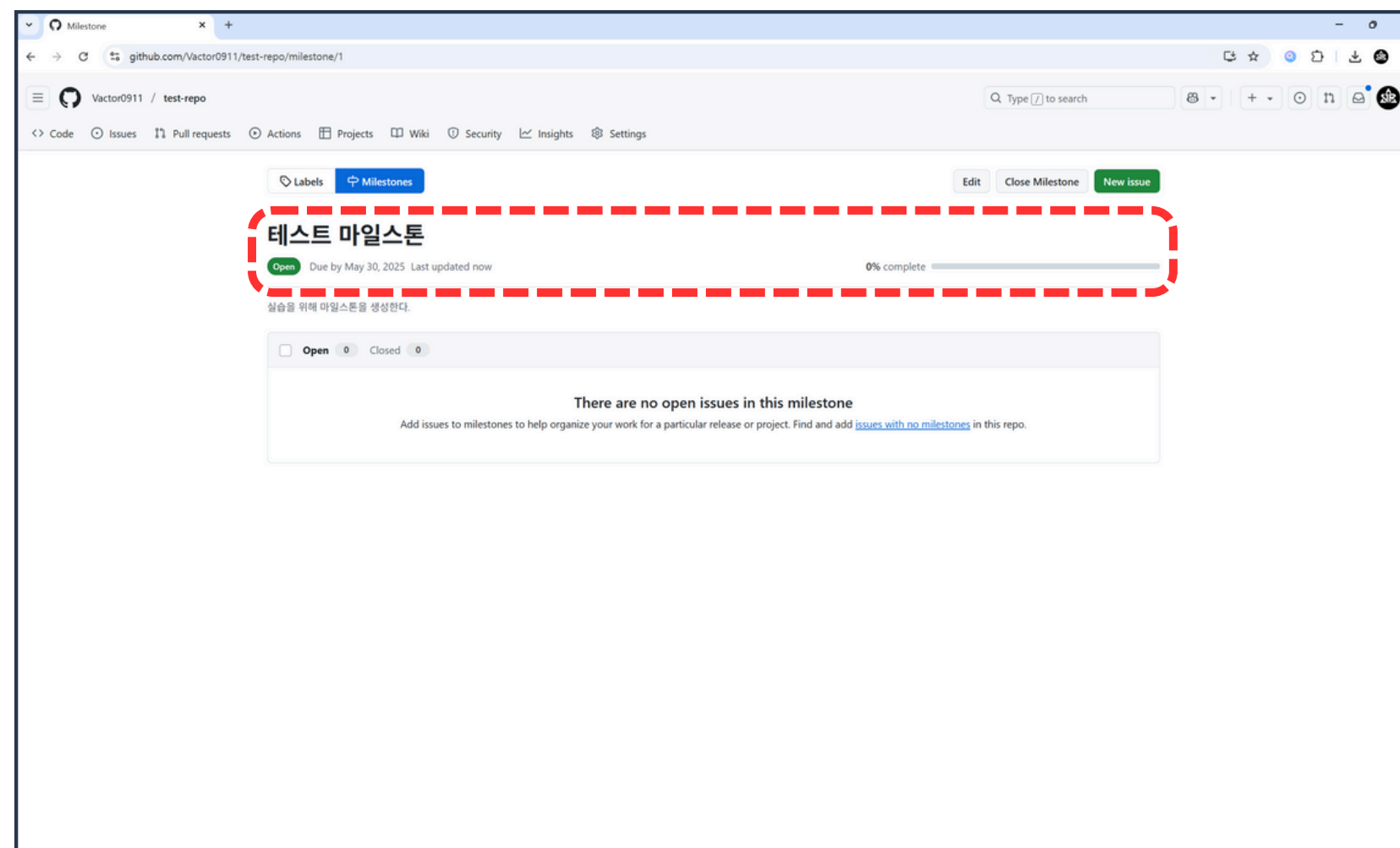
02 Issue 와 Milestone



5. 내용 입력 후 Create milestone 버튼 클릭



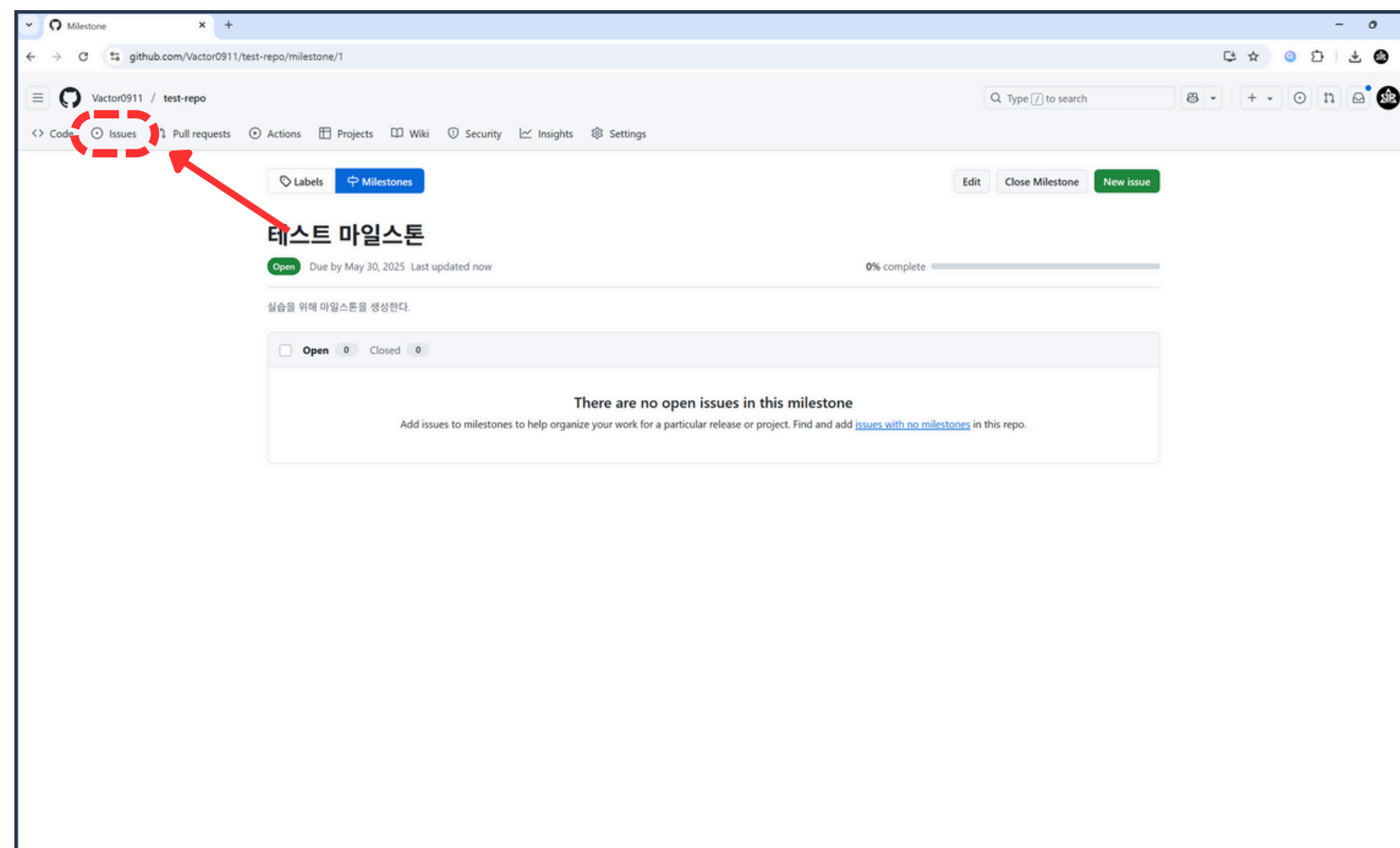
02 Issue 와 Milestone



6. 마일스톤 생성 결과 확인



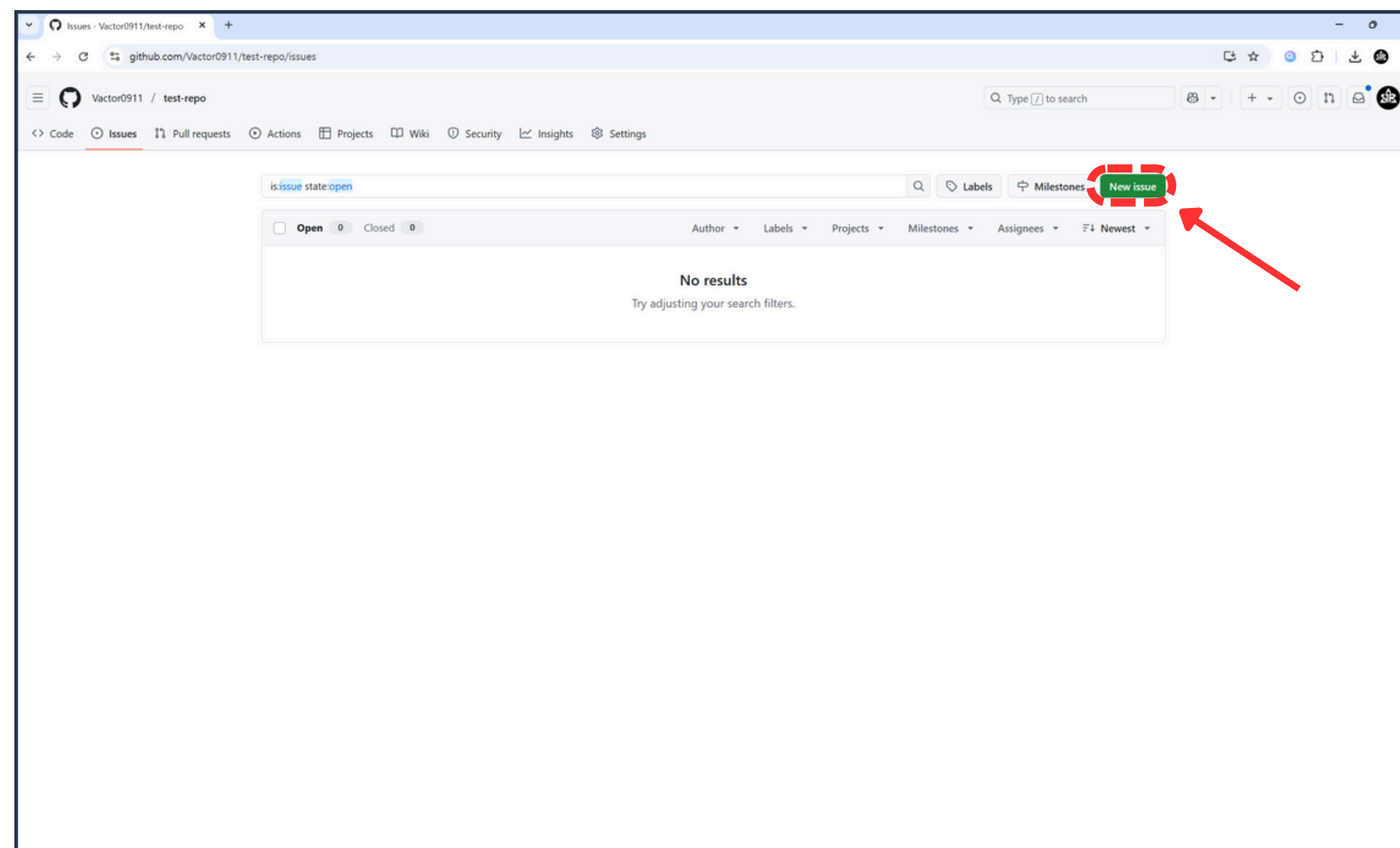
02 Issue 와 Milestone



7. Issues 버튼 클릭



02 Issue 와 Milestone



8. New issues 버튼 클릭

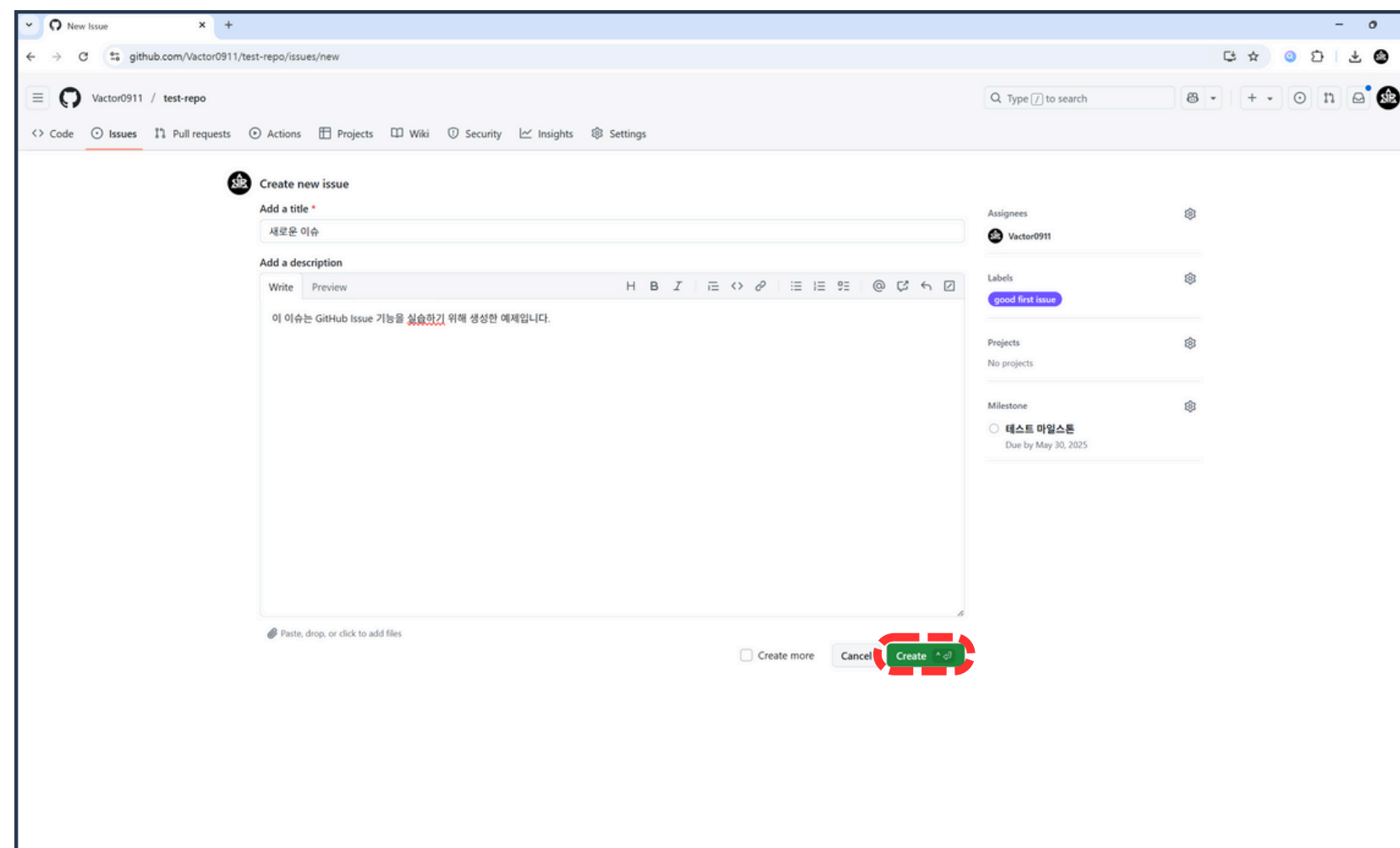


02 Issue 와 Milestone

The screenshot displays the GitHub 'New Issue' interface. The main form includes a title field with the placeholder '이슈 제목', a description field with the placeholder '이슈 설명', and a rich text editor. On the right sidebar, there are sections for 'Assignees' (labeled '담당자'), 'Labels' (labeled '라벨'), 'Projects' (labeled 'GitHub 프로젝트'), and 'Milestone' (labeled '마일스톤'). At the bottom, there are buttons for 'Create more', 'Cancel', and a green 'Create' button.



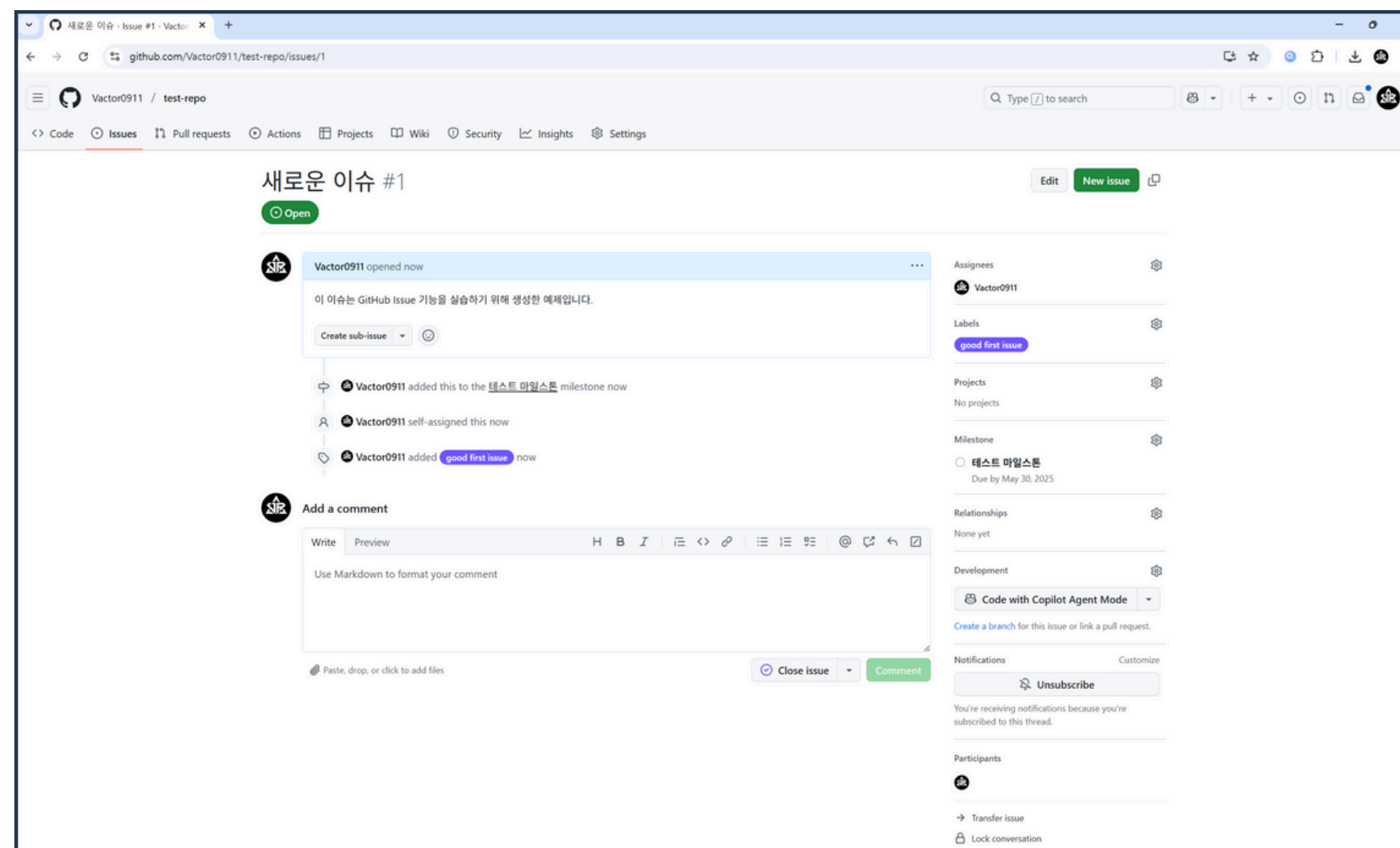
02 Issue 와 Milestone



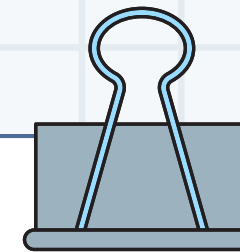
9. 이슈 정보 입력 후 Create 버튼 클릭



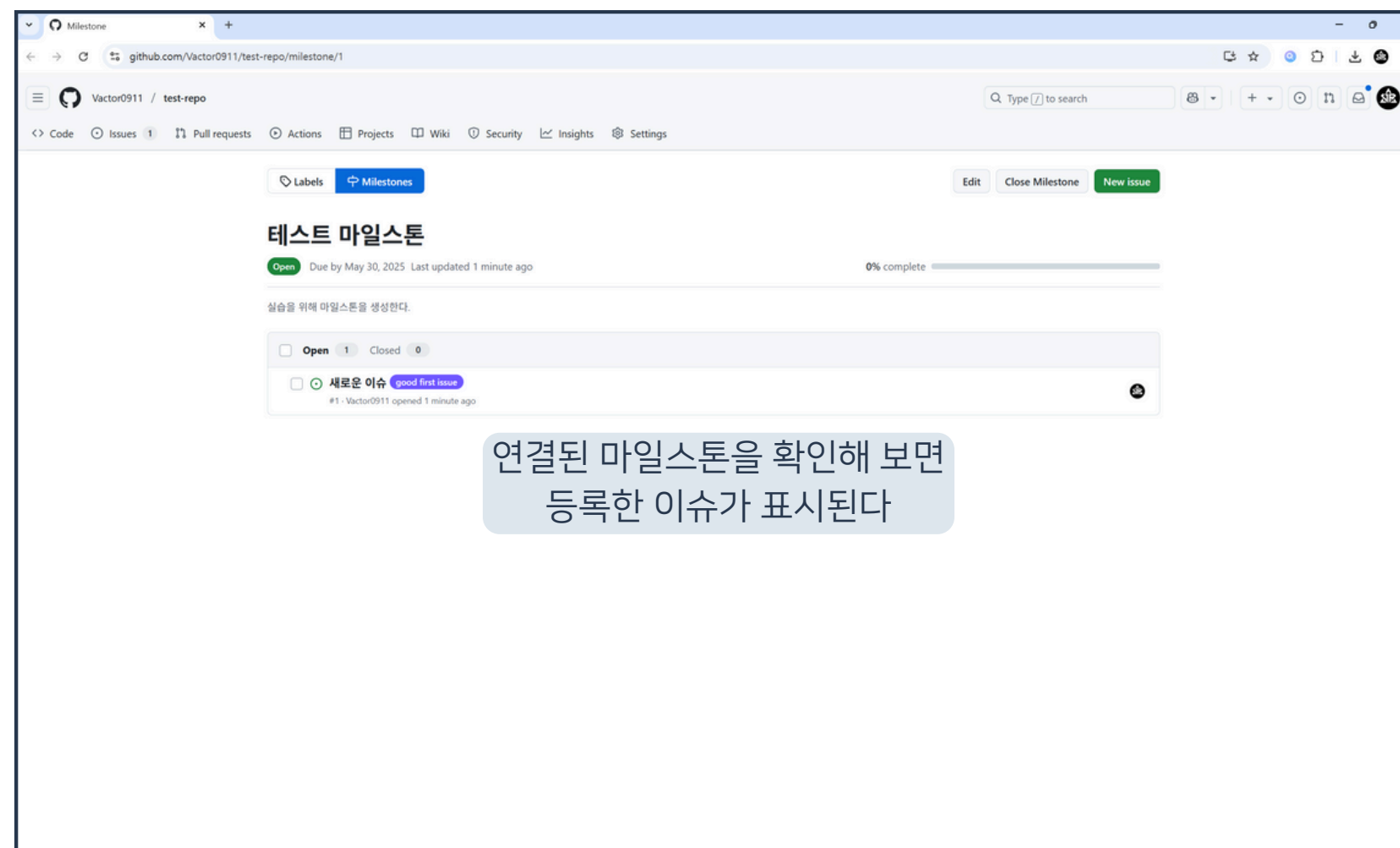
02 Issue 와 Milestone

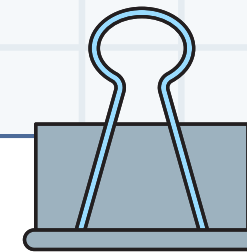


10. 이슈 생성 결과 확인



02 Issue 와 Milestone





02 Issue 와 Milestone

더 살펴보면 좋은 기능

GitHub Project

Issue Template, PR Template

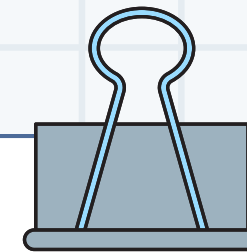
Webhooks

|

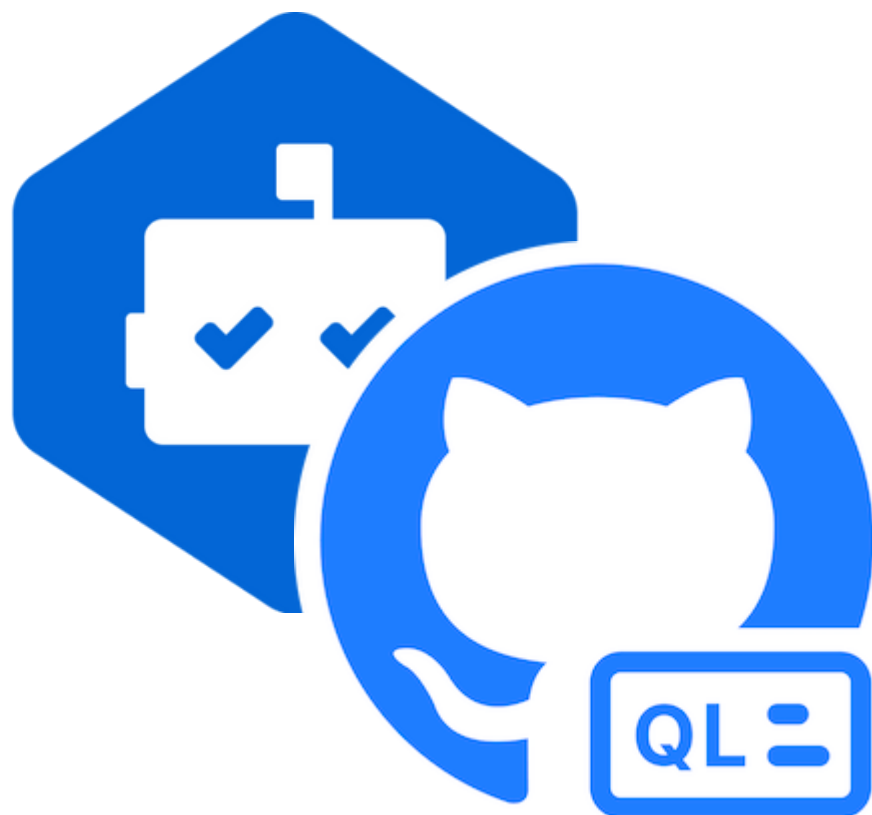
03

DependaBot과 CodeQL

|



03 DependaBot과 CodeQL



DependaBot & CodeQL

프로젝트 내 다양한 취약점을
분석, 해결해 주는 도구

소스 코드 및 라이브러리 취약점 탐지

취약점을 탐지하고 해결책을 제시하는 도구

03 DependaBot과 CodeQL



DependaBot

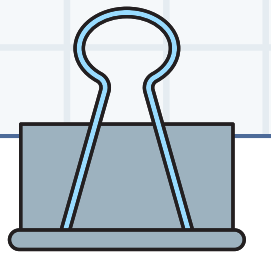
라이브러리 취약점 탐지



CodeQL

소스 코드 취약점 탐지

03 DependaBot과 CodeQL



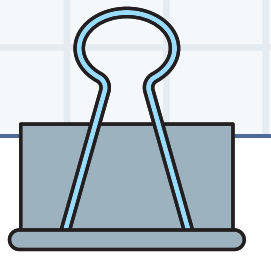
DependaBot

라이브러리, 패키지 취약점 경고

종속성 버전 업데이트 확인

설정된 시간마다 자동 실행

03 DependaBot과 CodeQL



CodeQL

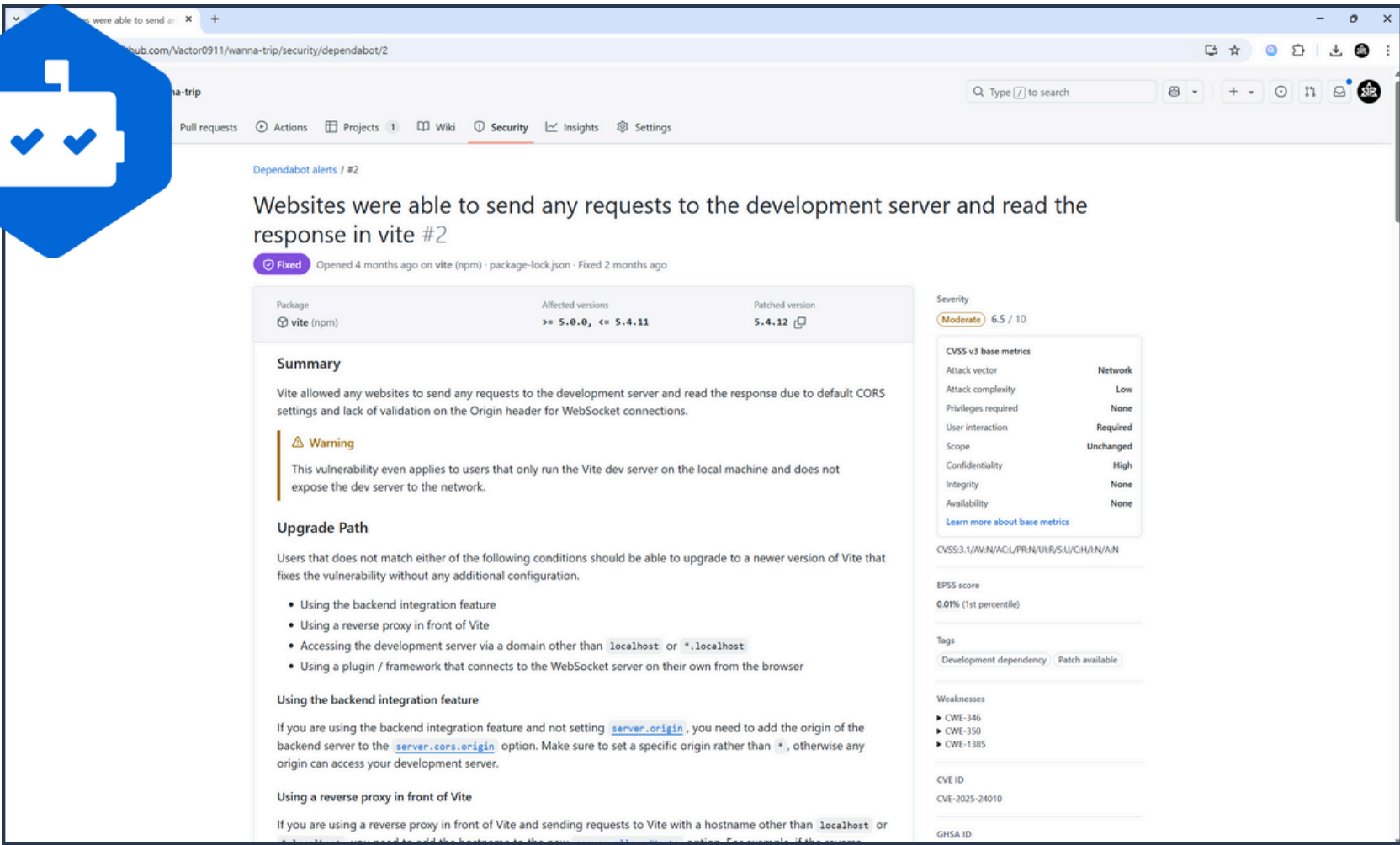
코드 취약점 및 오류 검사

코드 리뷰 진행 후 보고서 작성

다양한 프로그래밍 언어 지원



03 DependaBot과 CodeQL



Dependabot alerts / #2

Websites were able to send any requests to the development server and read the response in vite #2

Fixed Opened 4 months ago on vite (npm) · package-lock.json · Fixed 2 months ago

Package	Affected versions	Patched version
vite (npm)	<code>>= 5.0.0, <= 5.4.11</code>	<code>5.4.12</code>

Summary

Vite allowed any websites to send any requests to the development server and read the response due to default CORS settings and lack of validation on the Origin header for WebSocket connections.

Warning

This vulnerability even applies to users that only run the Vite dev server on the local machine and does not expose the dev server to the network.

Upgrade Path

Users that does not match either of the following conditions should be able to upgrade to a newer version of Vite that fixes the vulnerability without any additional configuration.

- Using the backend integration feature
- Using a reverse proxy in front of Vite
- Accessing the development server via a domain other than `localhost` or `*.localhost`
- Using a plugin / framework that connects to the WebSocket server on their own from the browser

Using the backend integration feature

If you are using the backend integration feature and not setting `server.origin`, you need to add the origin of the backend server to the `server.cors.origin` option. Make sure to set a specific origin rather than `*`, otherwise any origin can access your development server.

Using a reverse proxy in front of Vite

If you are using a reverse proxy in front of Vite and sending requests to Vite with a hostname other than `localhost` or `*.localhost`, you need to add the hostname to the `server.cors.origin` option. For example, if the server

Severity

Moderate 6.5 / 10

CVSS v3 base metrics

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	Required
Scope	Unchanged
Confidentiality	High
Integrity	None
Availability	None

[Learn more about base metrics](#)

CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A/N

EPSS score

0.01% (1st percentile)

Tags

Development dependency Patch available

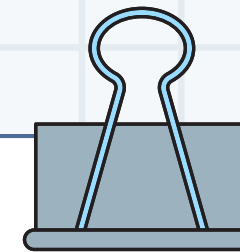
Weaknesses

- CWE-346
- CWE-350
- CWE-1385

CVE ID

CVE-2025-24010

GHSA ID



03 DependaBot과 CodeQL

Workflow does not contain permissions

Fixed in main last week

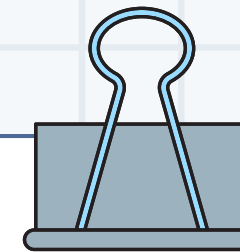
```
.github/workflows/deploy.yml:10
7
8 jobs:
9   deploy:
10     runs-on: ubuntu-latest
11
12     steps:
13     - name: Checkout code
14       uses: actions/checkout@v3
15
16     - name: Set git user
17       run: |
18         git config --global user.email "vactor0911@gmail.com"
19         git config --global user.name "vactor0911"
20
21     - name: Install dependencies
22       run: npm install
23
24     - name: Build the app
25       run: npm run build
26
27     - name: Set up github token for authentication
28       run: |
29         git config --global url."https://${{ secrets.GH_TOKEN }}@github.com:".insteadOf "https://github.com/"
30
31     - name: Deploy to github Pages
32       run: npm run deploy -- --repo https://github.com/${{ github.repository }}.git
33     env:
34       GH_TOKEN: ${{ secrets.GH_TOKEN }}
35       VITE_KAKAO_CLIENT_ID: ${{ secrets.VITE_KAKAO_CLIENT_ID }}
36       VITE_KAKAO_REDIRECT_URI: ${{ secrets.VITE_KAKAO_REDIRECT_URI }}
37       VITE_GOOGLE_CLIENT_ID: ${{ secrets.VITE_GOOGLE_CLIENT_ID }}
38       VITE_GOOGLE_REDIRECT_URI: ${{ secrets.VITE_GOOGLE_REDIRECT_URI }}
39
40 Actions job or workflow does not limit the permissions of the GITHUB_TOKEN. Consider setting an explicit permissions block, using the following as a minimal starting point: (contents: read)
41 CodeQL
```

Severity: Medium

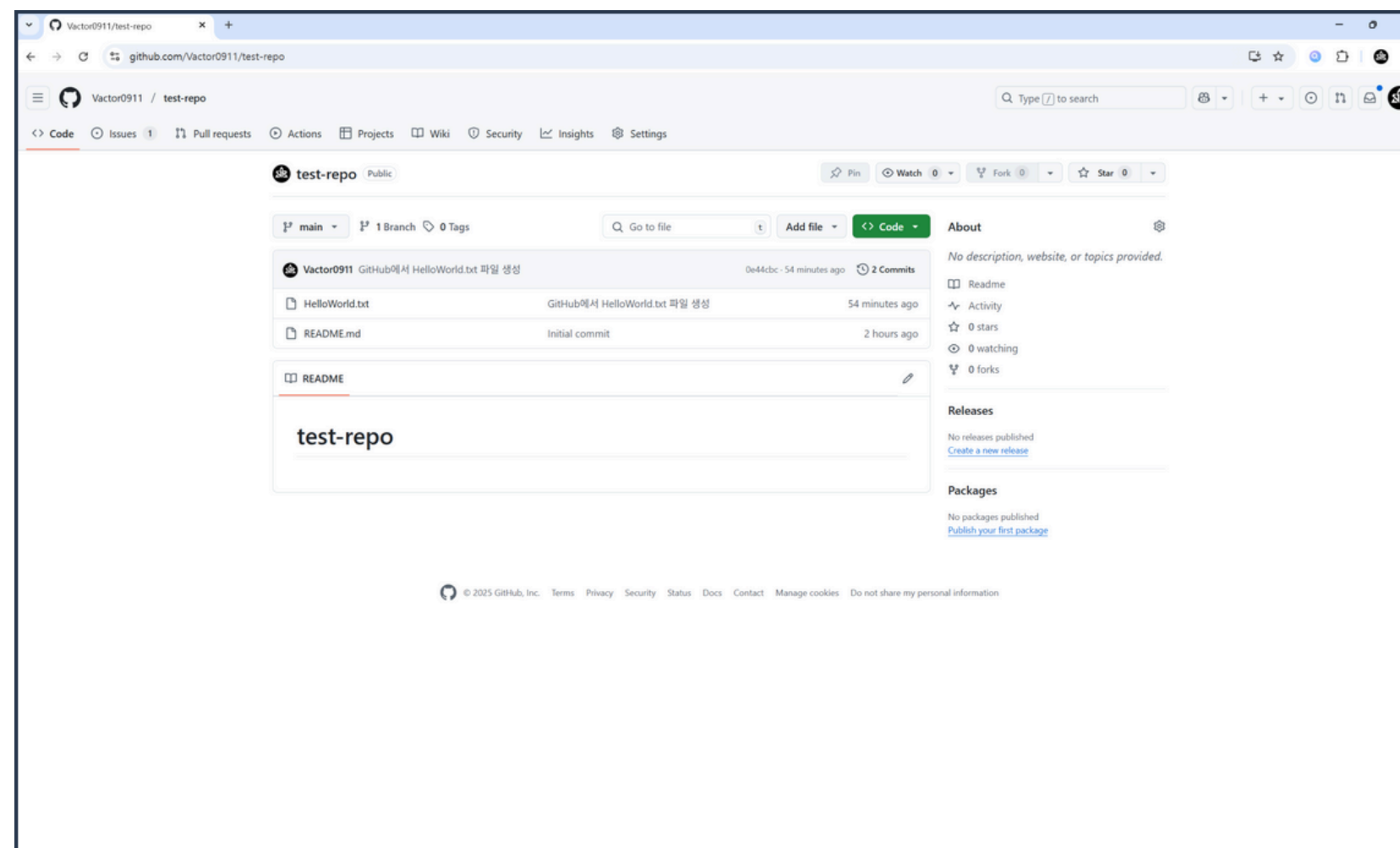
Affected branches: main

Tags: actions, maintainability, security

Weaknesses: CWE-275



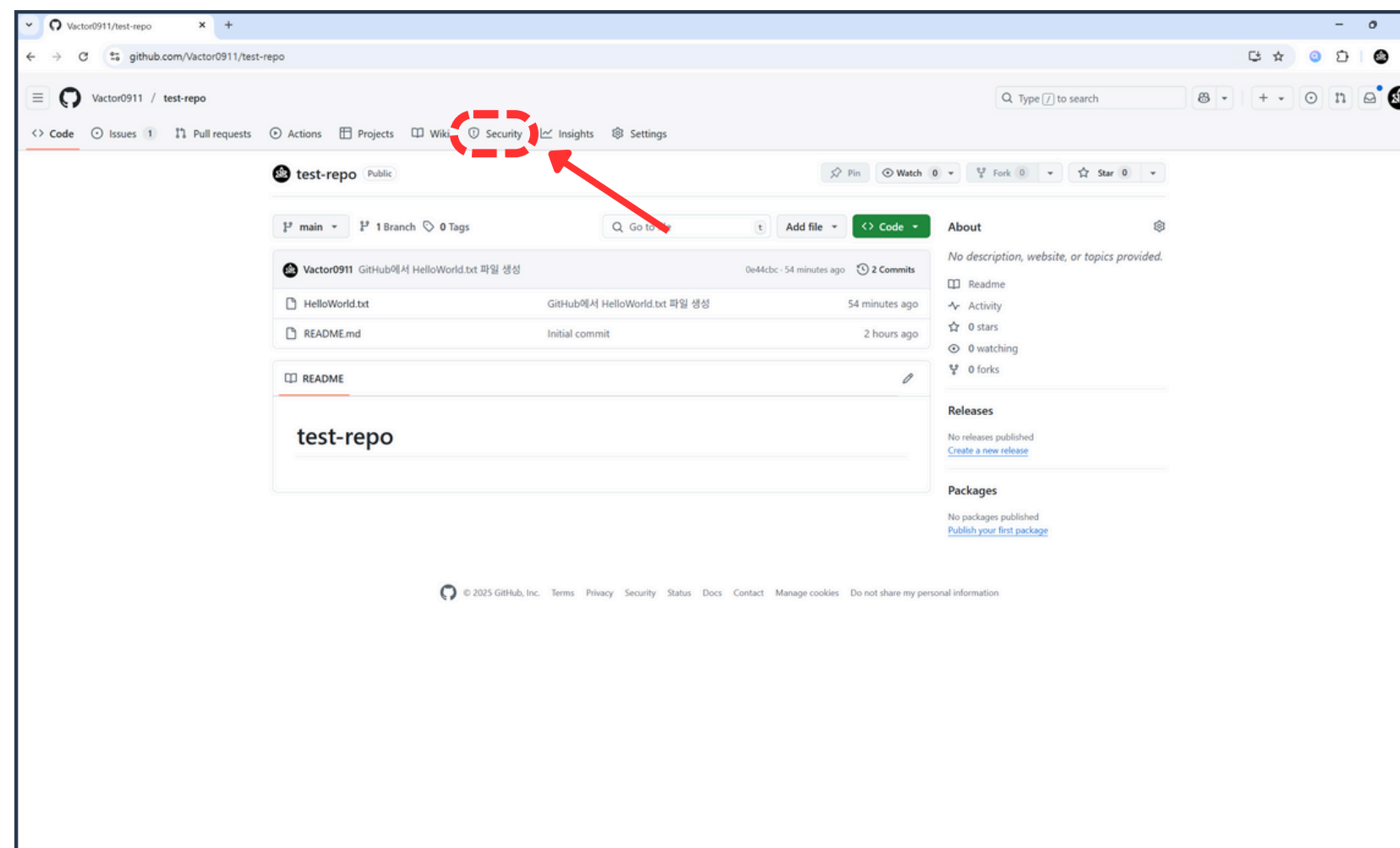
03 DependaBot과 CodeQL



1. GitHub 리포지토리 접속



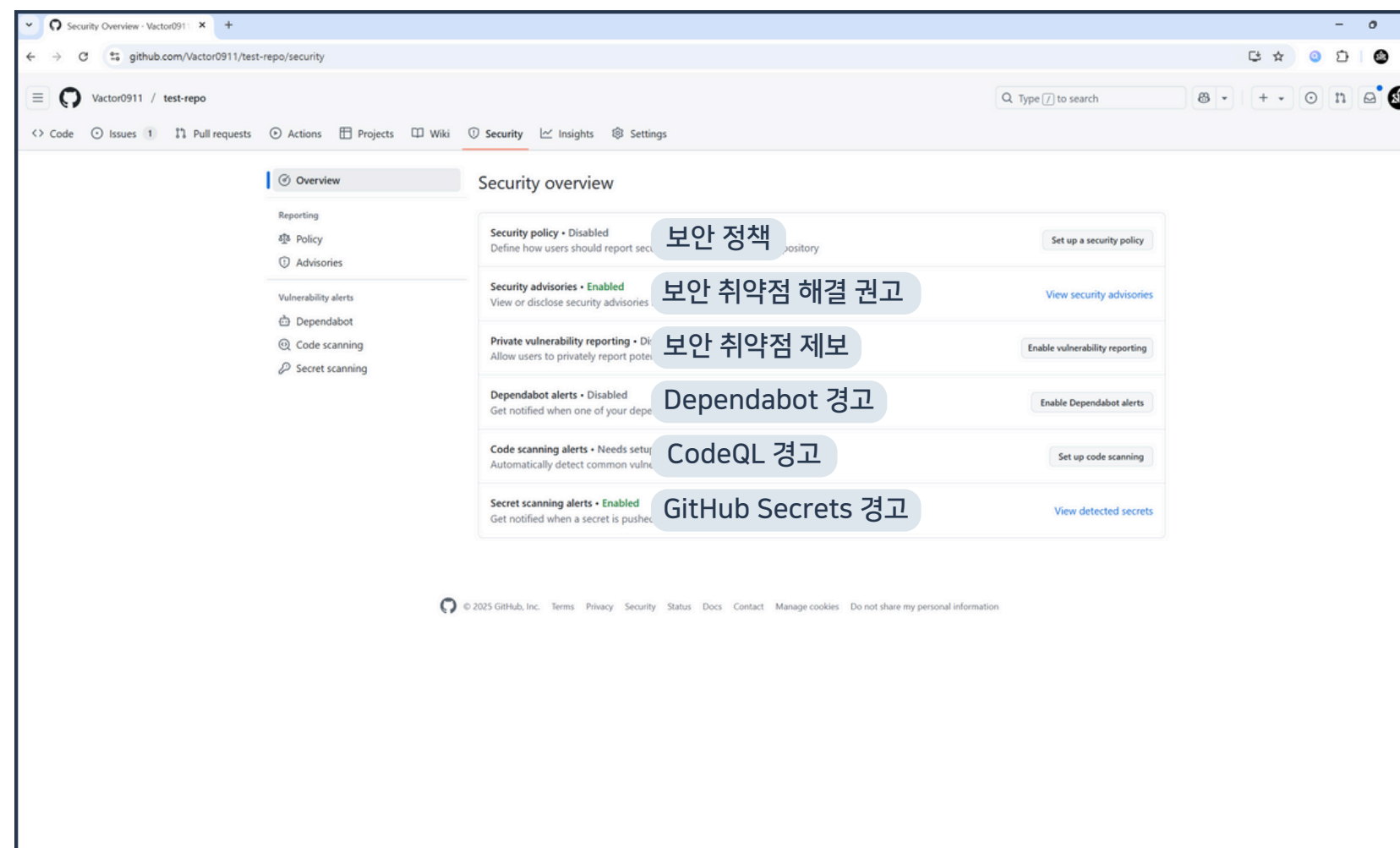
03 DependaBot과 CodeQL



2. Security 버튼 클릭

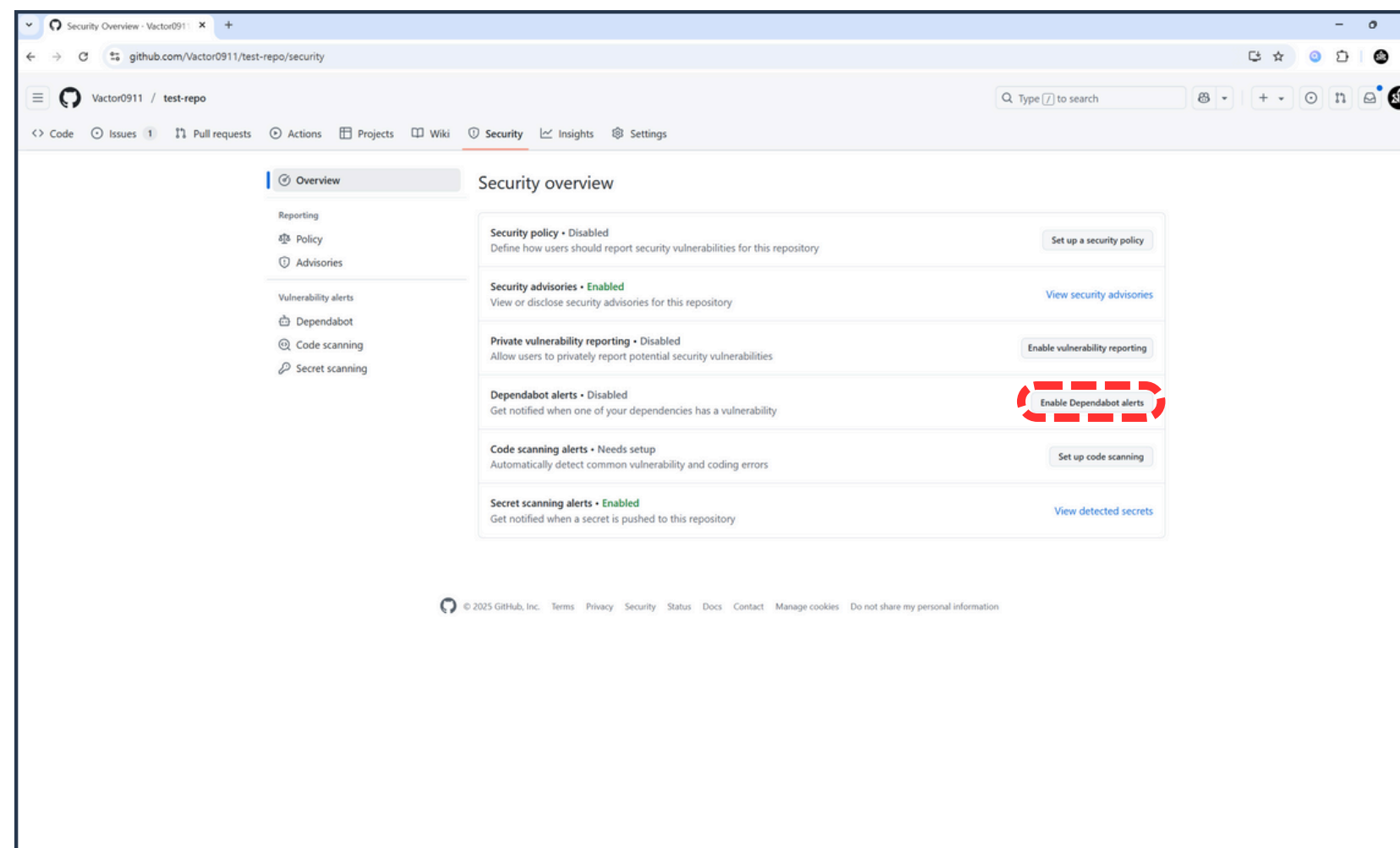


03 DependaBot과 CodeQL





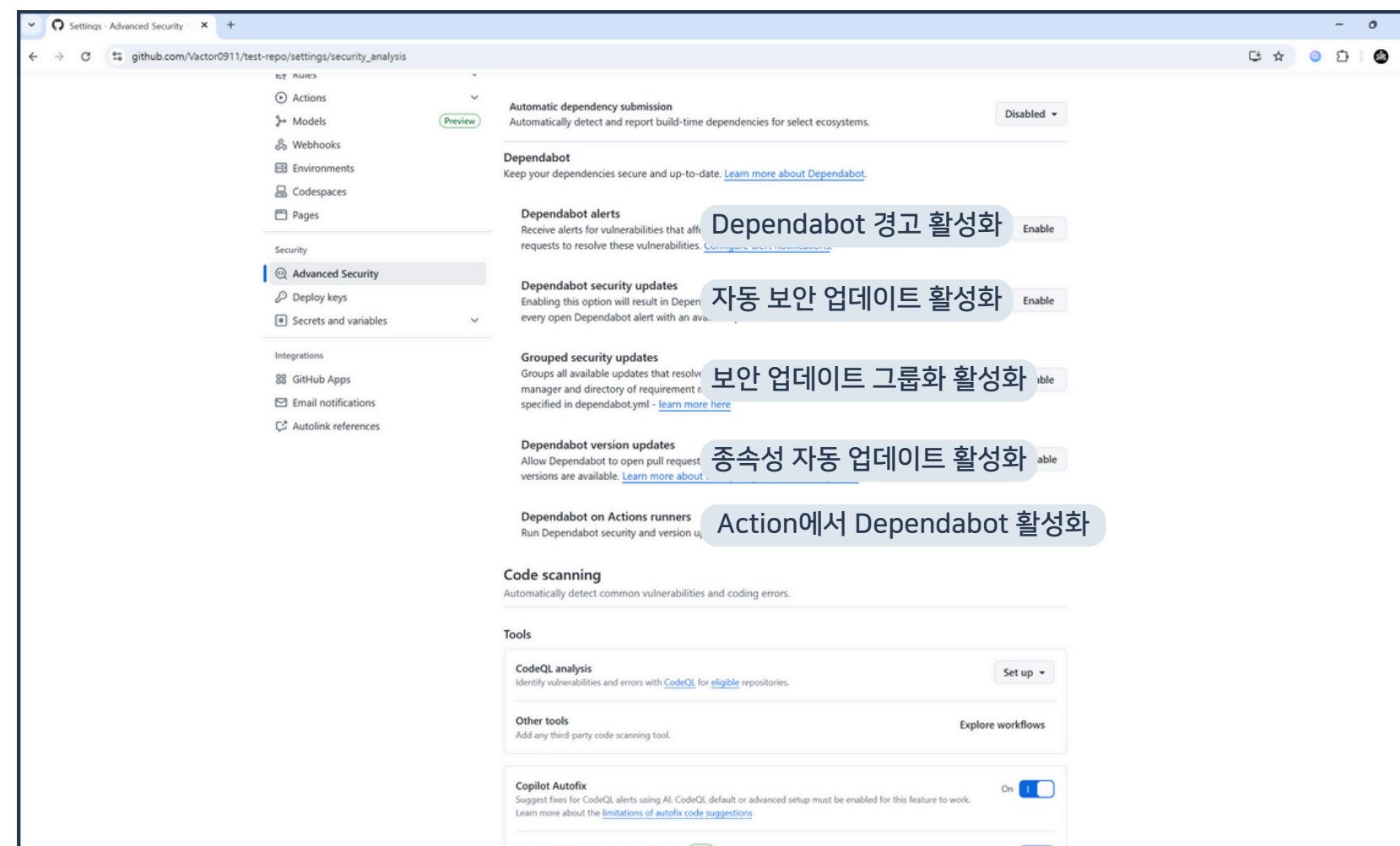
03 DependaBot과 CodeQL



3. Enable Dependabot alerts 버튼 클릭

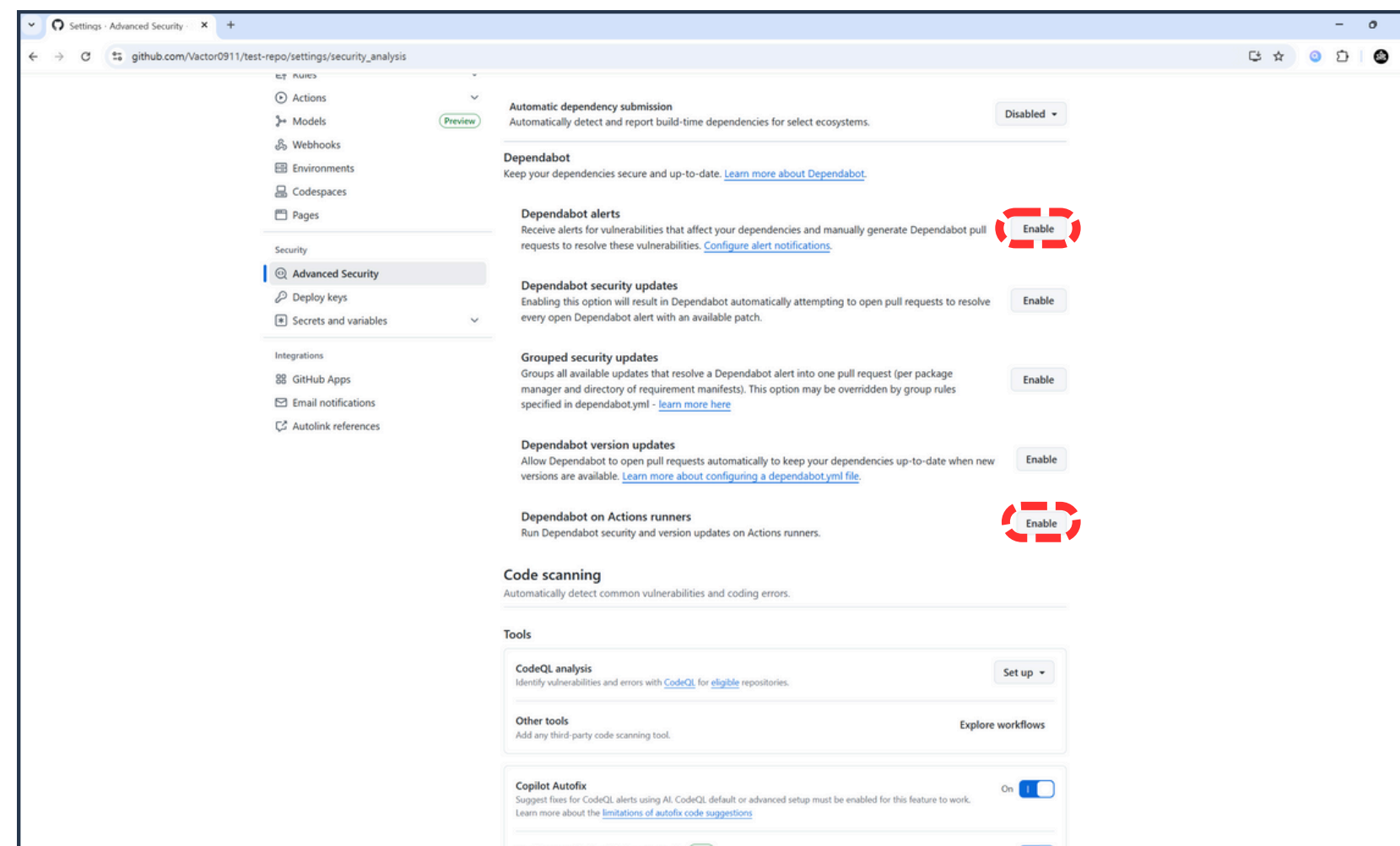


03 DependaBot과 CodeQL





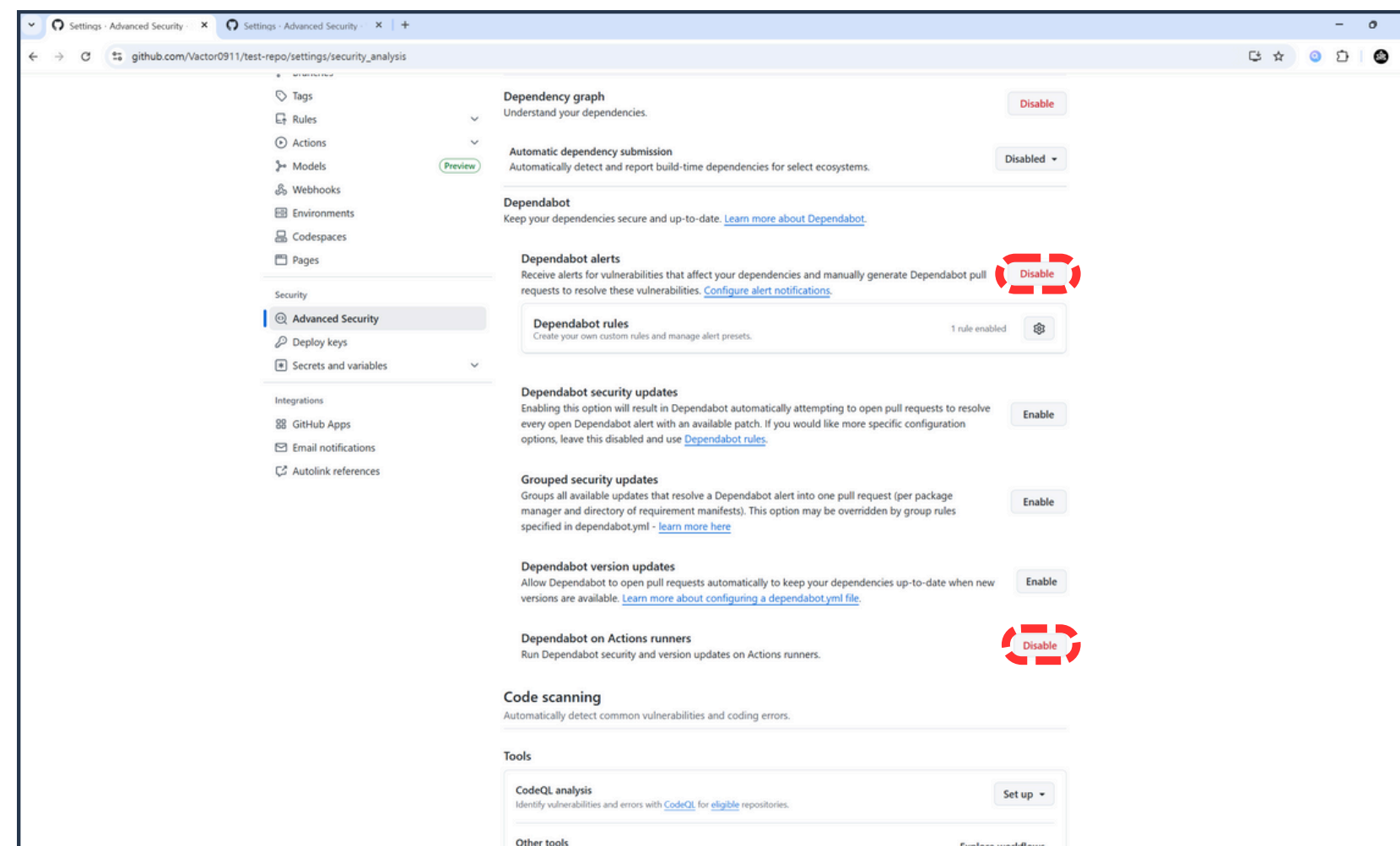
03 DependaBot과 CodeQL



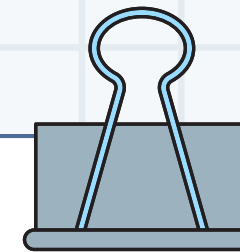
4. Dependabot alerts, Dependabot on Action runners 활성화



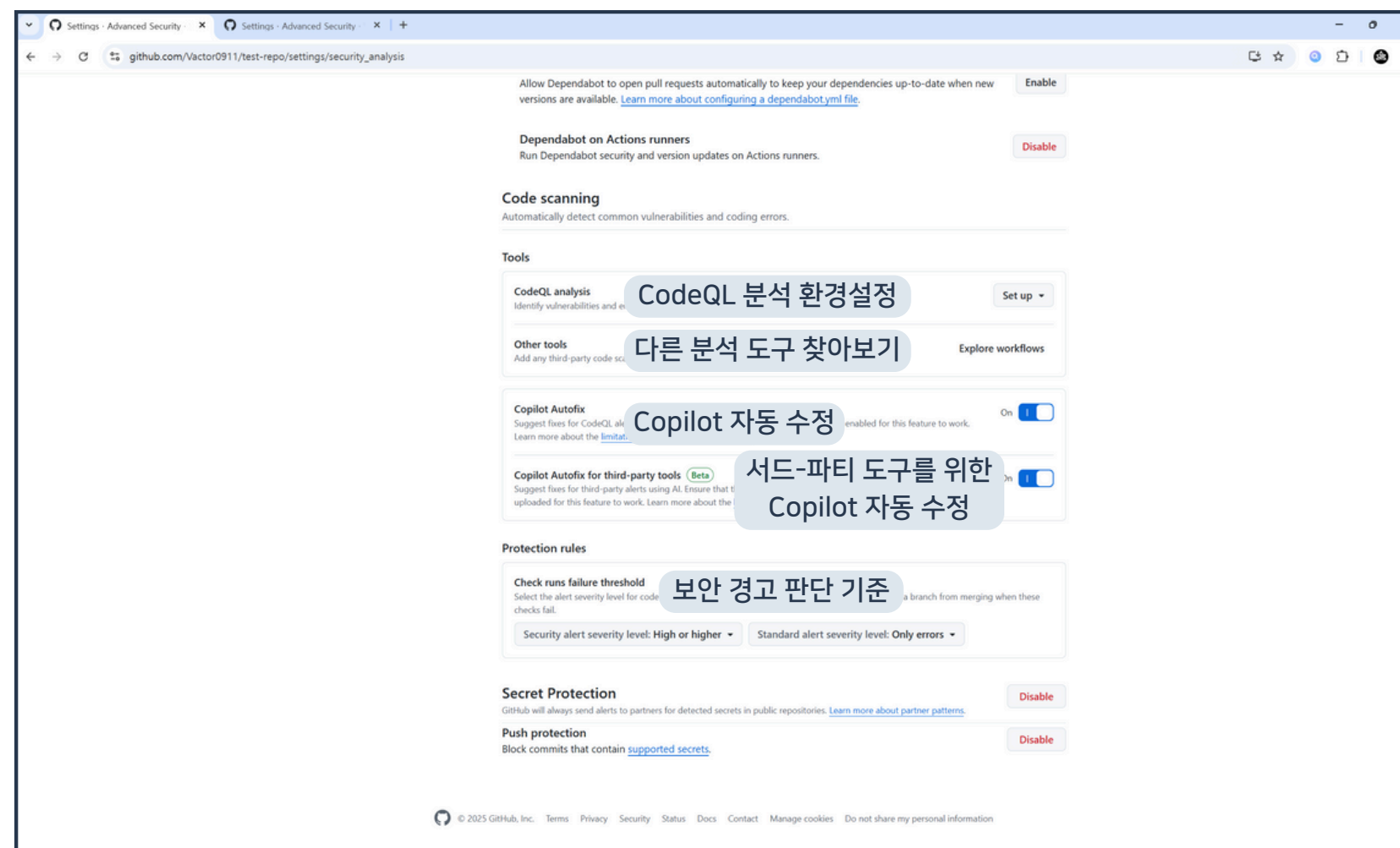
03 DependaBot과 CodeQL

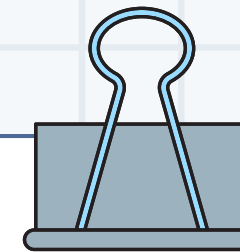


5. 활성화 결과 확인

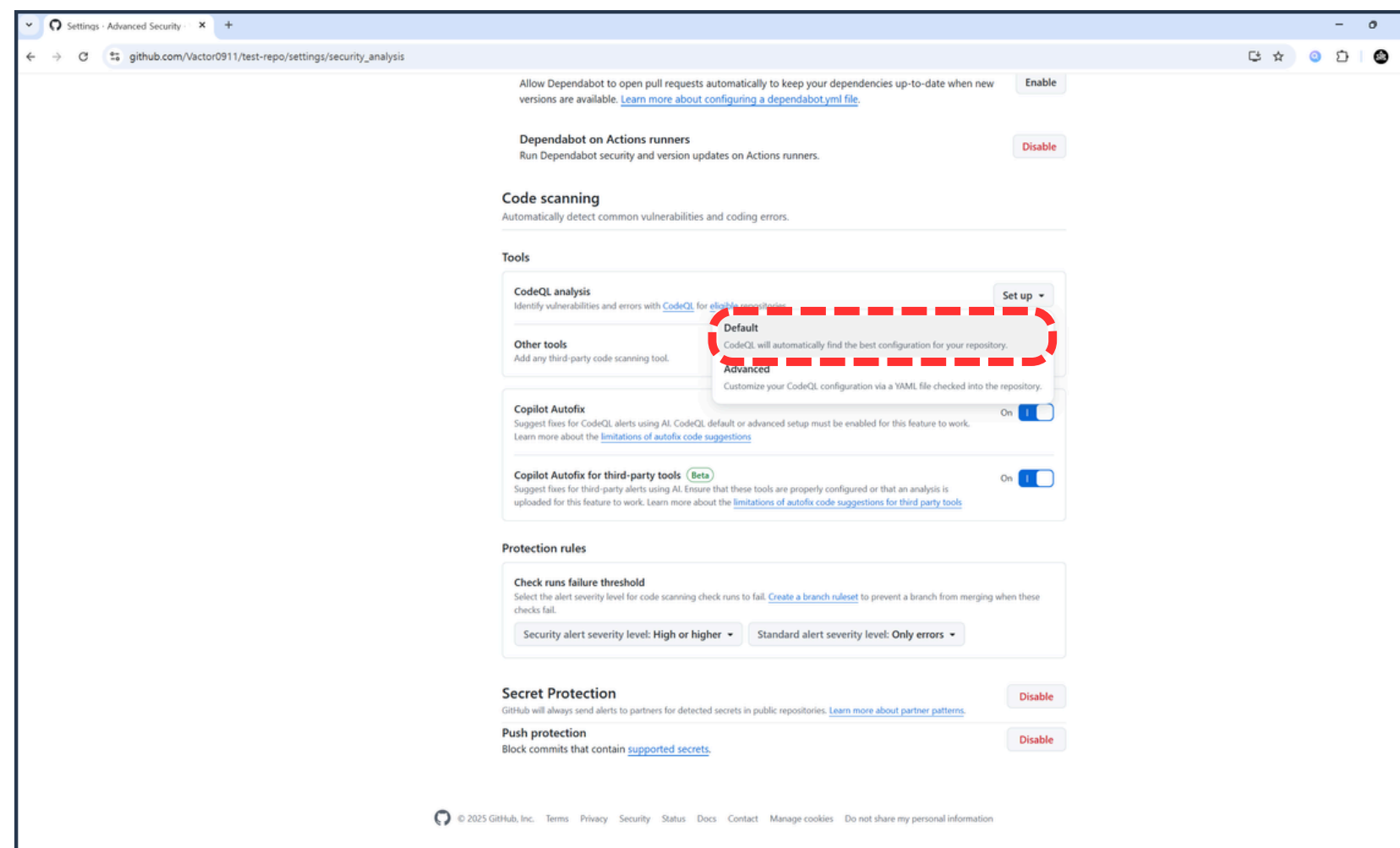


03 DependaBot과 CodeQL





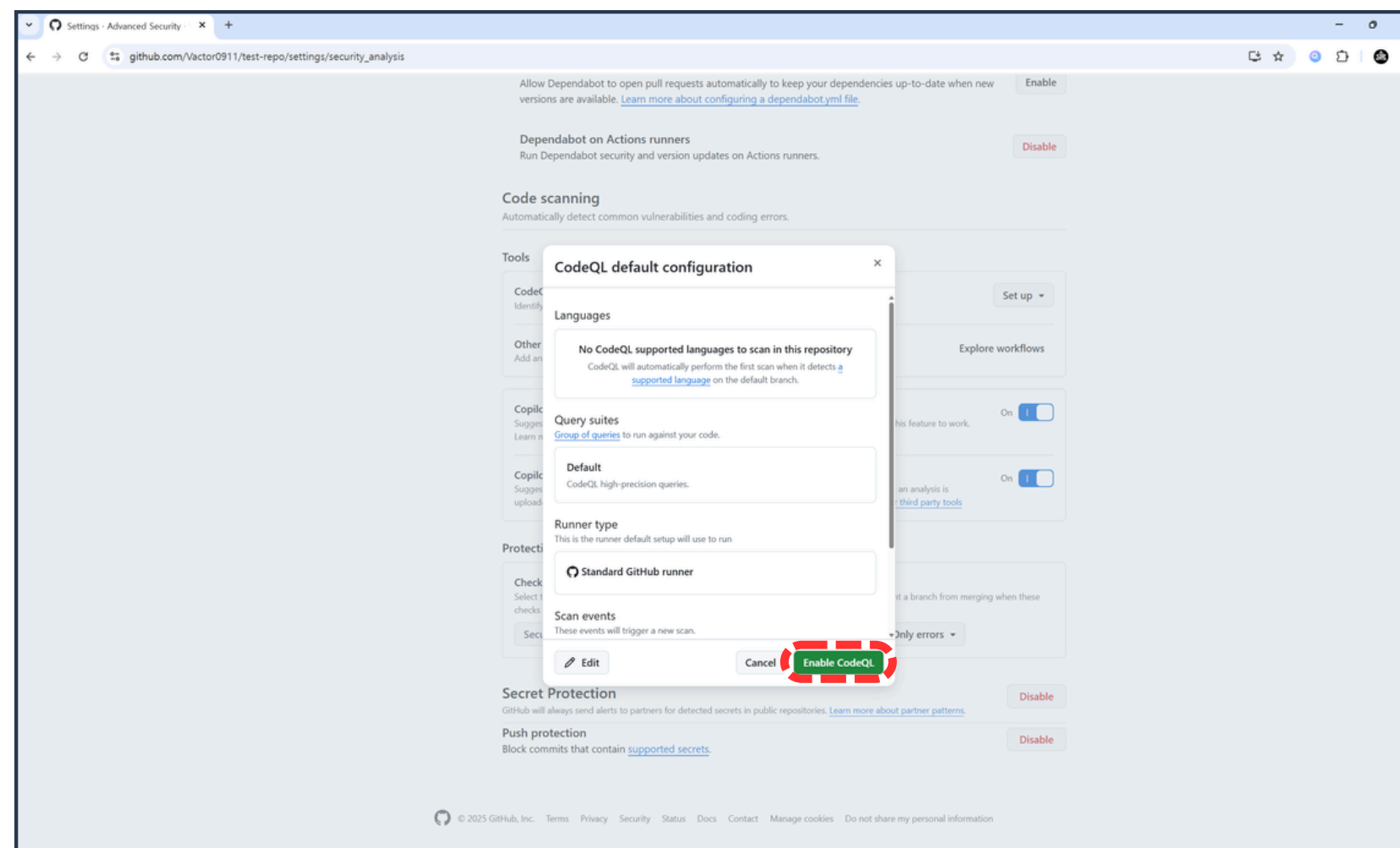
03 DependaBot과 CodeQL



6. Set up > Default 버튼 클릭



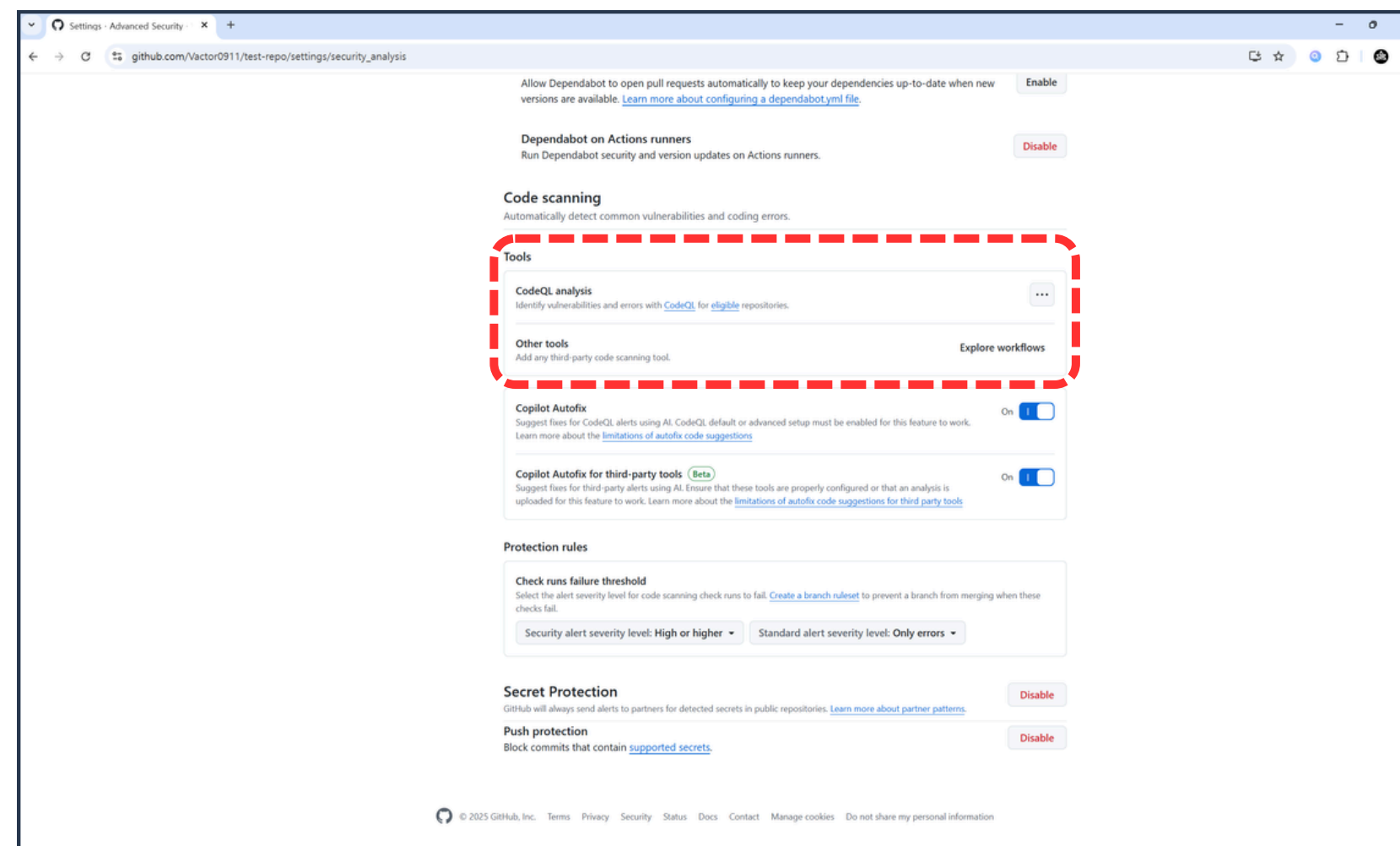
03 DependaBot과 CodeQL



7. Enable CodeQL 버튼 클릭



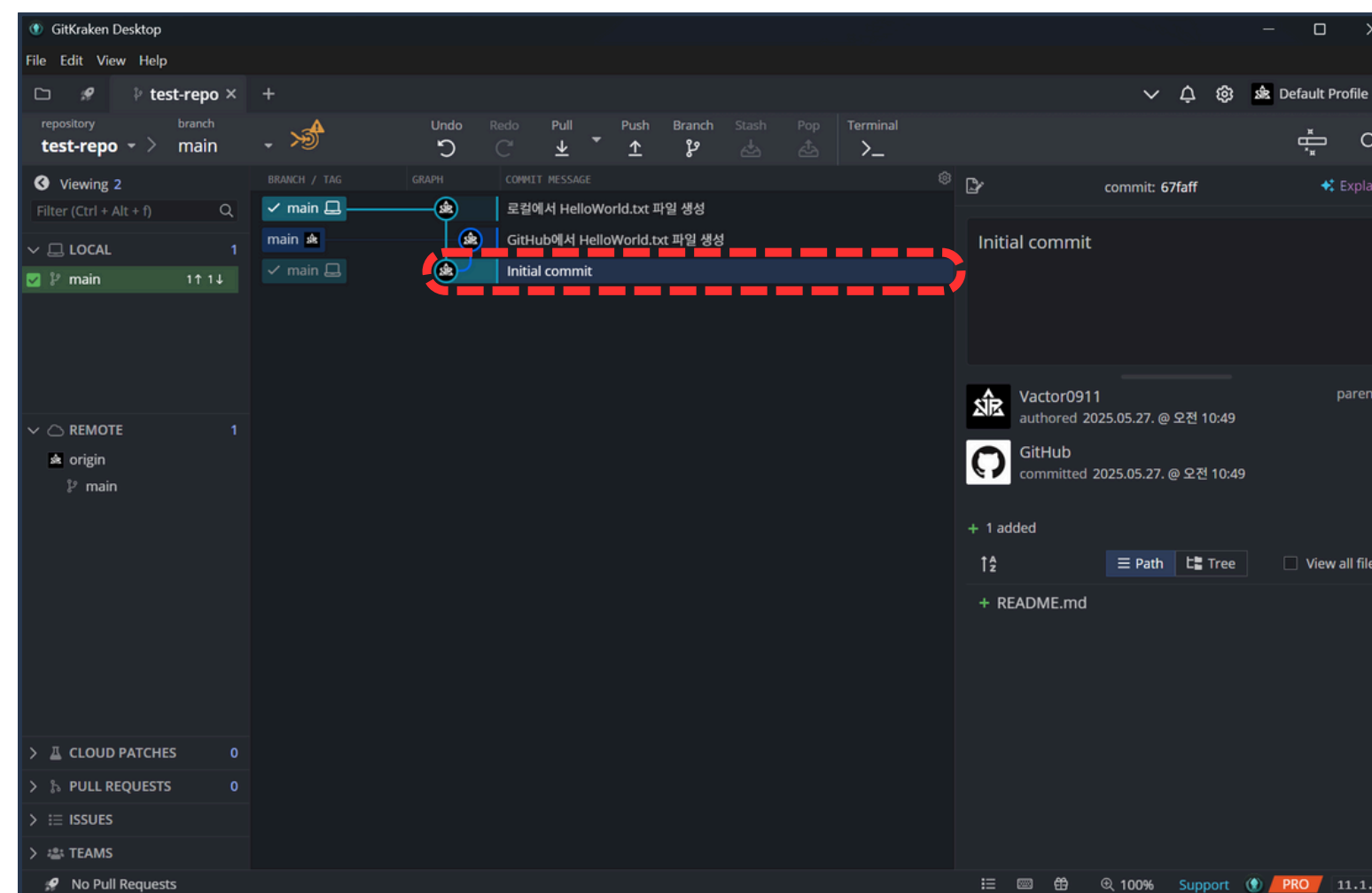
03 DependaBot과 CodeQL



8. CodeQL 활성화 결과 확인



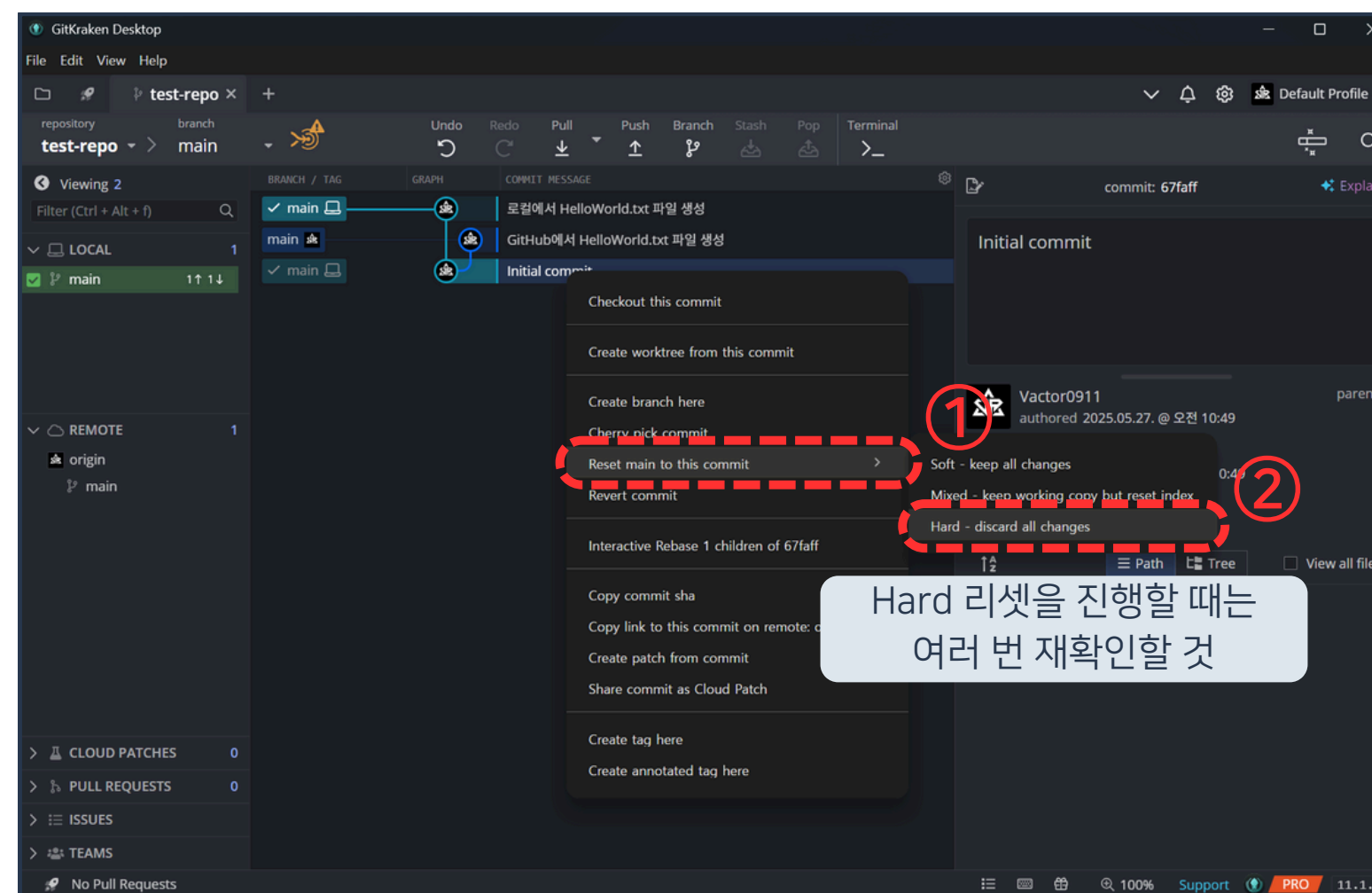
03 DependaBot과 CodeQL



9. 리포지토리 최초 커밋 선택 후
마우스 오른쪽 버튼 클릭



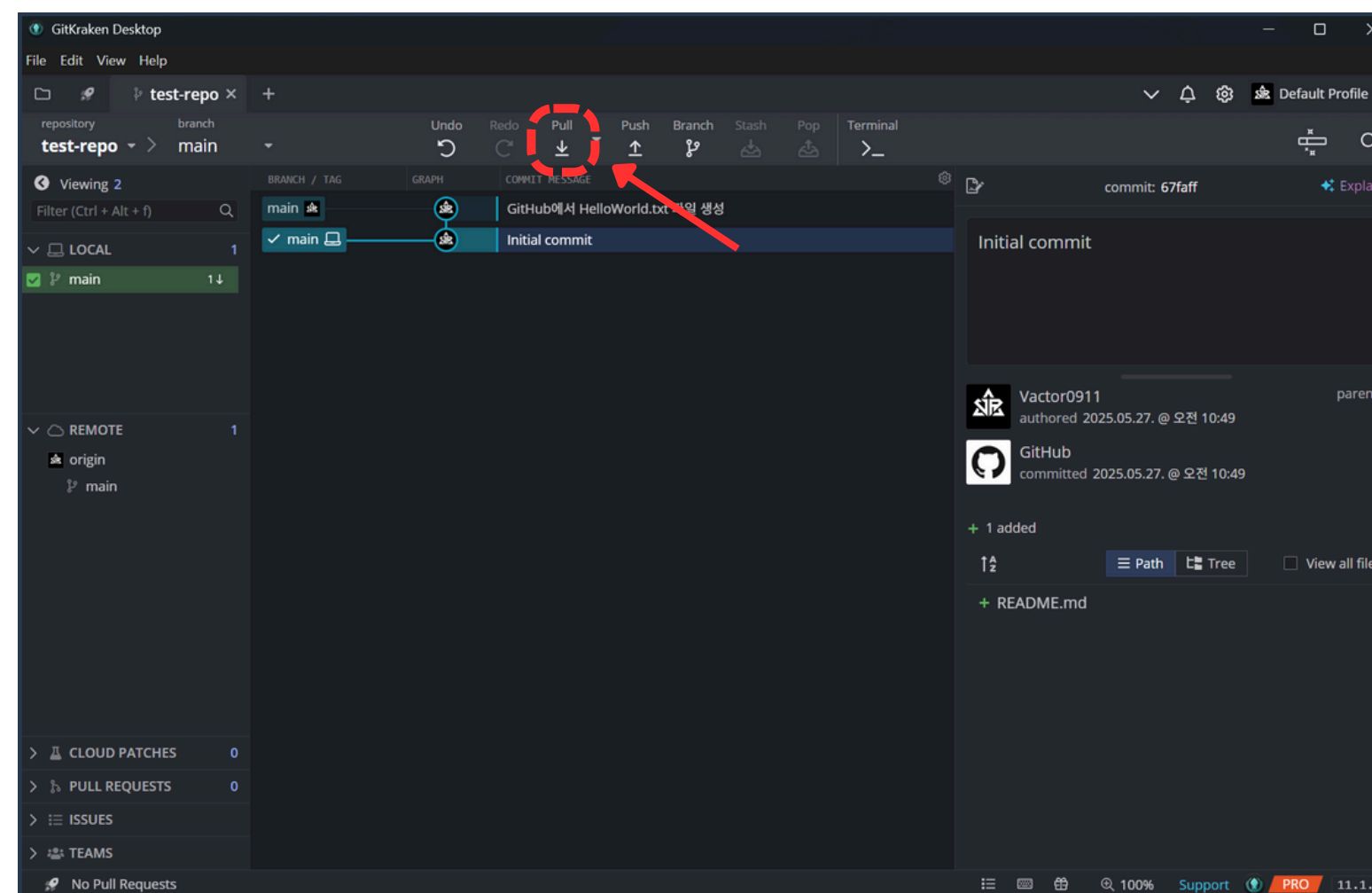
03 DependaBot과 CodeQL



10. Reset main to this commit 버튼 클릭 후
Hard 버튼 클릭

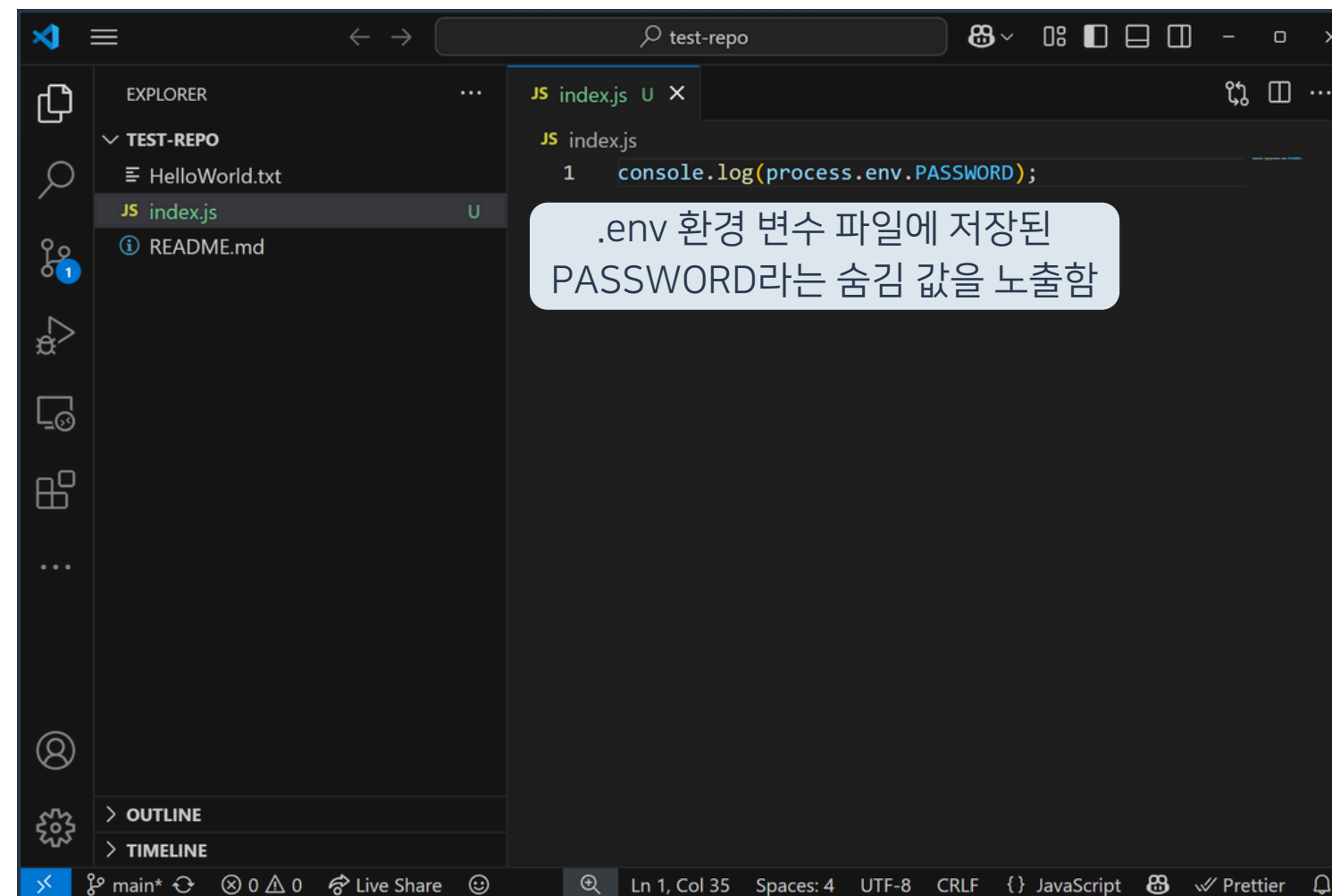
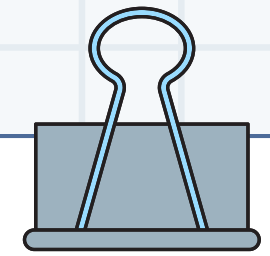


03 DependaBot과 CodeQL



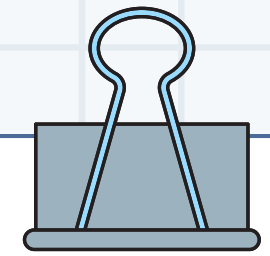
11. Pull 버튼 클릭

03 DependaBot과 CodeQL

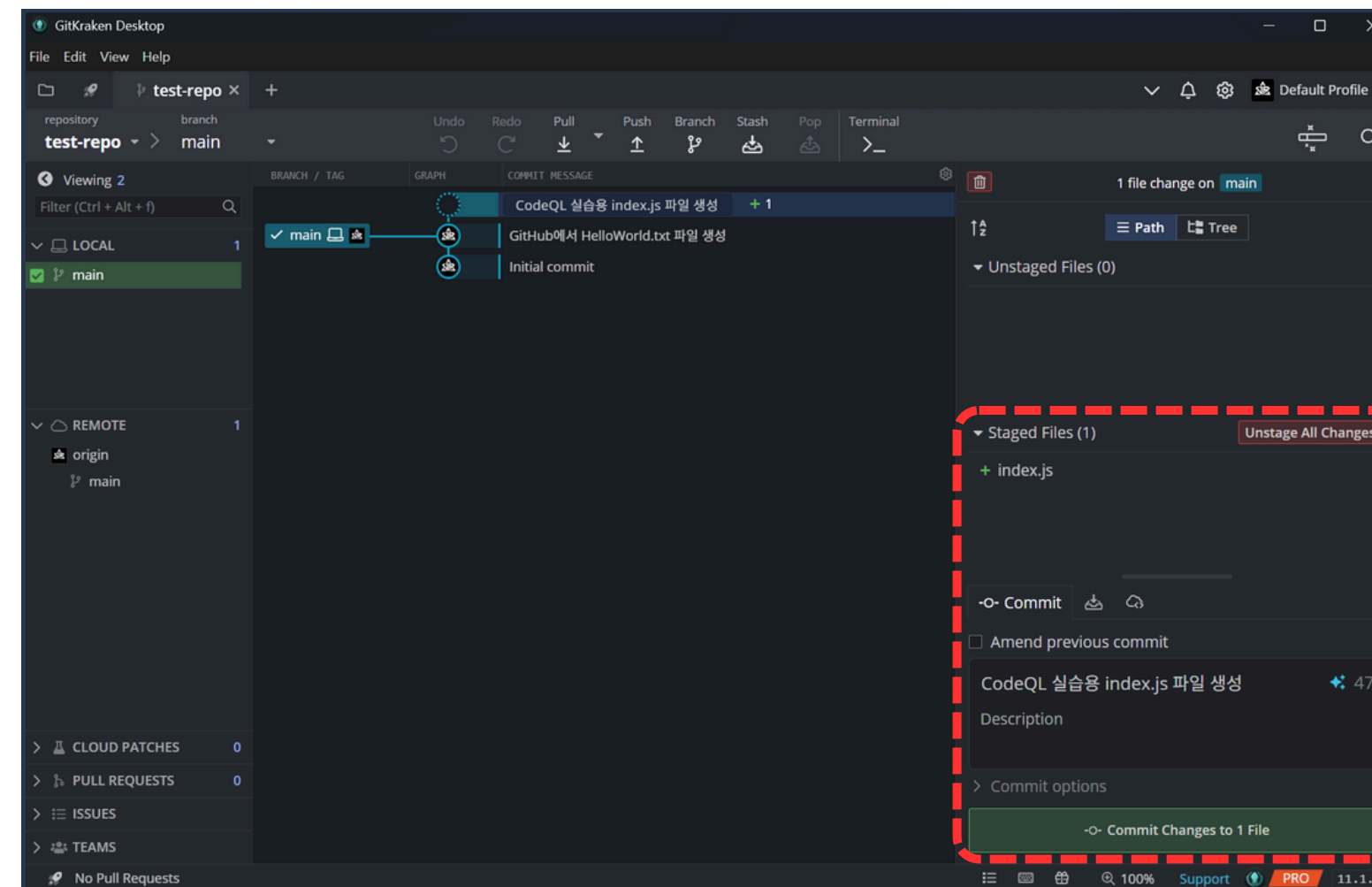


강의 자료 다운로드

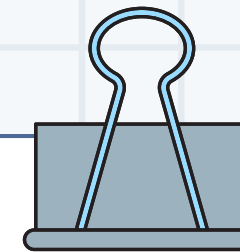
12. 프로젝트 위치에 index.js 파일 생성



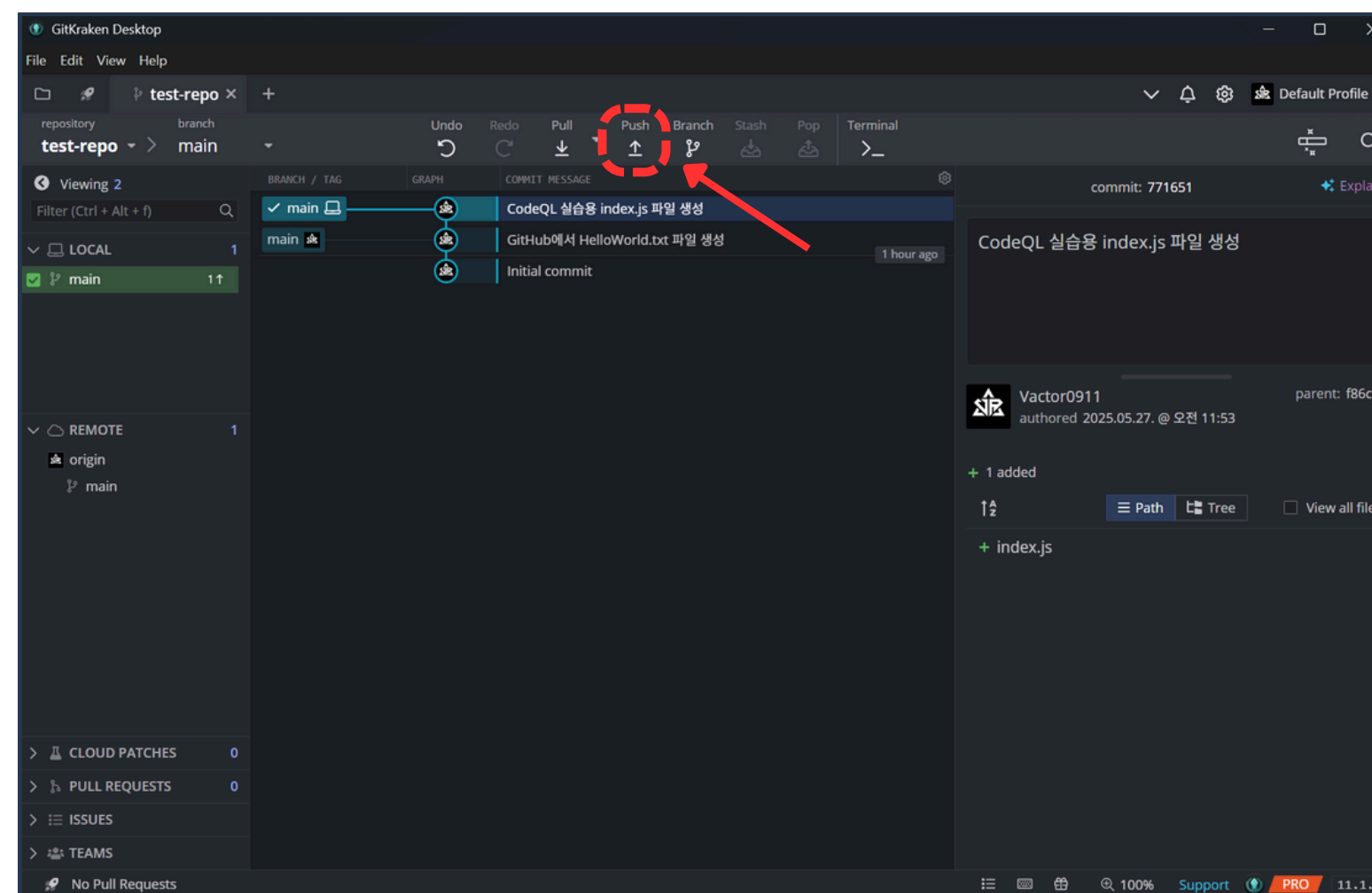
03 DependaBot과 CodeQL



13. 변경점 커밋



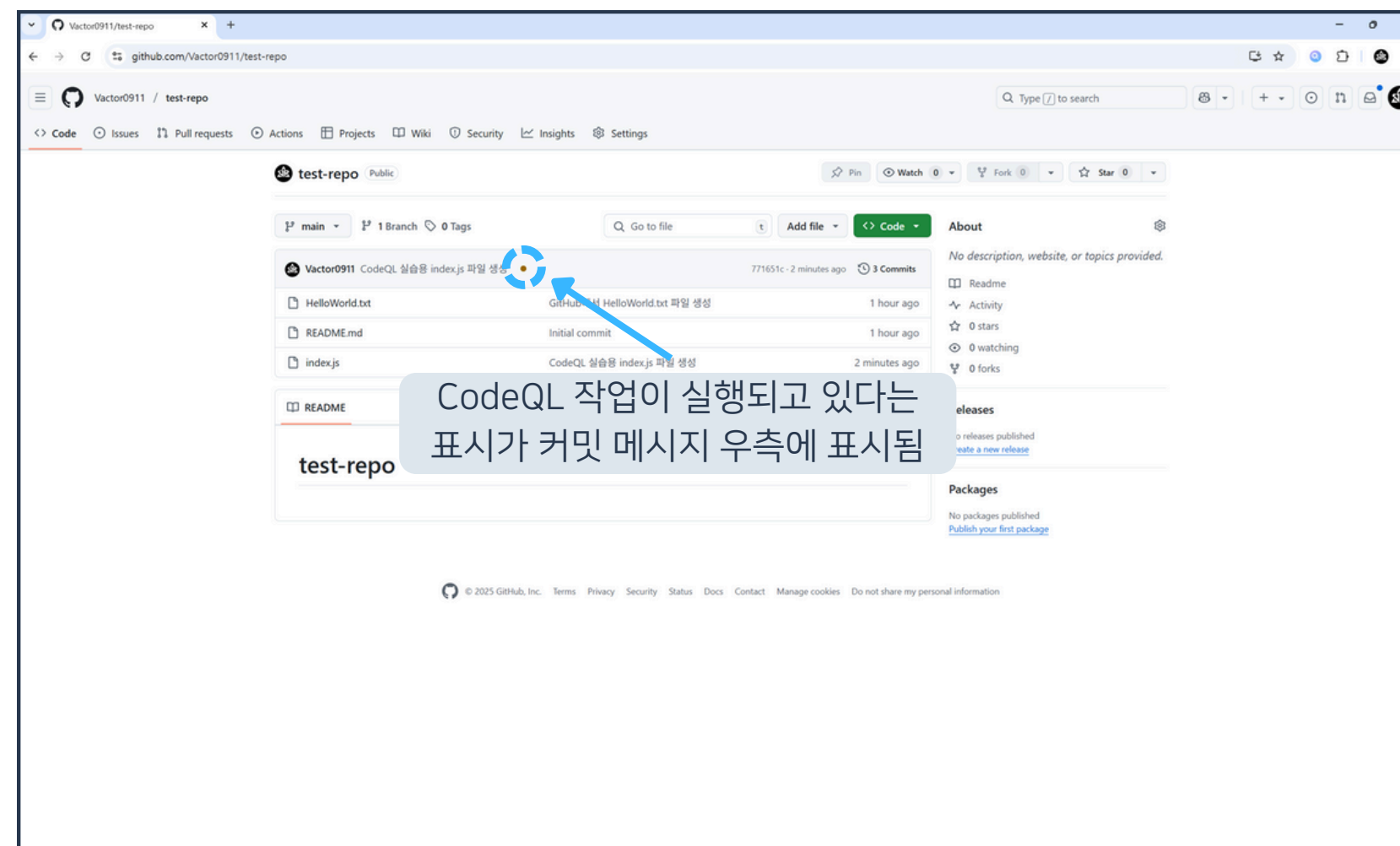
03 DependaBot과 CodeQL



14. Push 버튼 클릭



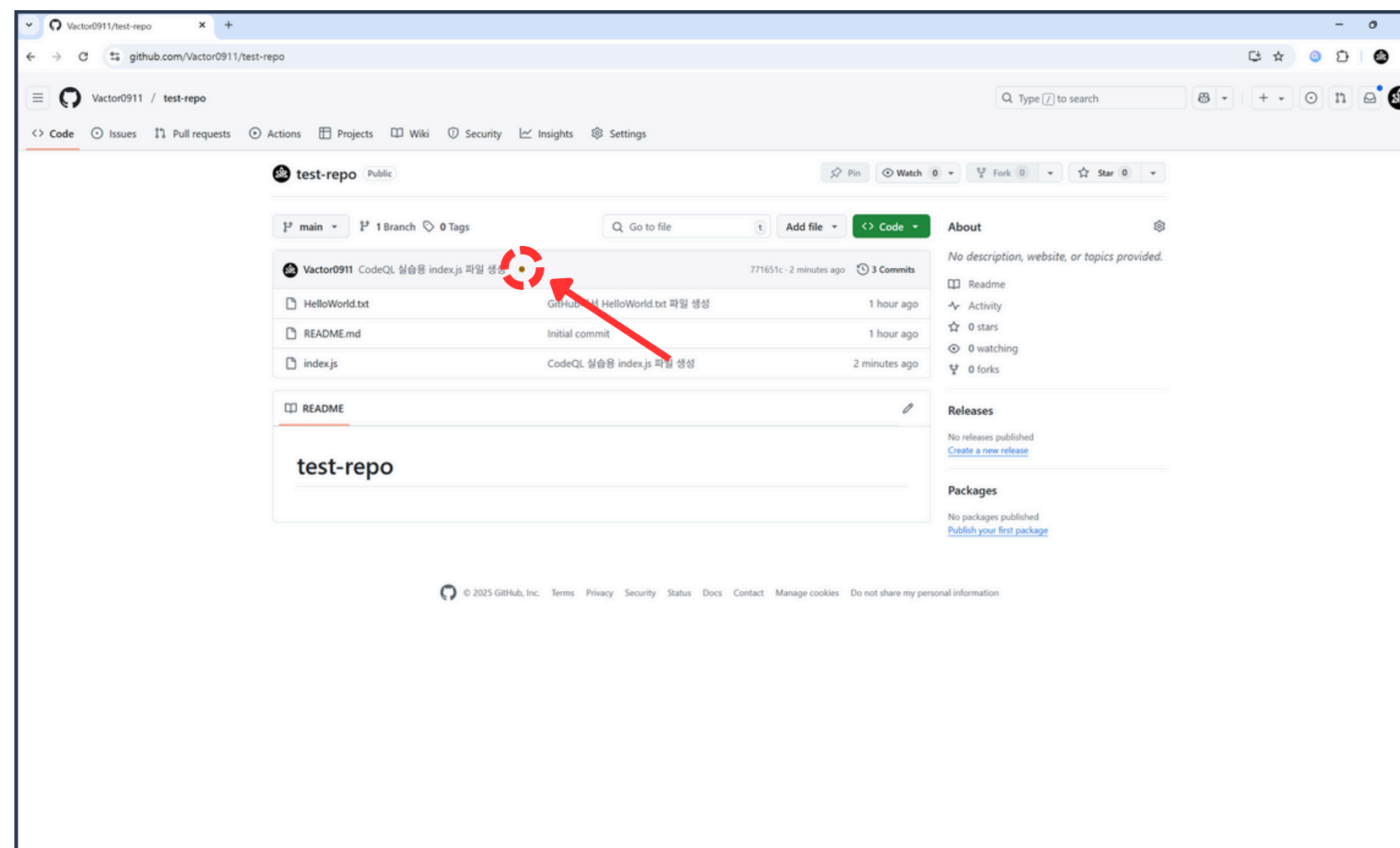
03 DependaBot과 CodeQL



15. GitHub 리포지토리 접속



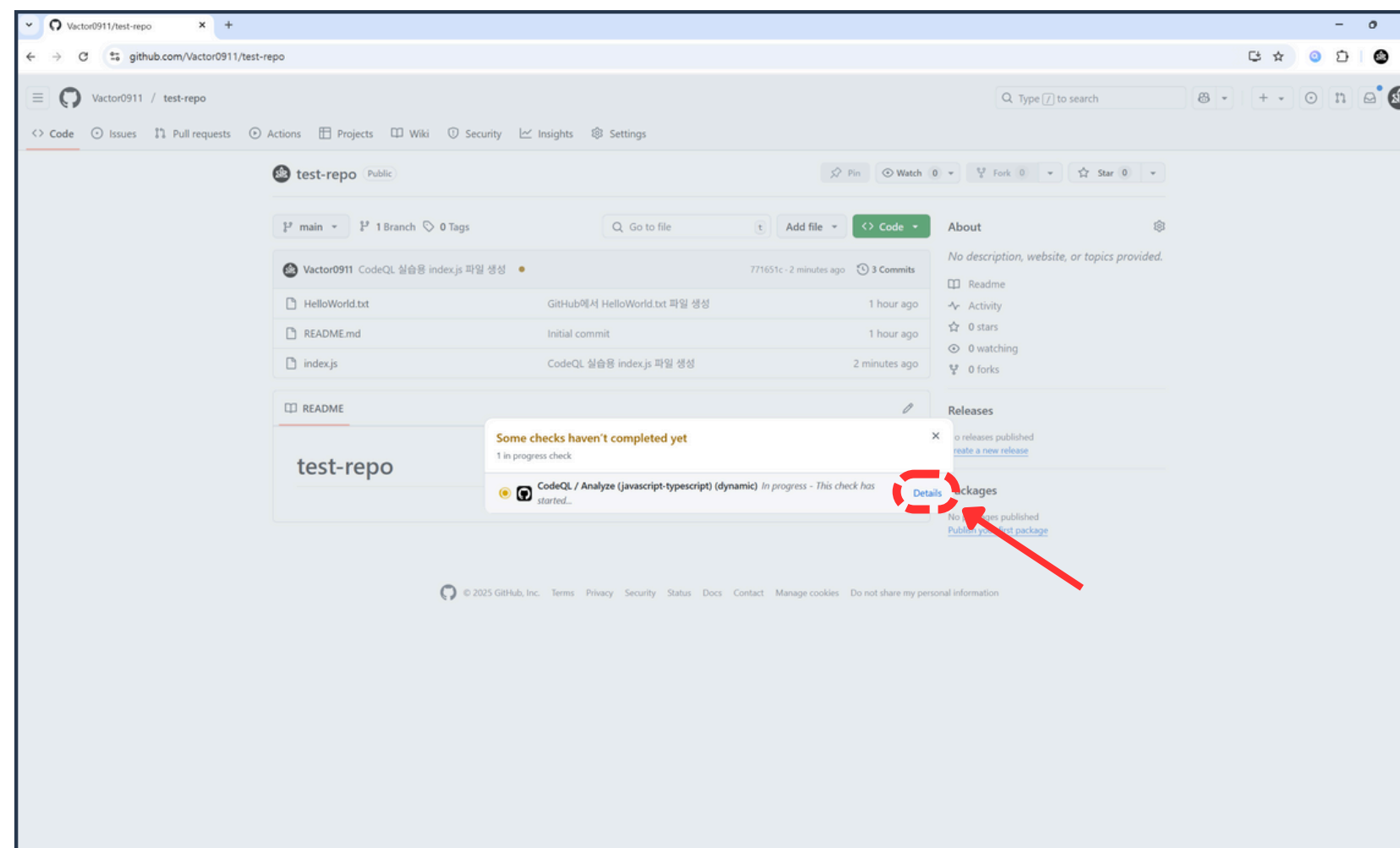
03 DependaBot과 CodeQL



16. 커밋 메시지 우측의 주황색 버튼 클릭



03 DependaBot과 CodeQL



17. Details 버튼 클릭



03 DependaBot과 CodeQL

CodeQL Setup #1

Summary

Analyze (javascript-typescript)

Analyze (javascript-typescript)

javascript/typescript 언어 분석중

Analyze (javascript-typescript)

분석 상황 및 중간 결과 표시

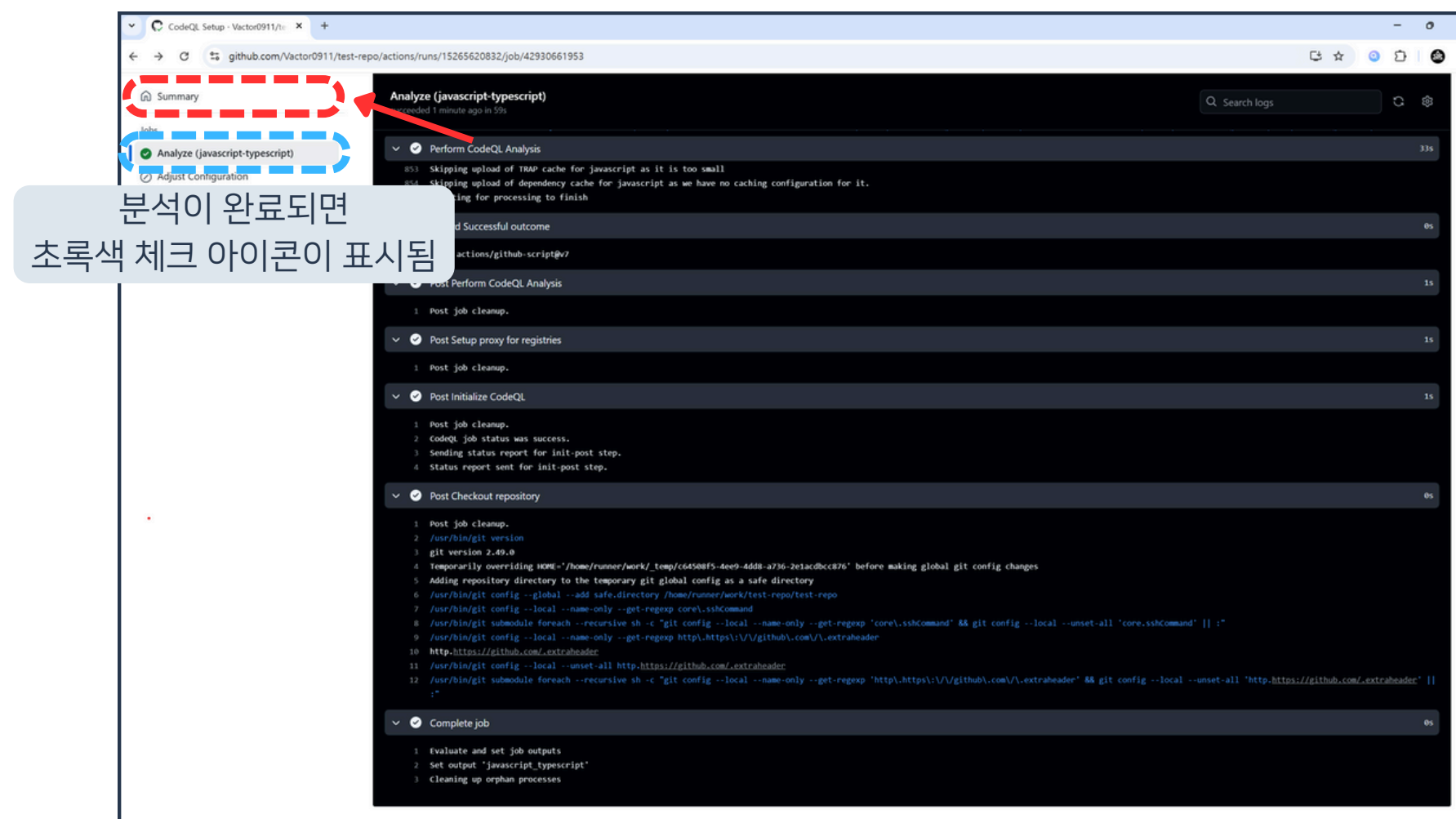
Perform CodeQL Analysis

```
1 Run github/codeql-action/analyze@v1
40 While resolving threads, found a cgroup CPU file with 4 CPUs in /sys/fs/cgroup/cpuset.cpus.effective.
41 Not performing diff-informed analysis because we are not analyzing a pull request.
42
43 Extracting javascript
44 /opt/hostedtoolcache/CodeQL/2.21.3/x64/codeql/codeql database trace-command --use-build-mode --working-dir /home/runner/work/test-repo/test-repo -
0-javascript.trap.cache.dir=/home/runner/work/_temp/trapCaches/javascript -O-javascript.trap.cache.bound-1024 -O-javascript.trap.cache.write-true /home/runner/work/_temp/codeql_databases/javascript
Running command in /home/runner/work/test-repo/test-repo: [/opt/hostedtoolcache/CodeQL/2.21.3/x64/codeql/javascript/tools/autobuild.sh]
45 [2025-05-27 02:55:49] [build-stdout] Parallel extraction with 4 threads.
46 [2025-05-27 02:55:49] [build-stdout] Extracting /home/runner/work/test-repo/test-repo/index.js (140 ms)
47 [2025-05-27 02:55:49] [build-stdout] Done extracting /home/runner/work/test-repo/test-repo/index.js (140 ms)
48 [2025-05-27 02:55:49] [build-stdout] Extracting /opt/hostedtoolcache/CodeQL/2.21.3/x64/codeql/javascript/tools/data/externs/nodejs/module.js
49 [2025-05-27 02:55:49] [build-stdout] Extracting /opt/hostedtoolcache/CodeQL/2.21.3/x64/codeql/javascript/tools/data/externs/nodejs/fs.js
50 [2025-05-27 02:55:49] [build-stdout] Extracting /opt/hostedtoolcache/CodeQL/2.21.3/x64/codeql/javascript/tools/data/externs/nodejs/punycode.js
51 [2025-05-27 02:55:49] [build-stdout] Extracting /opt/hostedtoolcache/CodeQL/2.21.3/x64/codeql/javascript/tools/data/externs/nodejs/tls.js
52 [2025-05-27 02:55:49] [build-stdout] Done extracting /opt/hostedtoolcache/CodeQL/2.21.3/x64/codeql/javascript/tools/data/externs/nodejs/module.js (65 ms)
53 [2025-05-27 02:55:49] [build-stdout] Extracting /opt/hostedtoolcache/CodeQL/2.21.3/x64/codeql/javascript/tools/data/externs/nodejs/os.js
54 [2025-05-27 02:55:49] [build-stdout] Done extracting /opt/hostedtoolcache/CodeQL/2.21.3/x64/codeql/javascript/tools/data/externs/nodejs/punycode.js (72 ms)
55 [2025-05-27 02:55:49] [build-stdout] Extracting /opt/hostedtoolcache/CodeQL/2.21.3/x64/codeql/javascript/tools/data/externs/nodejs/string_decoder.js
56 [2025-05-27 02:55:49] [build-stdout] Done extracting /opt/hostedtoolcache/CodeQL/2.21.3/x64/codeql/javascript/tools/data/externs/nodejs/string_decoder.js (15 ms)
57 [2025-05-27 02:55:49] [build-stdout] Extracting /opt/hostedtoolcache/CodeQL/2.21.3/x64/codeql/javascript/tools/data/externs/nodejs/globals.js
58 [2025-05-27 02:55:49] [build-stdout] Done extracting /opt/hostedtoolcache/CodeQL/2.21.3/x64/codeql/javascript/tools/data/externs/nodejs/os.js (148 ms)
59 [2025-05-27 02:55:49] [build-stdout] Extracting /opt/hostedtoolcache/CodeQL/2.21.3/x64/codeql/javascript/tools/data/externs/nodejs/vm.js
60 [2025-05-27 02:55:49] [build-stdout] Done extracting /opt/hostedtoolcache/CodeQL/2.21.3/x64/codeql/javascript/tools/data/externs/nodejs/tls.js (276 ms)
61 [2025-05-27 02:55:49] [build-stdout] Extracting /opt/hostedtoolcache/CodeQL/2.21.3/x64/codeql/javascript/tools/data/externs/nodejs/util.js
62 [2025-05-27 02:55:49] [build-stdout] Done extracting /opt/hostedtoolcache/CodeQL/2.21.3/x64/codeql/javascript/tools/data/externs/nodejs/vm.js (76 ms)
63 [2025-05-27 02:55:49] [build-stdout] Extracting /opt/hostedtoolcache/CodeQL/2.21.3/x64/codeql/javascript/tools/data/externs/nodejs/https.js
64 [2025-05-27 02:55:49] [build-stdout] Done extracting /opt/hostedtoolcache/CodeQL/2.21.3/x64/codeql/javascript/tools/data/externs/nodejs/util.js (75 ms)
65 [2025-05-27 02:55:49] [build-stdout] Extracting /opt/hostedtoolcache/CodeQL/2.21.3/x64/codeql/javascript/tools/data/externs/nodejs/domain.js
66 [2025-05-27 02:55:49] [build-stdout] Done extracting /opt/hostedtoolcache/CodeQL/2.21.3/x64/codeql/javascript/tools/data/externs/nodejs/https.js (89 ms)
```

18. 실행중인 CodeQL 워크플로우 확인



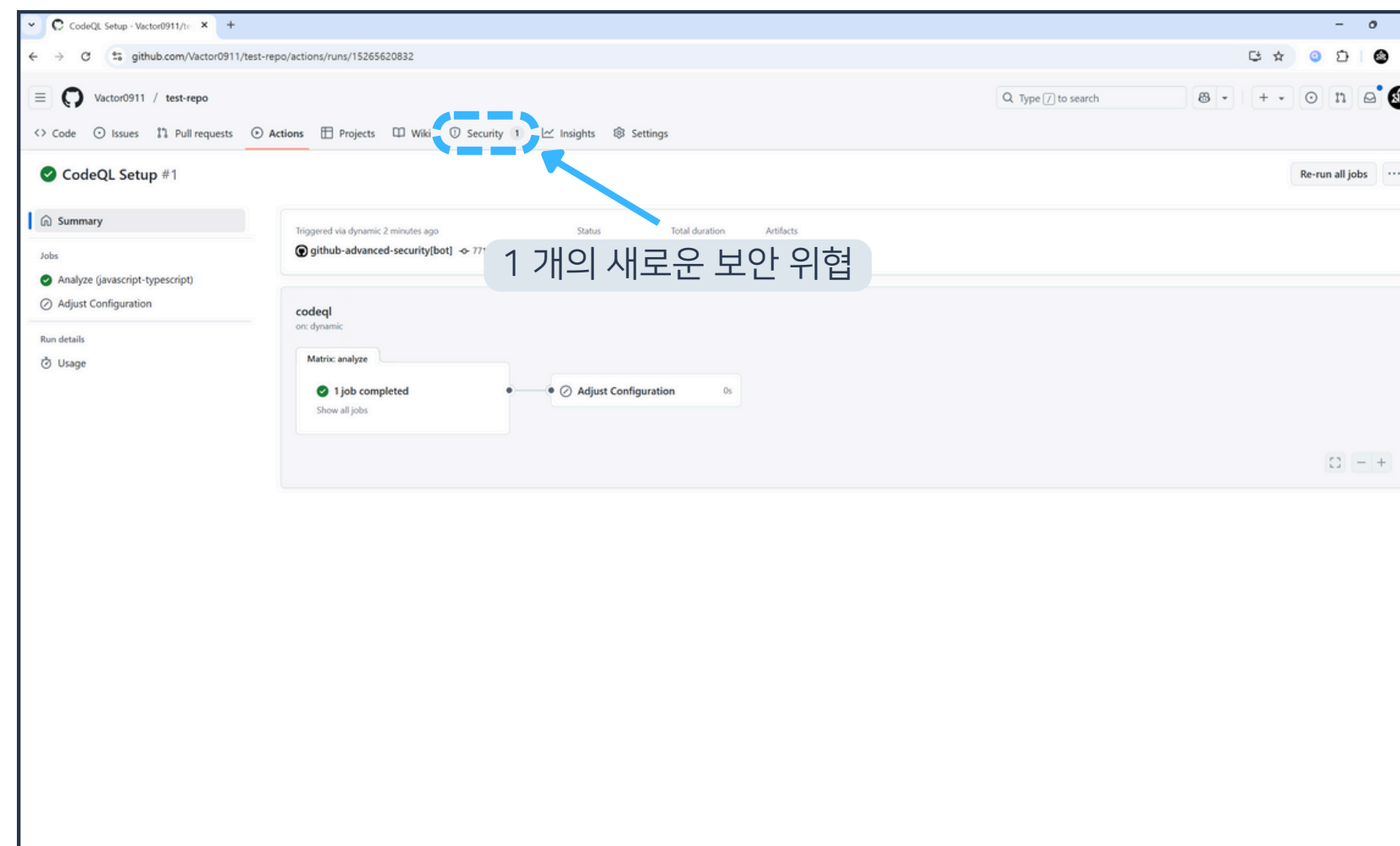
03 DependaBot과 CodeQL



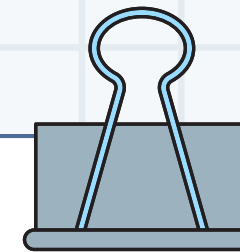
19. 분석이 완료되면 Summary 버튼 클릭



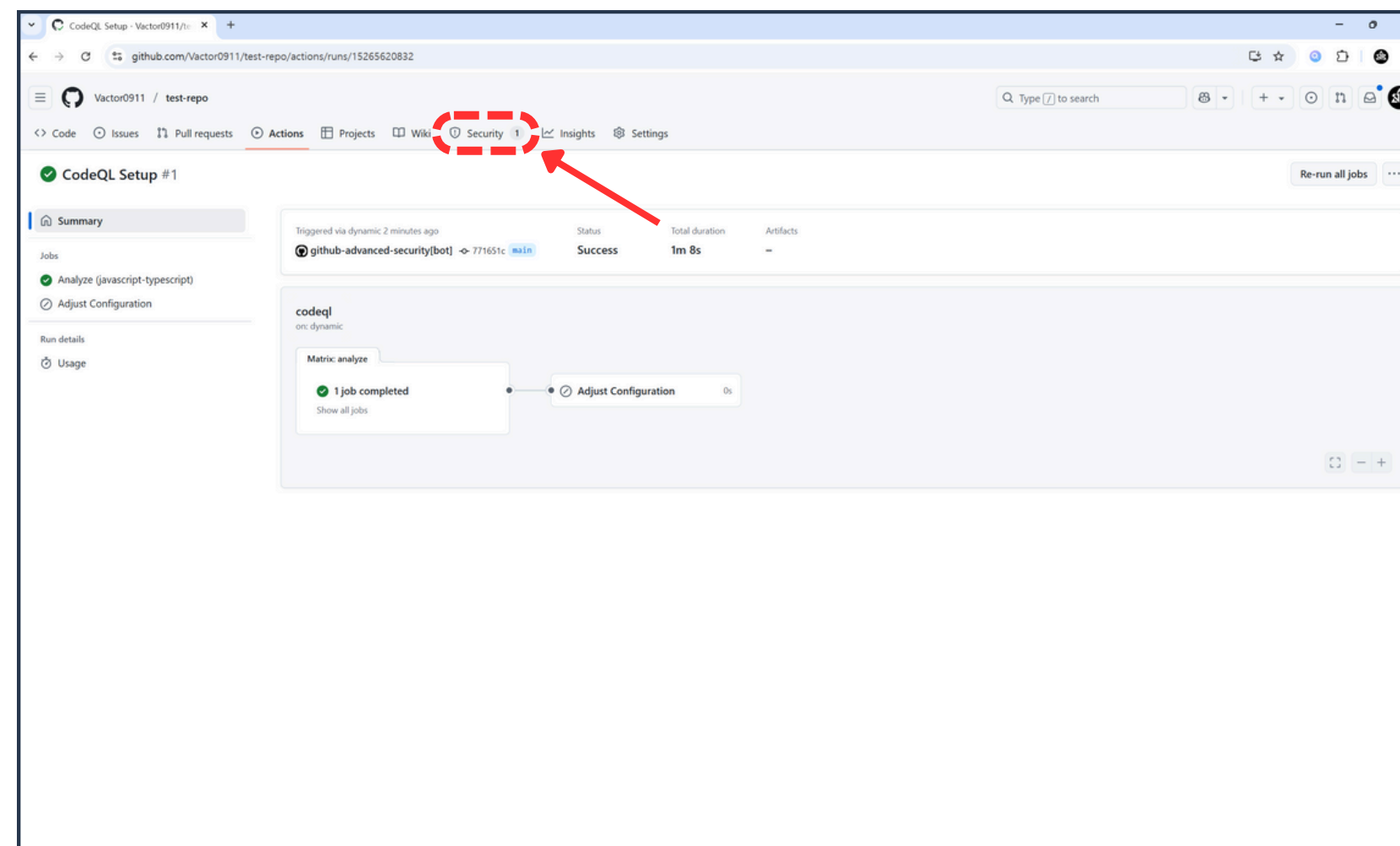
03 DependaBot과 CodeQL



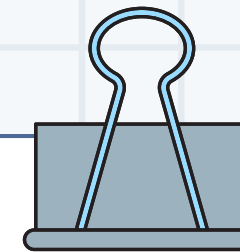
20. 분석 요약 확인



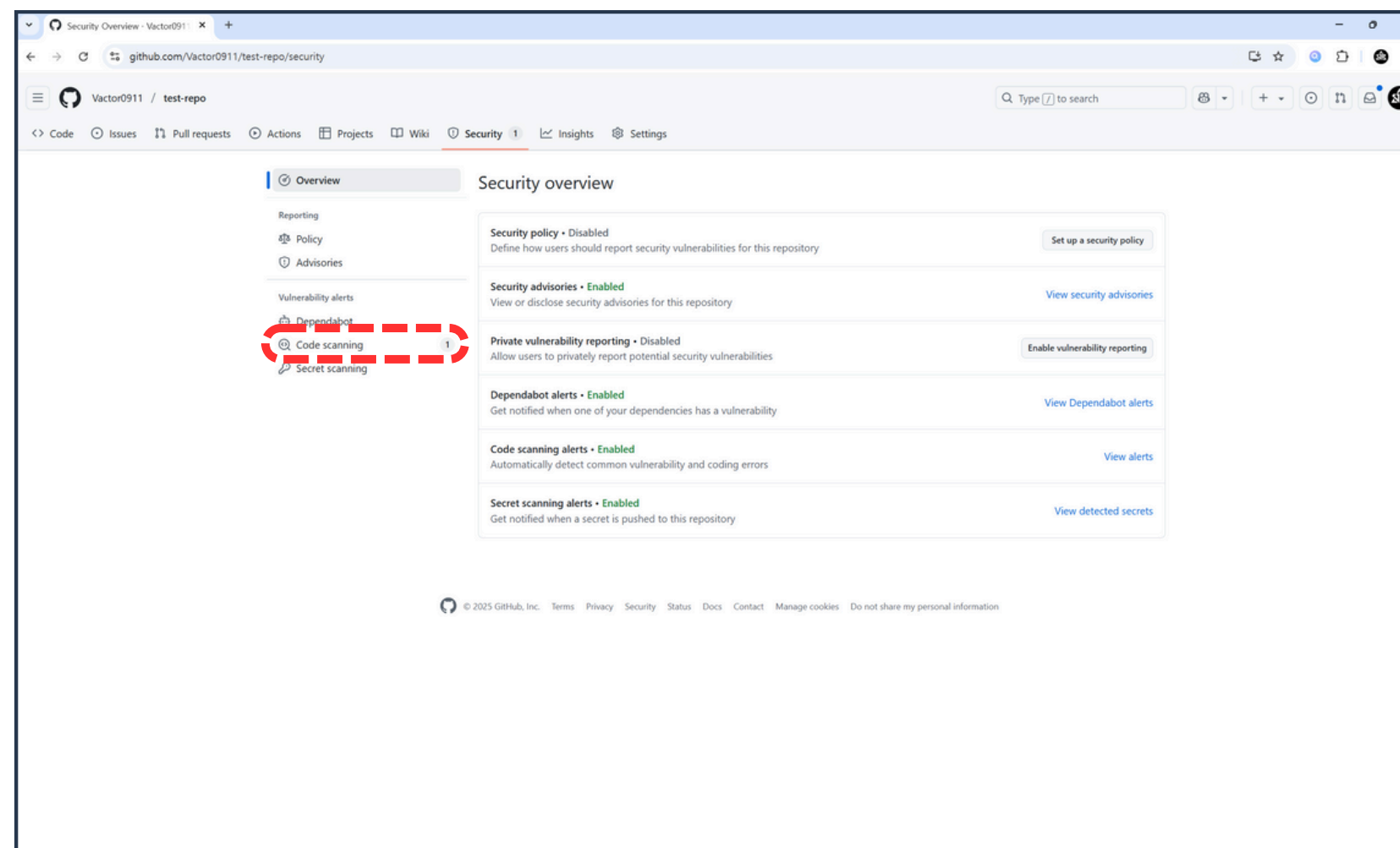
03 DependaBot과 CodeQL



21. Security 버튼 클릭



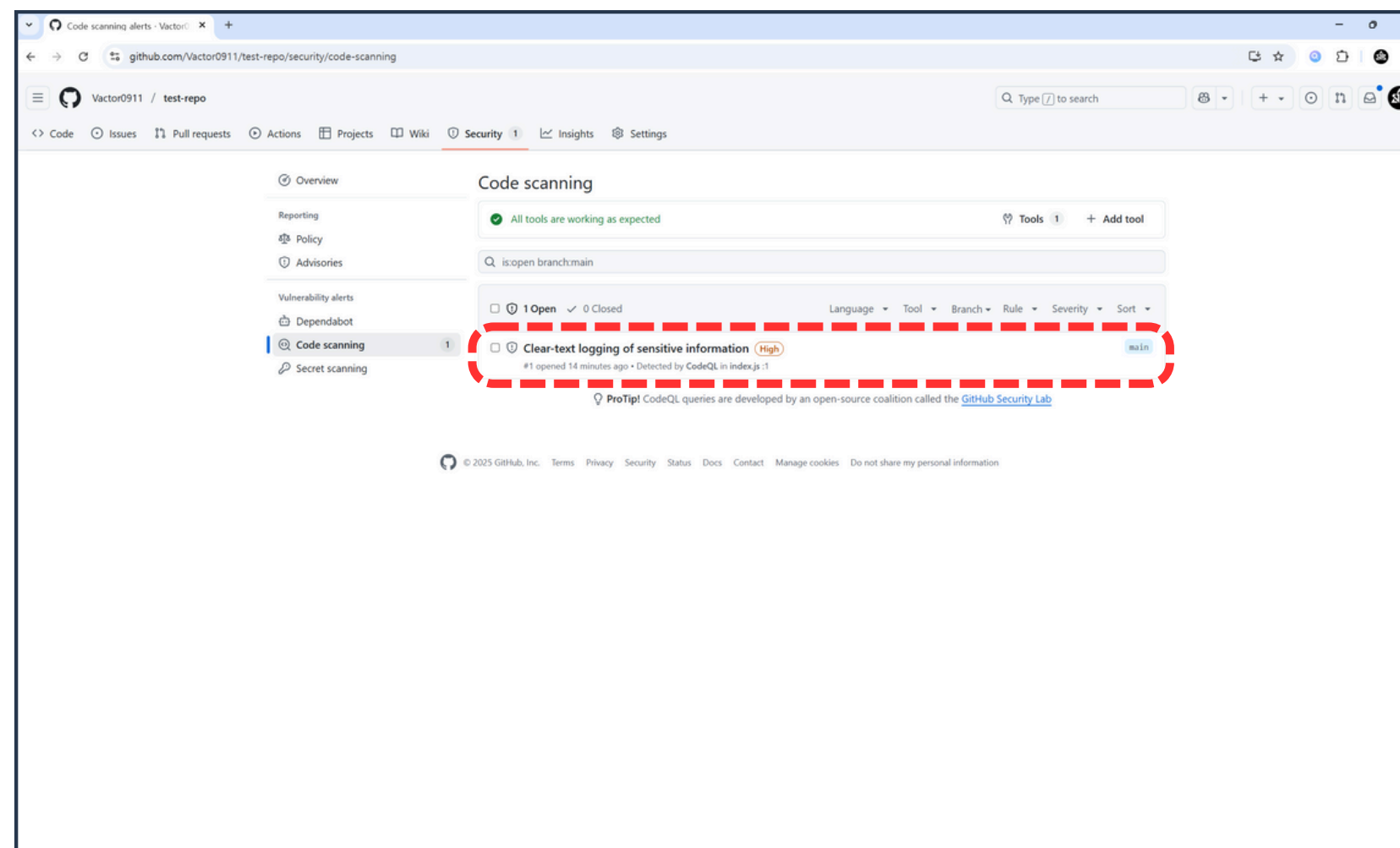
03 DependaBot과 CodeQL



22. Code scanning 버튼 클릭



03 DependaBot과 CodeQL



23. 보안 위협 항목 클릭



03 DependaBot과 CodeQL

The screenshot displays a GitHub Security Center alert for a CodeQL scan. The alert is titled 'Clear-text logging of sensitive information' and is categorized as a 'High' severity issue. It was first detected 16 minutes ago on the 'main' branch. The alert details include a snippet of JavaScript code from 'index.js' that logs sensitive information like 'process.env.PASSWORD'. The alert also provides a 'Dismiss alert' button and a 'Generate fix' button. On the right side, there are sections for 'Affected branches' (showing 'main' and 'default'), 'Development' (with a link to 'Link a branch, pull request, or create a new branch'), 'Tags' (showing 'security'), and 'Weaknesses' (listing CWE-312, CWE-359, and CWE-532). The bottom of the alert shows the 'First detected in commit' information and a link to 'View source'.

취약점 이슈 상태 (열림, 닫힘, 무시 등)

Clear-text logging of sensitive information 위험 개요

Speed up the remediation of this alert with Copilot Autofix for CodeQL

보안 취약점이 포함된 소스 코드 및 이유

Tool Rule ID Query 취약점 상세 내용

First detected in commit 16 minutes ago 취약점 탐지 기록

Severity 심각성 척도

Affected branches 영향 받은 브랜치

Development

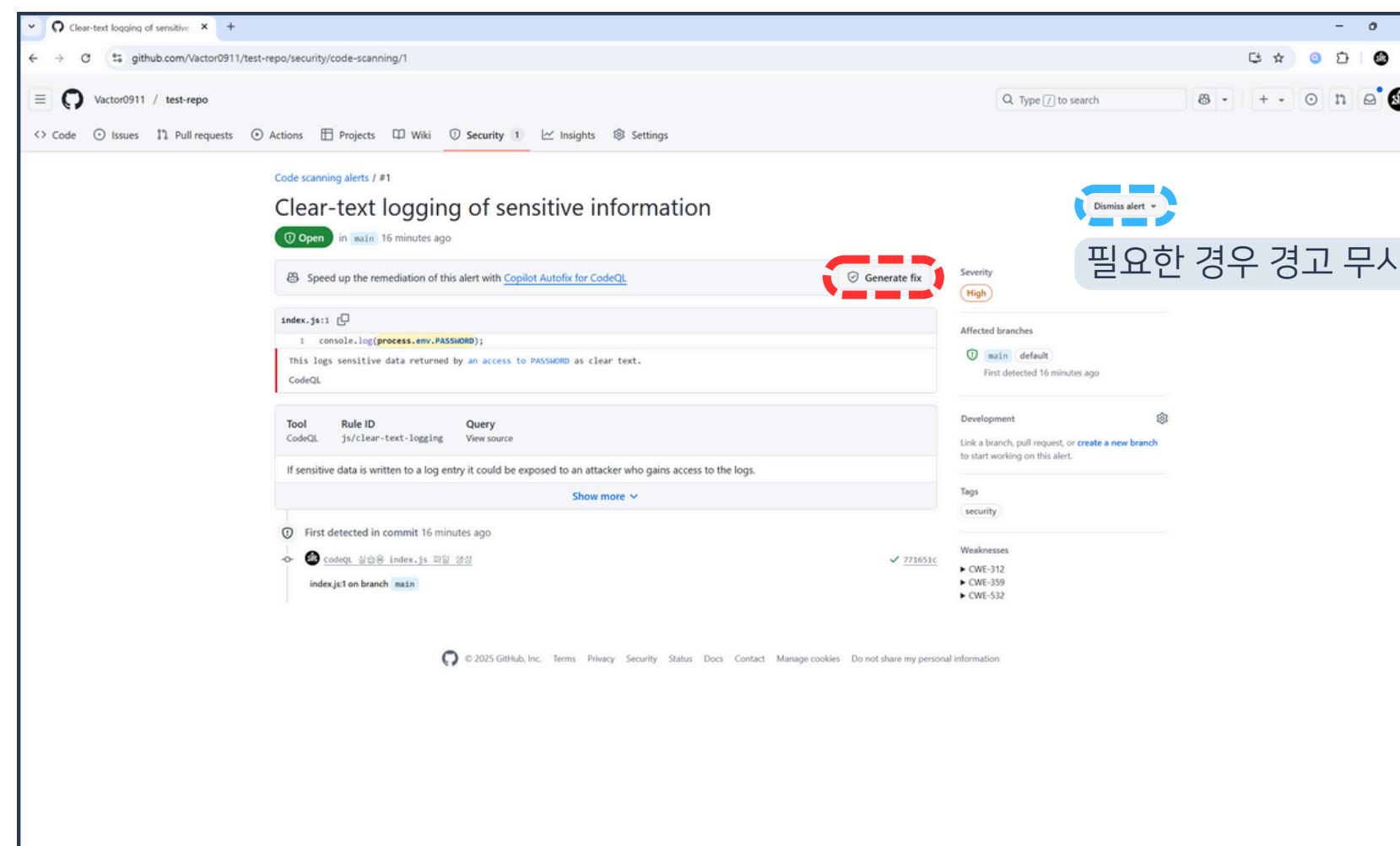
Tags

Weaknesses 취약점 목록

24. 보안 위협 보고서 확인



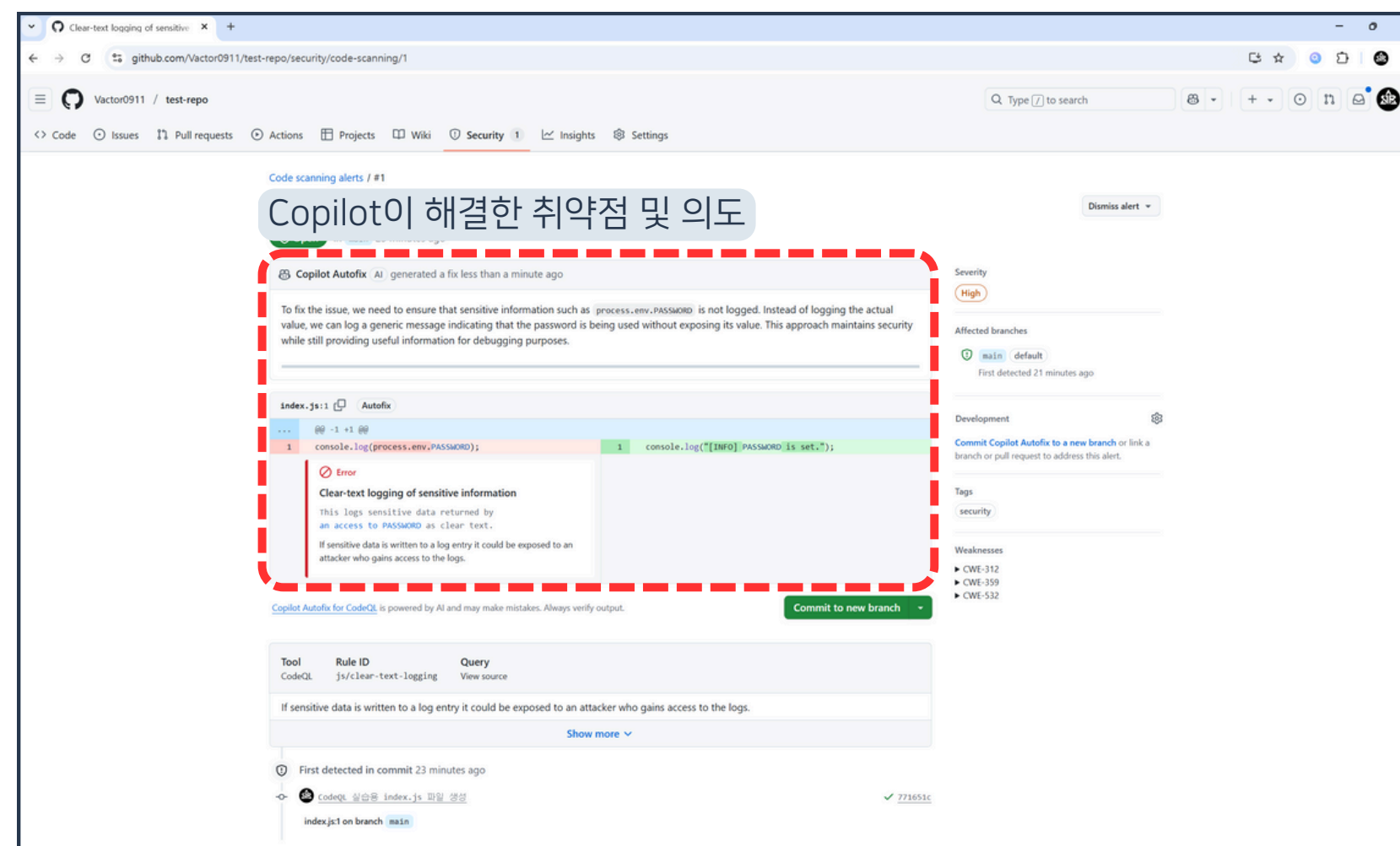
03 DependaBot과 CodeQL



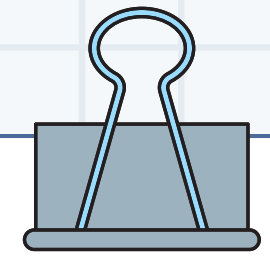
25. Generate fix 버튼 클릭



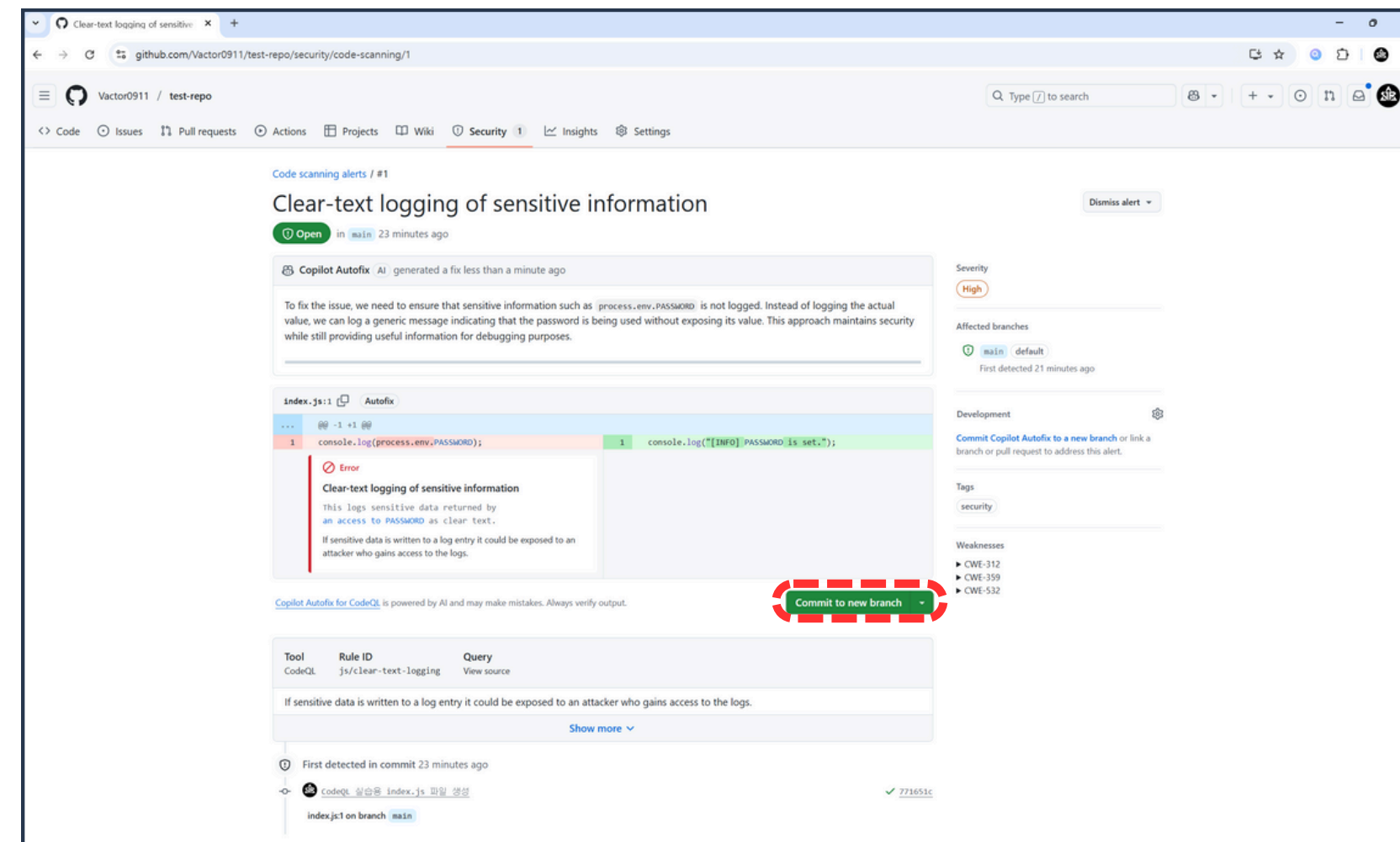
03 DependaBot과 CodeQL



26. Copilot Autofix 실행 확인



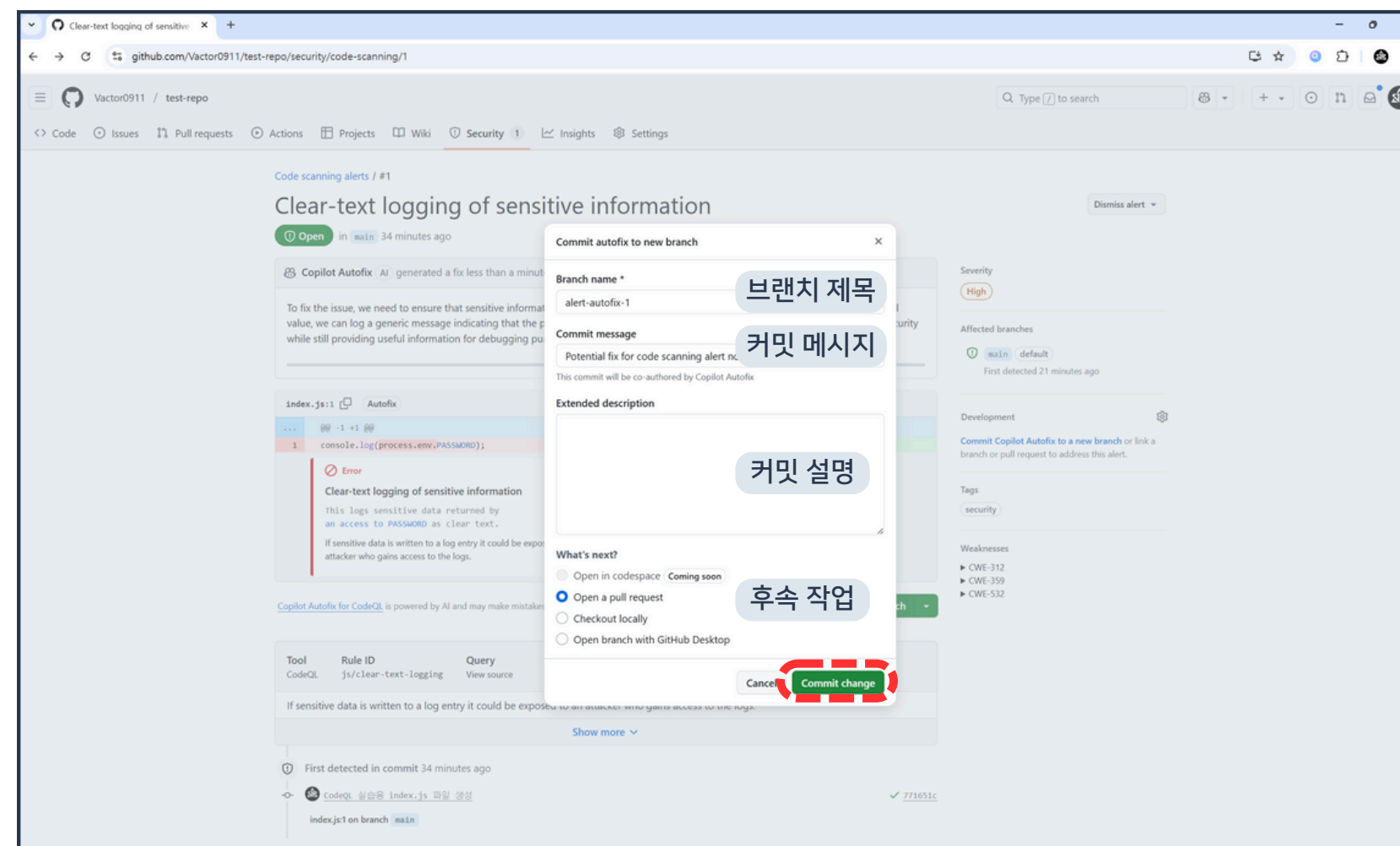
03 DependaBot과 CodeQL



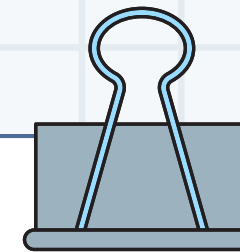
27. Commit to new branch 버튼 클릭



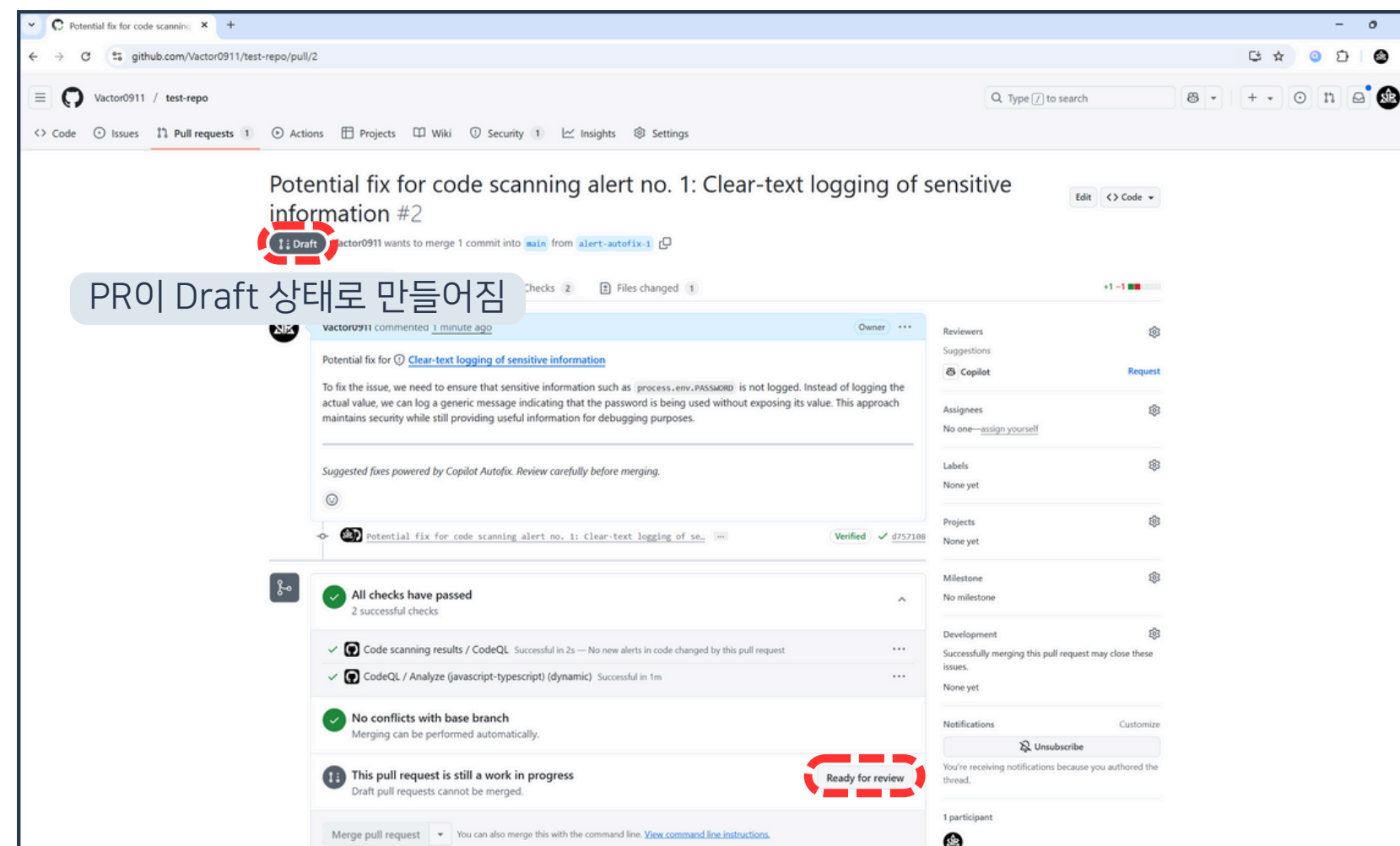
03 DependaBot과 CodeQL



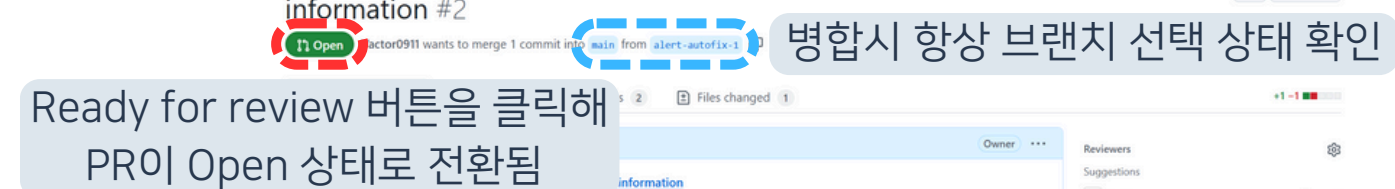
28. 브랜치 제목, 커밋 메시지 등 수정 후
Commit change 버튼 클릭



03 DependaBot과 CodeQL



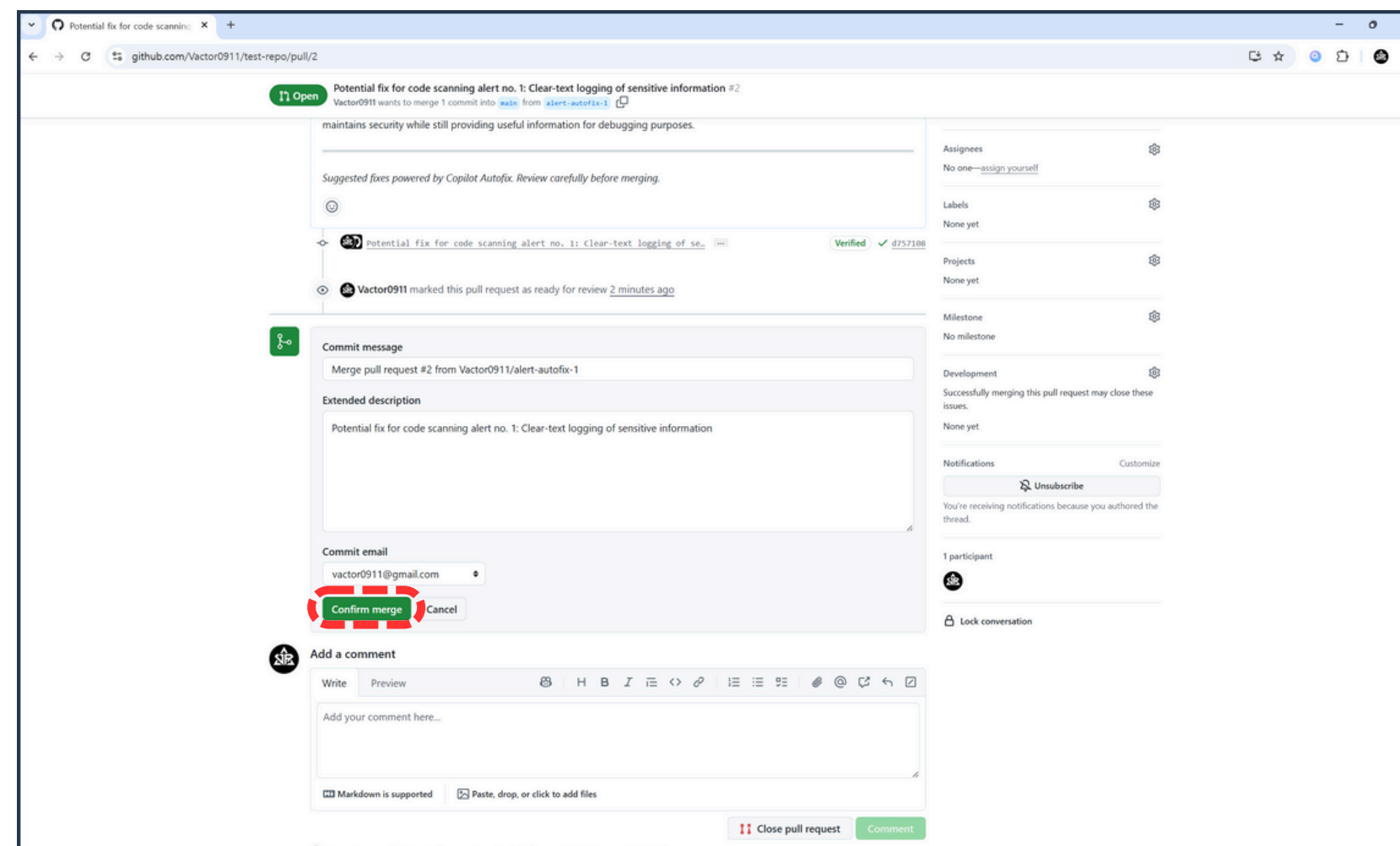
29. Ready for review 버튼 클릭



30. Merge pull request 버튼 클릭



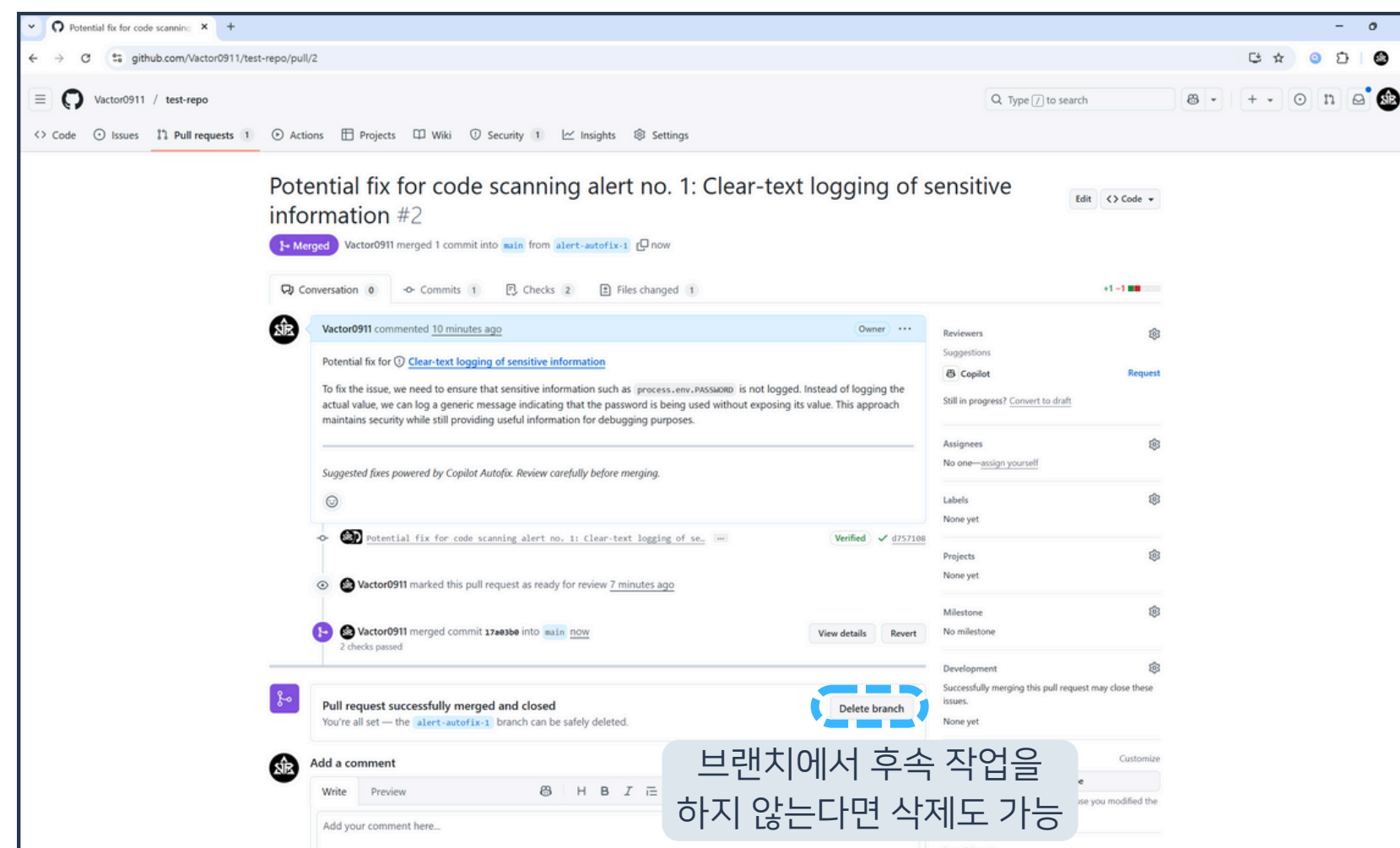
03 DependaBot과 CodeQL



31. Confirm merge 버튼 클릭



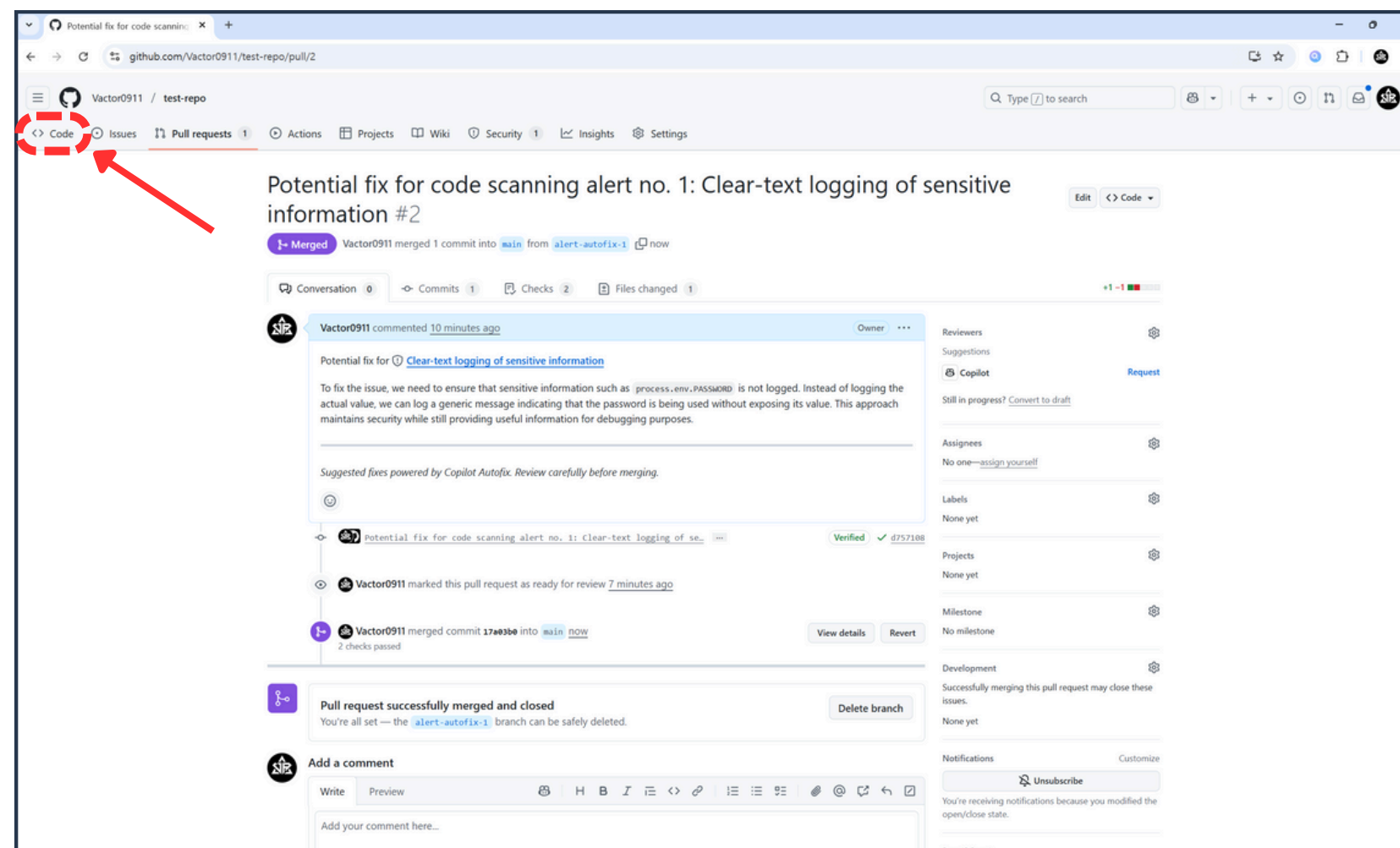
03 DependaBot과 CodeQL



32. 브랜치 병합 결과 확인



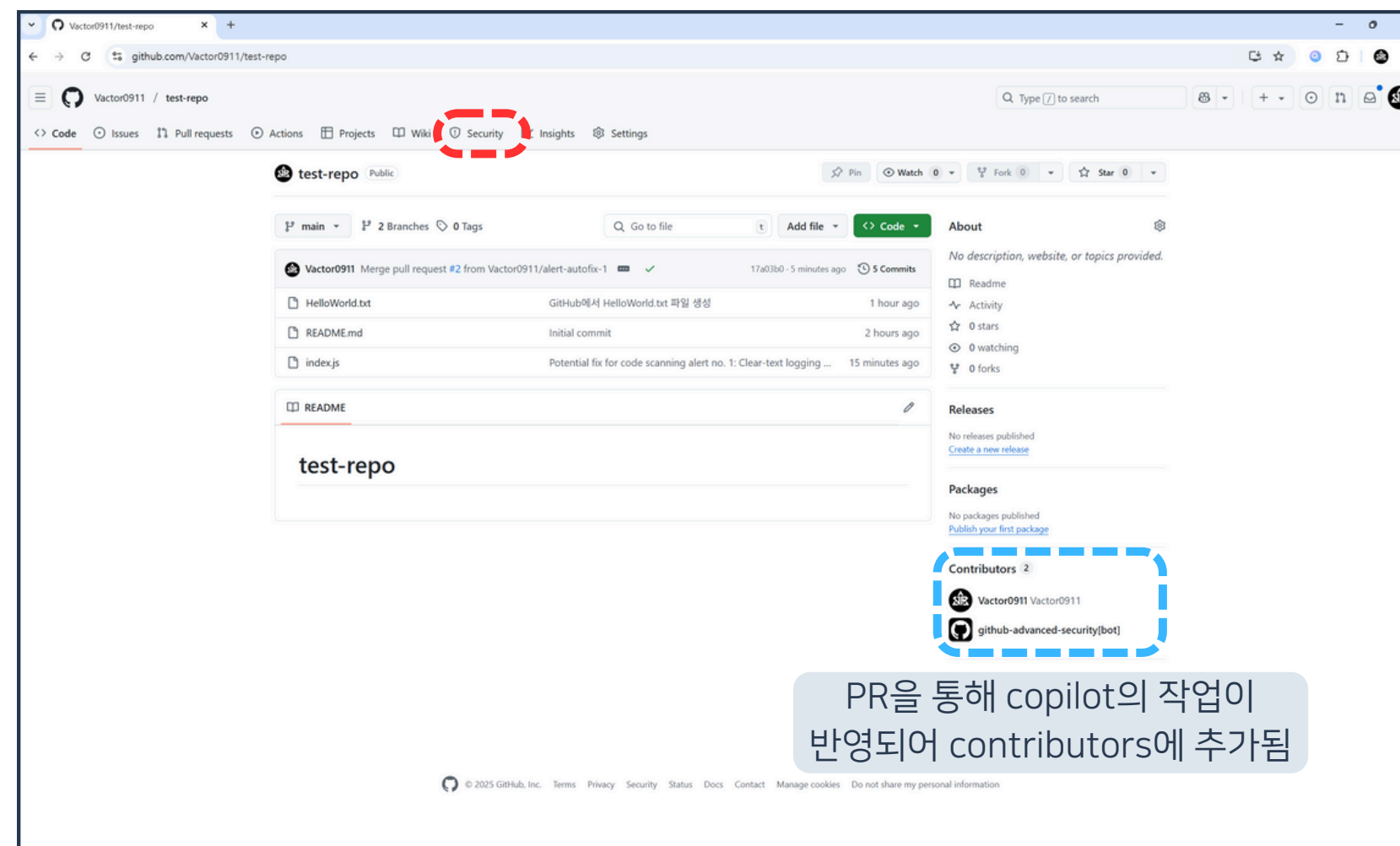
03 DependaBot과 CodeQL



33. Code 버튼 클릭



03 DependaBot과 CodeQL



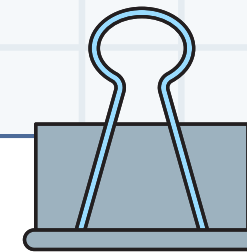
34. Security 경고 알림이 사라진 것 확인

|

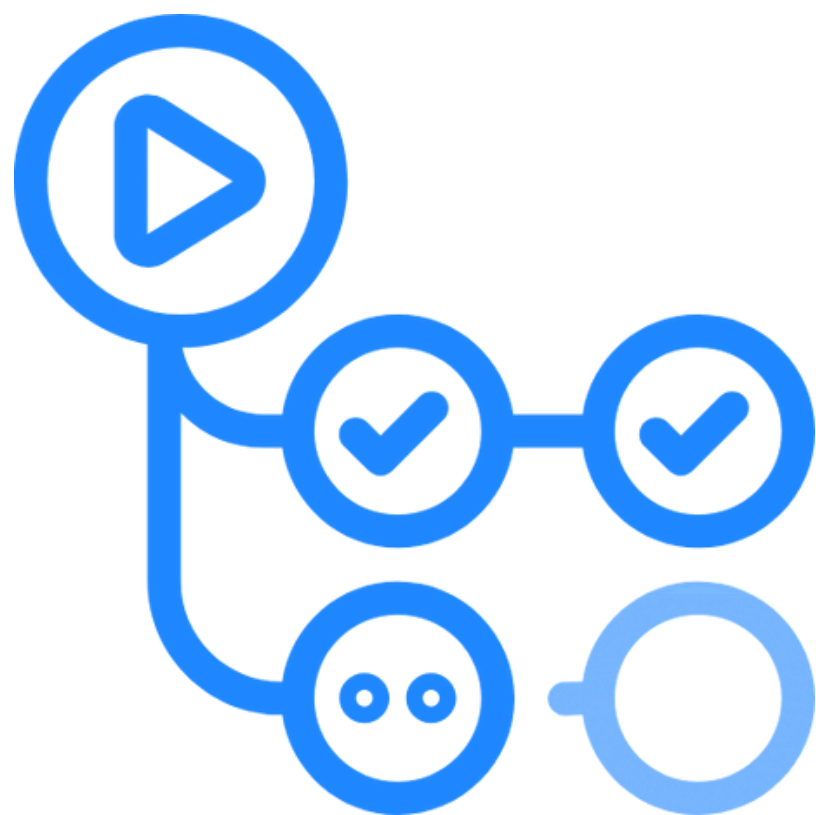
04

Actions로 자동화하기

|



04 Actions로 자동화하기

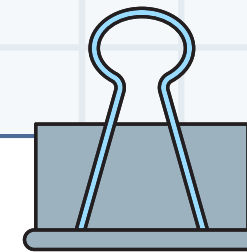


GitHub Actions

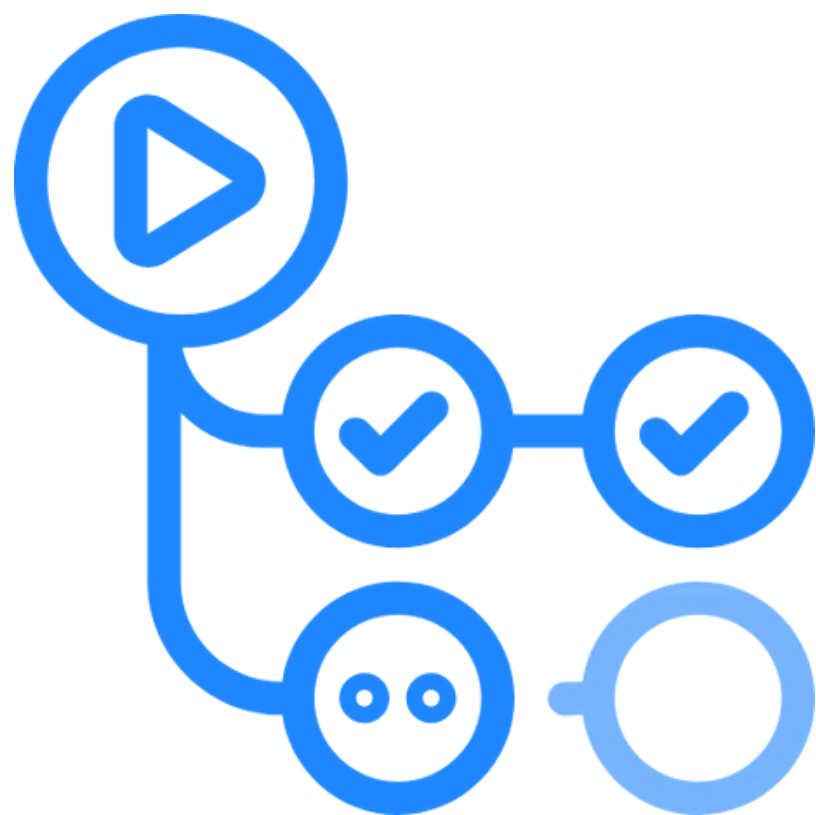
GitHub에서 공식적으로
제공하는 CI/CD 도구

특정 브랜치에서 특정 이벤트가
발생했을 때 작업을 실행

개발의 워크플로우를 자동화하는 도구



04 Actions로 자동화하기



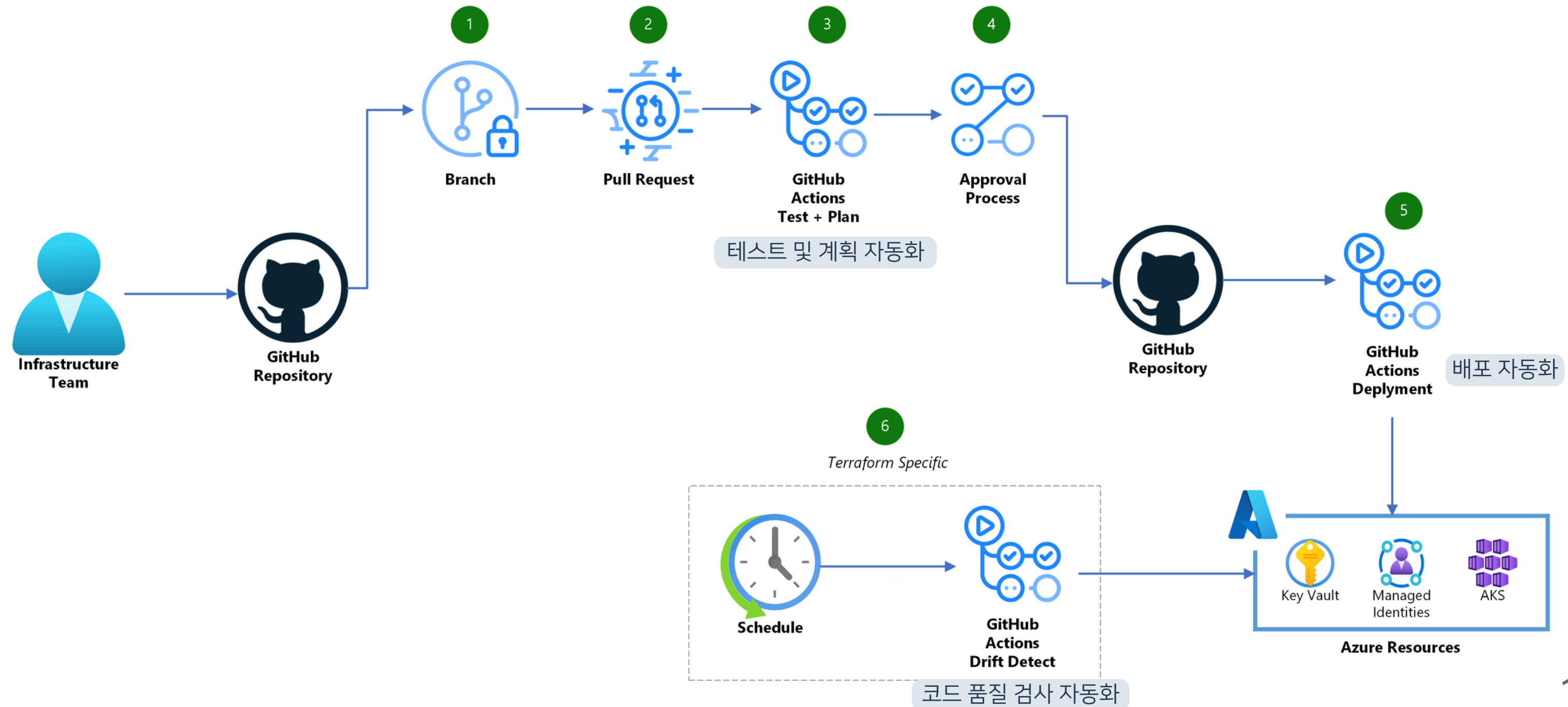
GitHub Actions

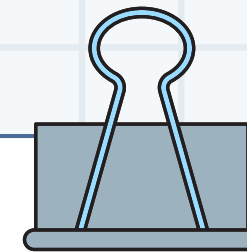
빌드 및 배포 자동화

소스 코드 테스트 자동화

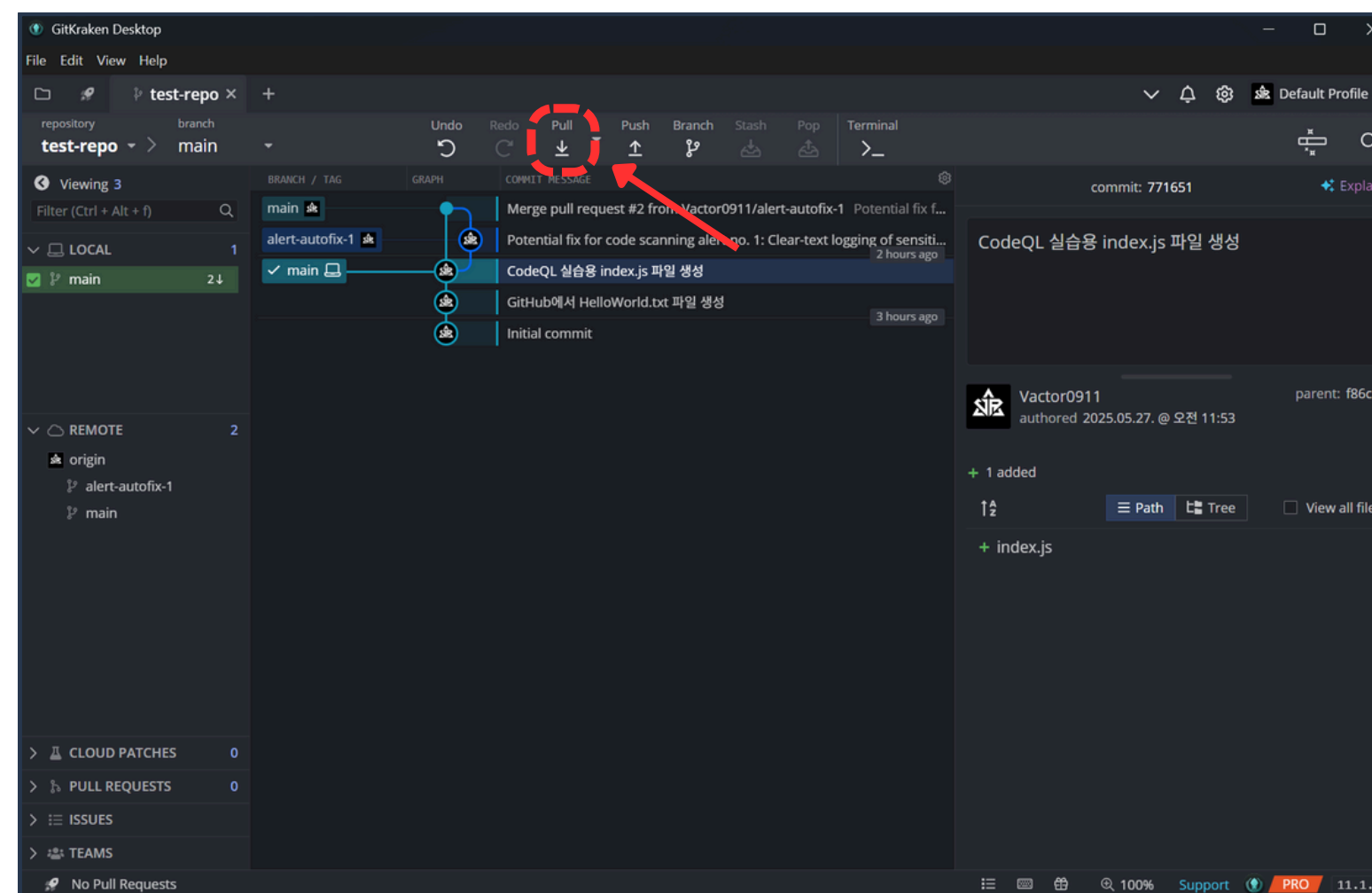
특정 이벤트 발생시 스크립트 실행

04 Actions로 자동화하기



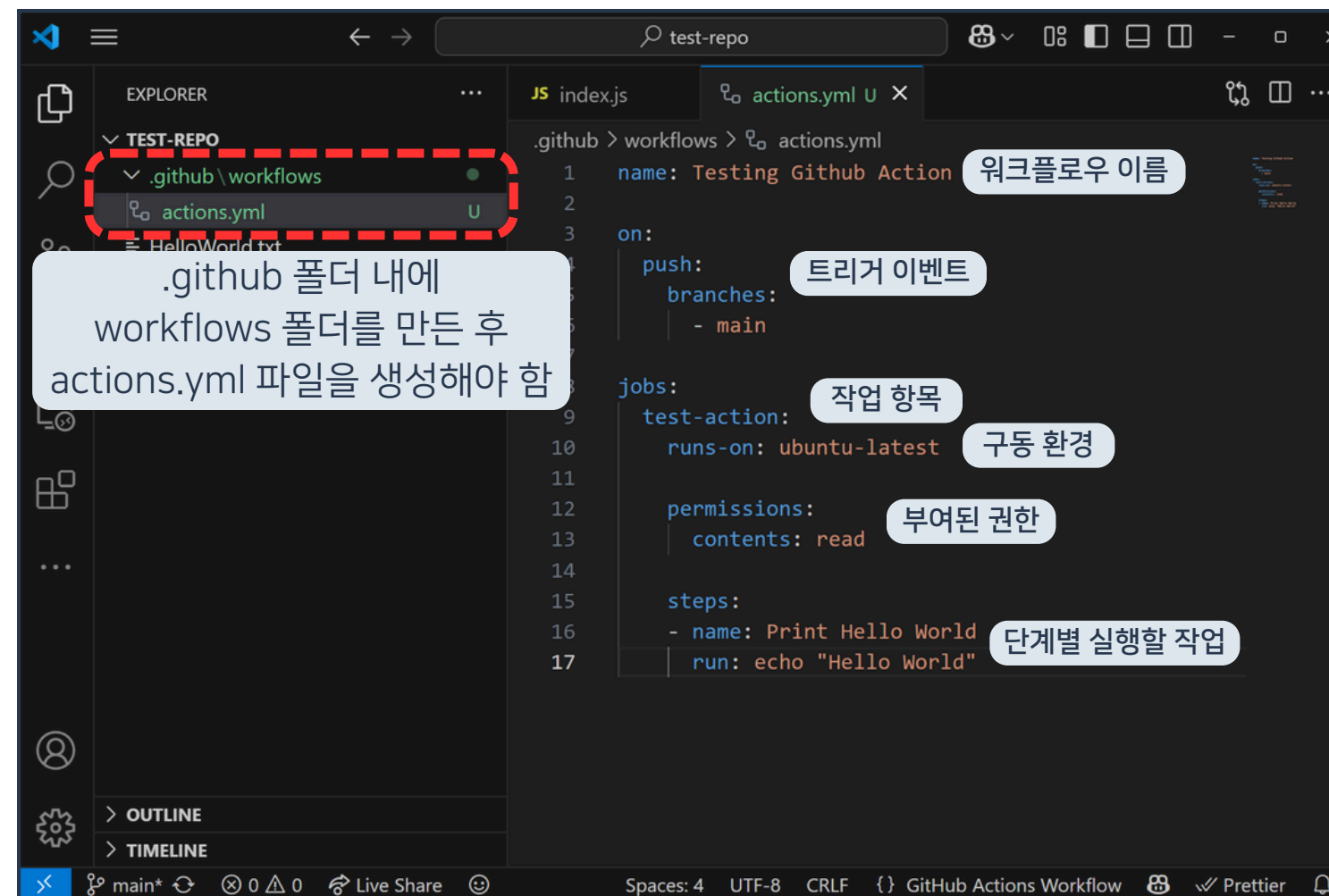
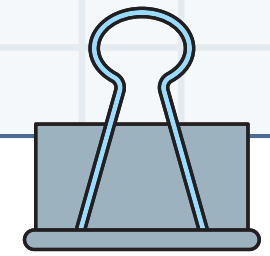


04 Actions로 자동화하기



1. Pull 버튼 클릭

04 Actions로 자동화하기

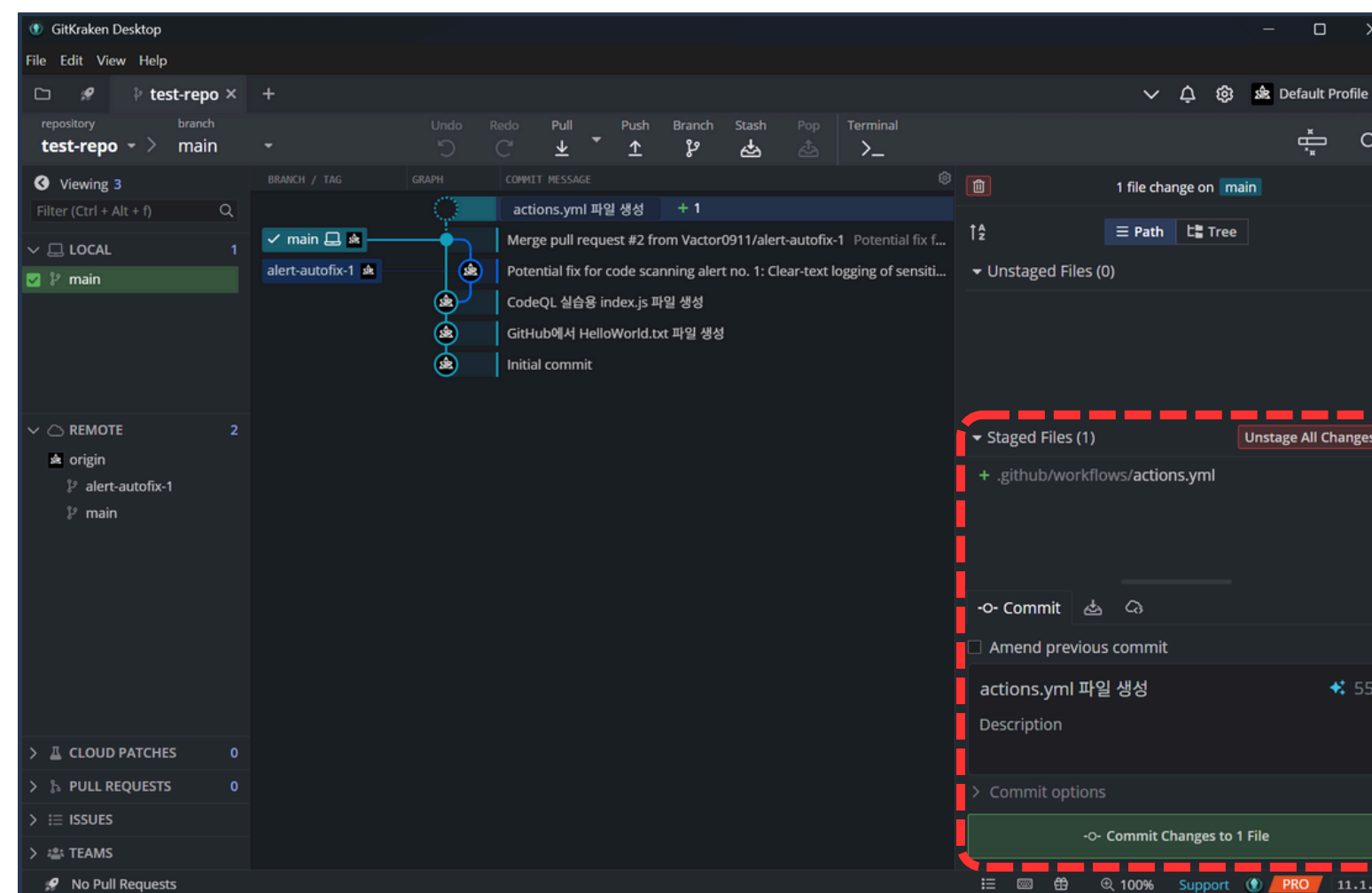


강의 자료 다운로드

2. .github/workflows/actions.yml 파일 생성



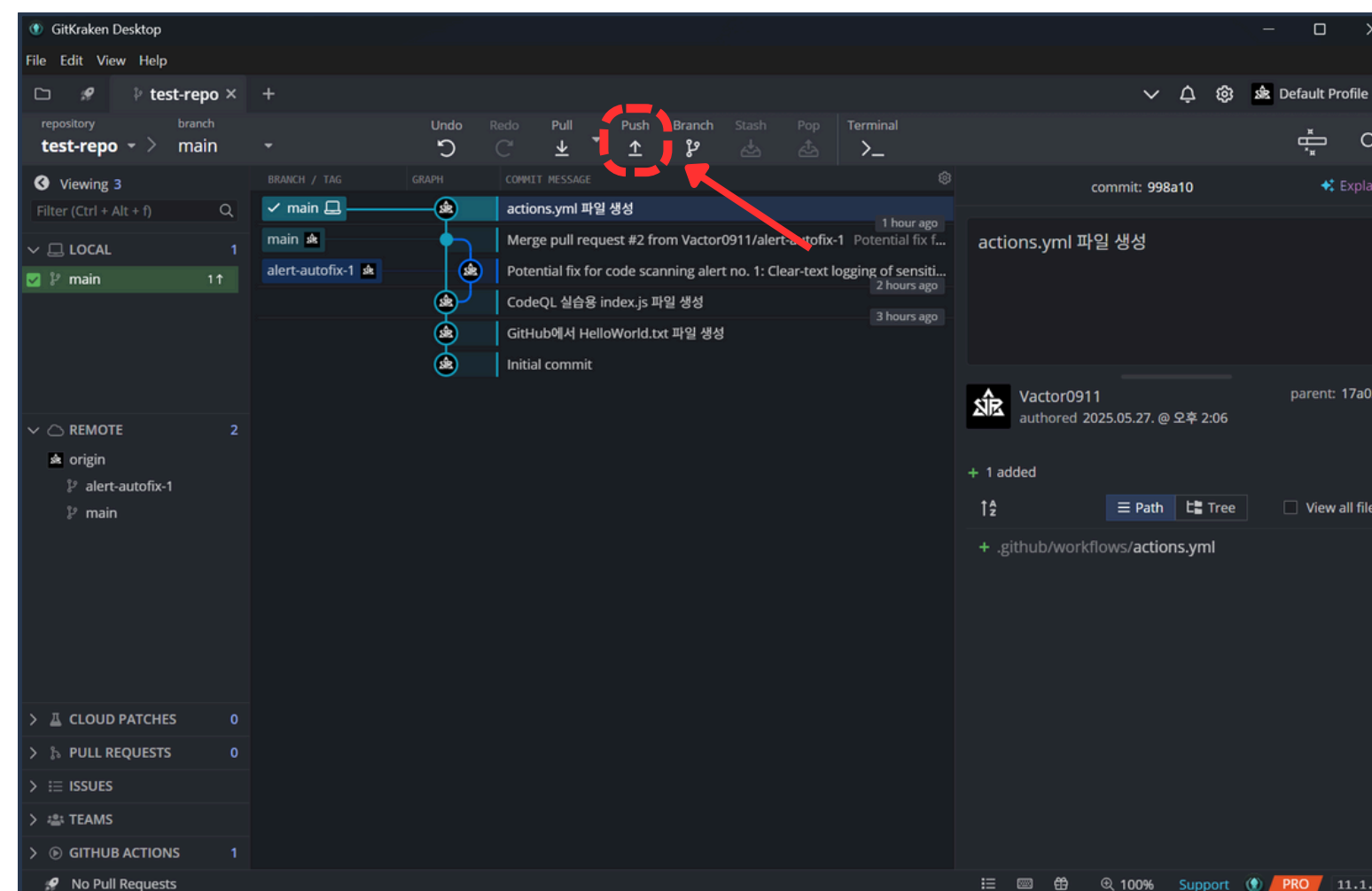
04 Actions로 자동화하기



3. 변경점 커밋



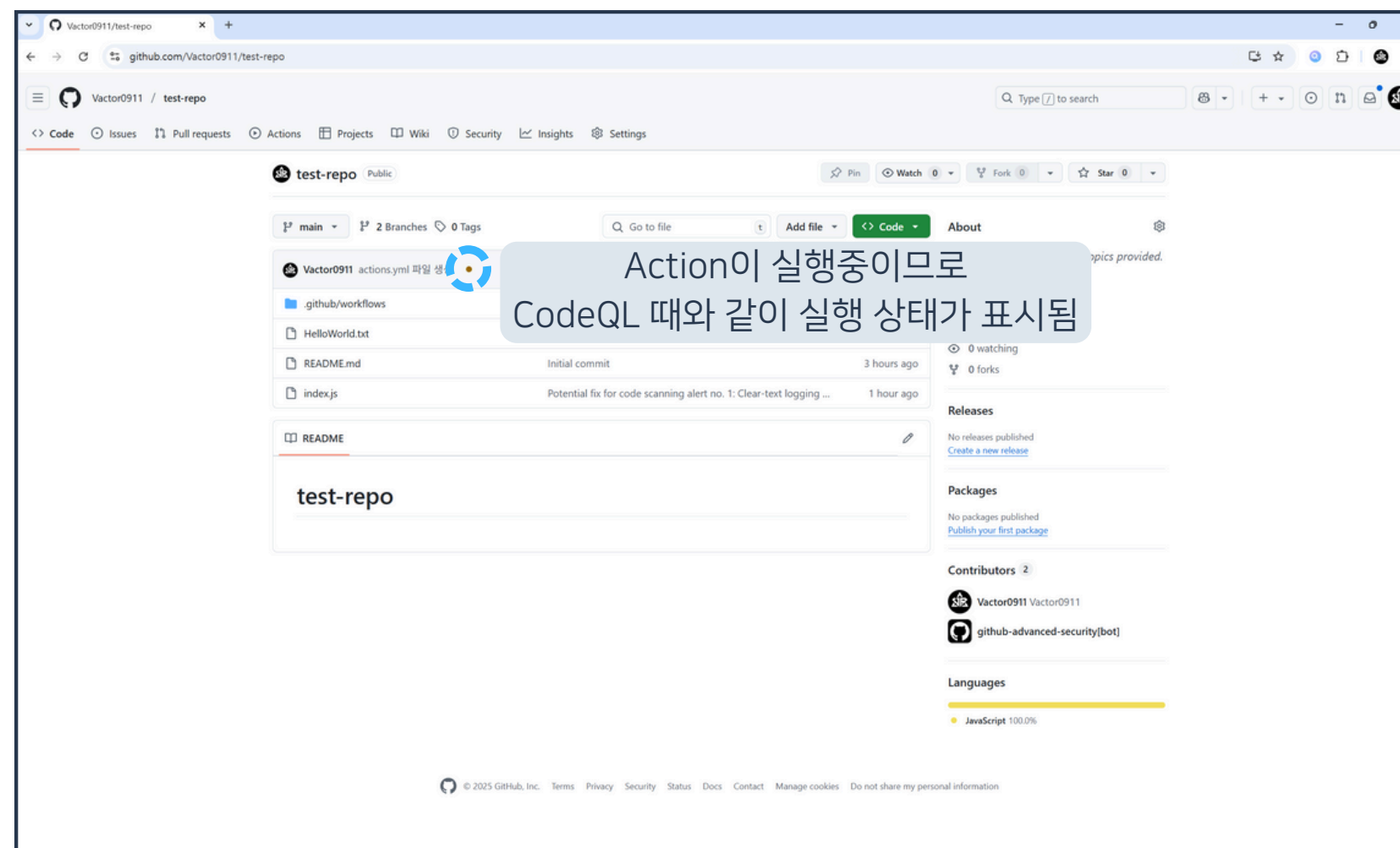
04 Actions로 자동화하기



4. Push 버튼 클릭



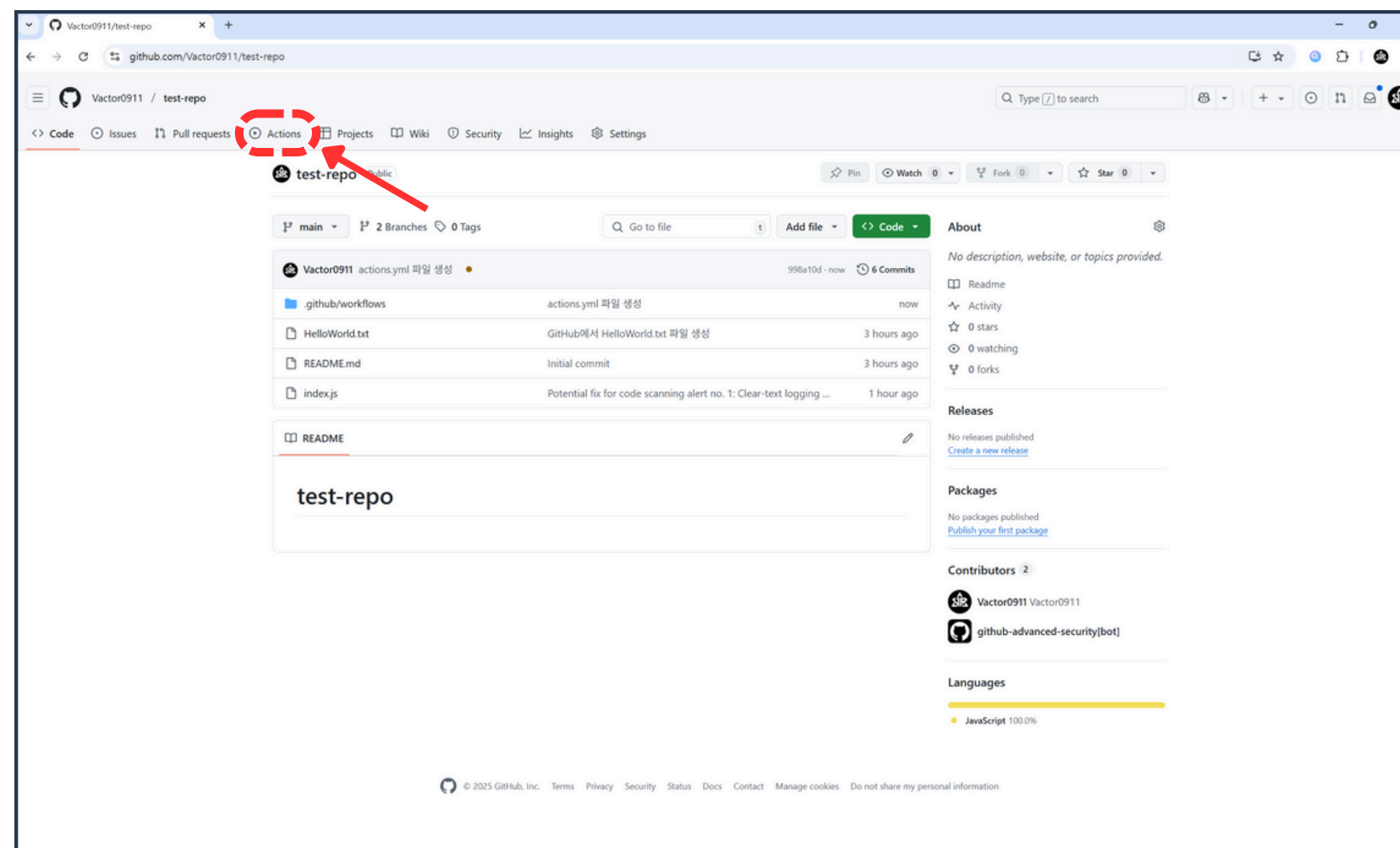
04 Actions로 자동화하기



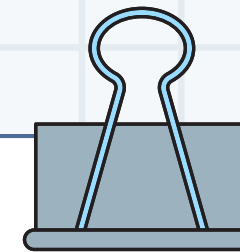
5. GitHub 리포지토리 접속



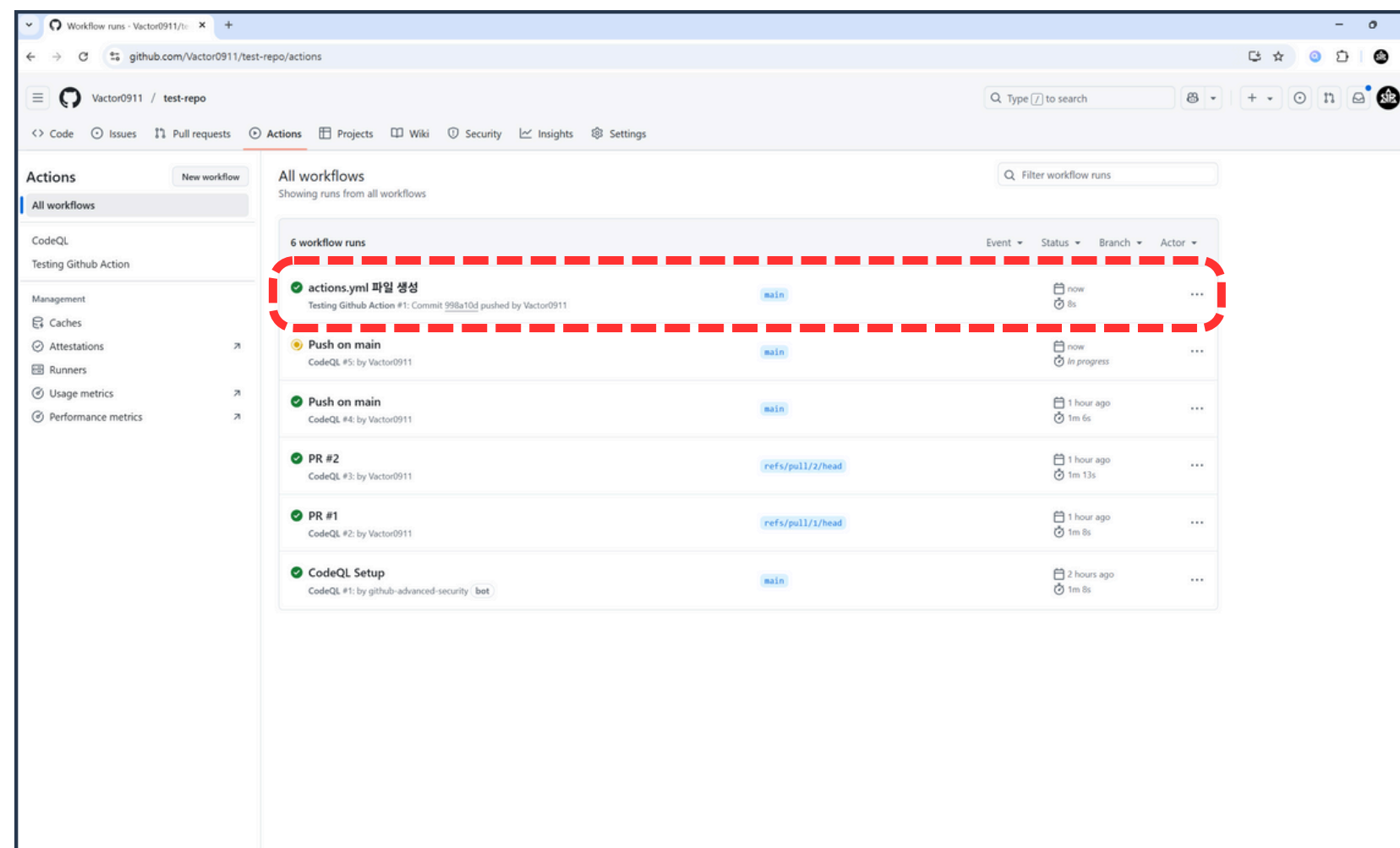
04 Actions로 자동화하기



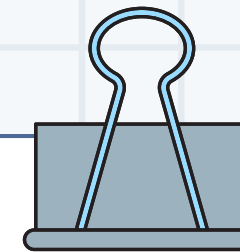
6. Actions 버튼 클릭



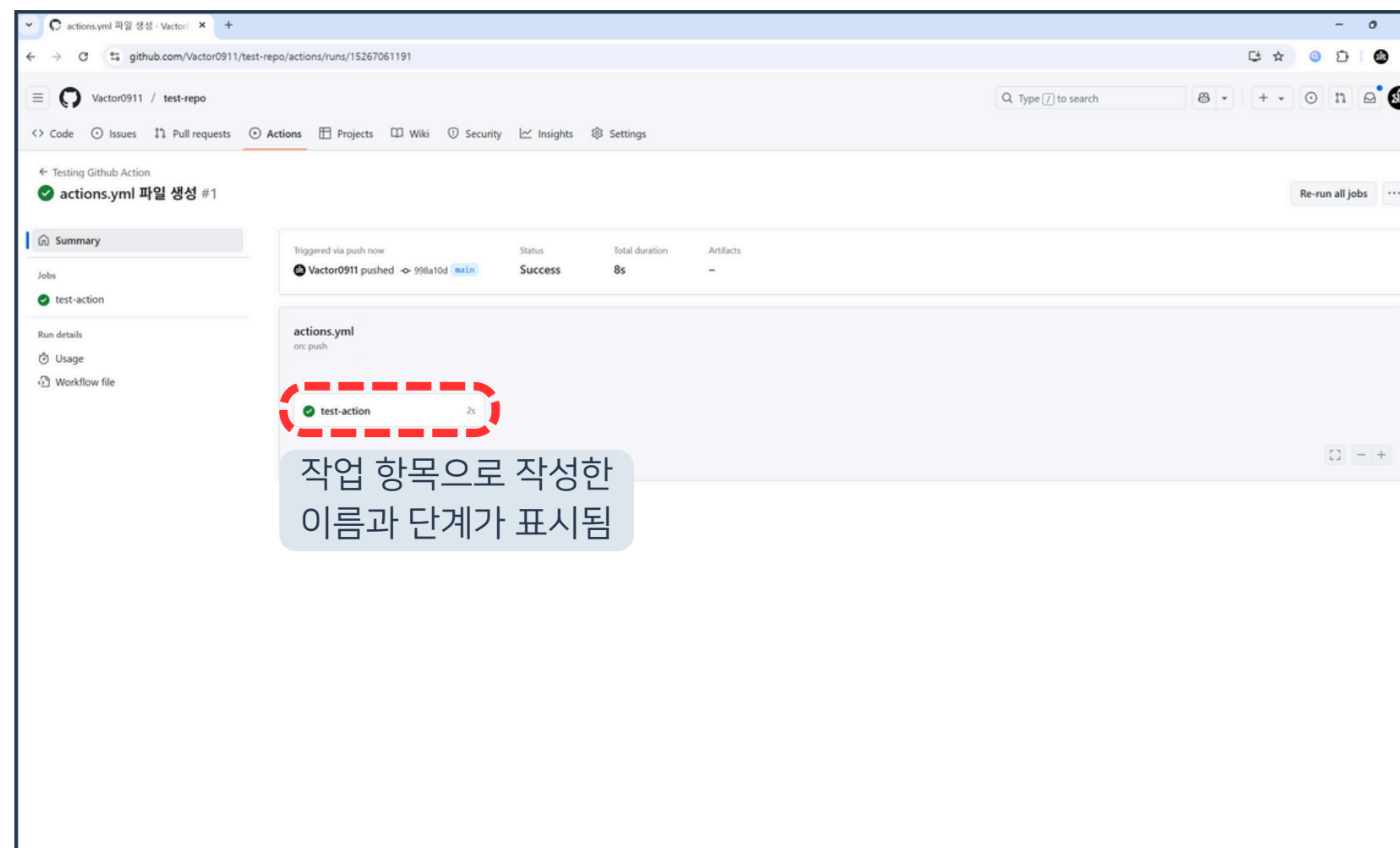
04 Actions로 자동화하기



7. actions.yml 파일 생성 항목 클릭



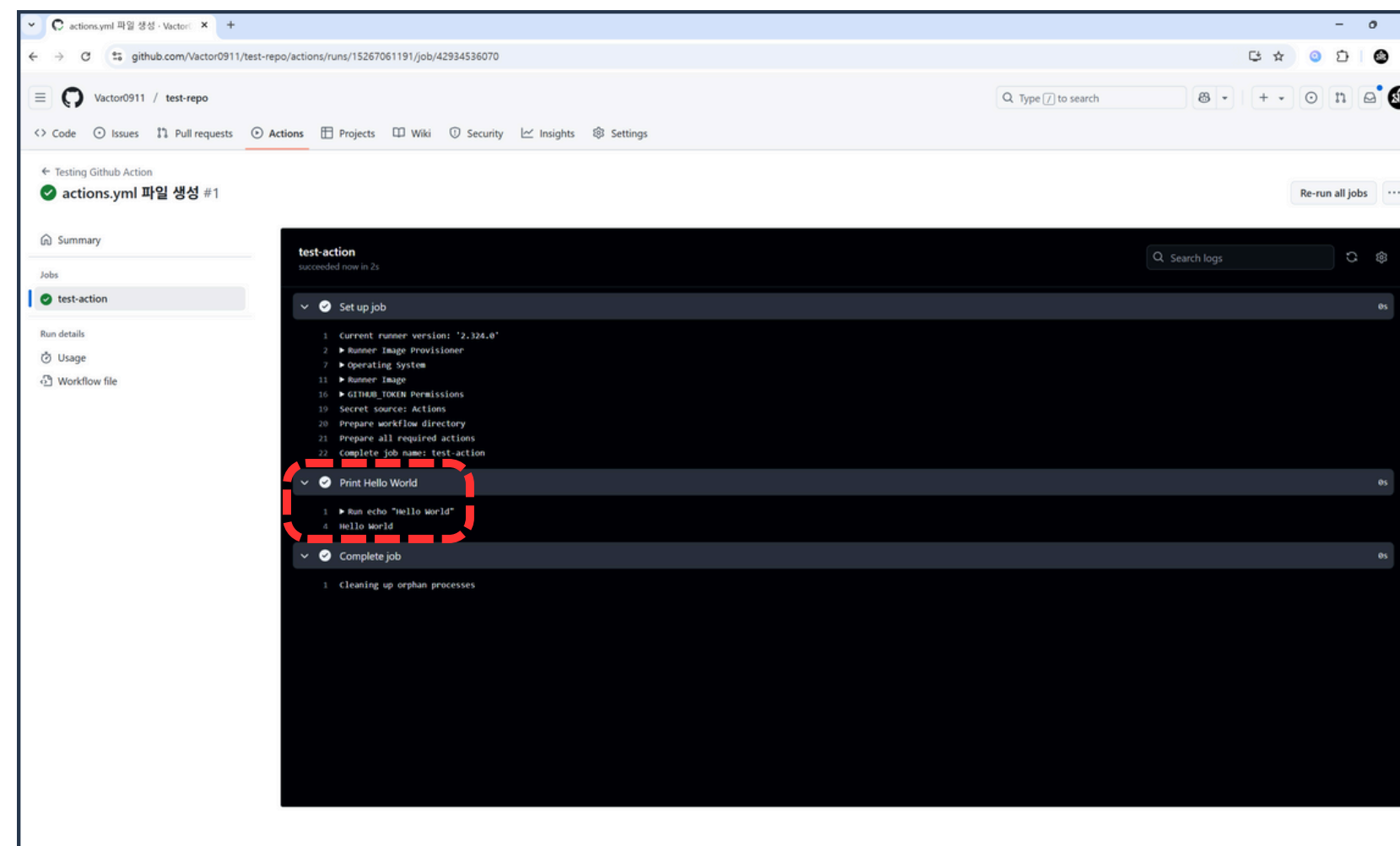
04 Actions로 자동화하기



8. test-action 항목 클릭



04 Actions로 자동화하기



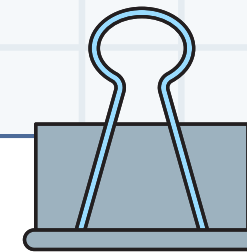
9. test-action 단계 실행 결과 확인

|

05

Secrets로 안전하게 보호하기

|



05 Secrets로 안전하게 보호하기

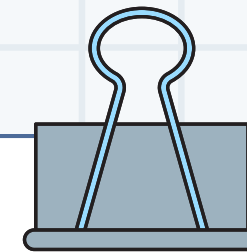


GitHub Secrets

특정 값을 외부로부터 숨기기 위해
사용하는 GitHub 기능

API 키, 서버 주소, 계정 ID / PW 등
민감한 정보를 숨기기 위해 사용

민감한 정보를 안전하게 사용하기 위한 기능



05 Secrets로 안전하게 보호하기



GitHub Secrets 작명 원칙

영문 대문자만 사용

띄어쓰기는 _ 기호로 대체

알기 쉬운 유의미한 단어로 구성

05 Secrets로 안전하게 보호하기

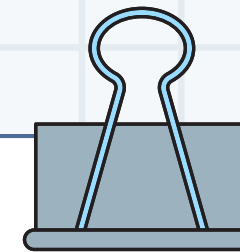


GitHub Secrets 주의사항

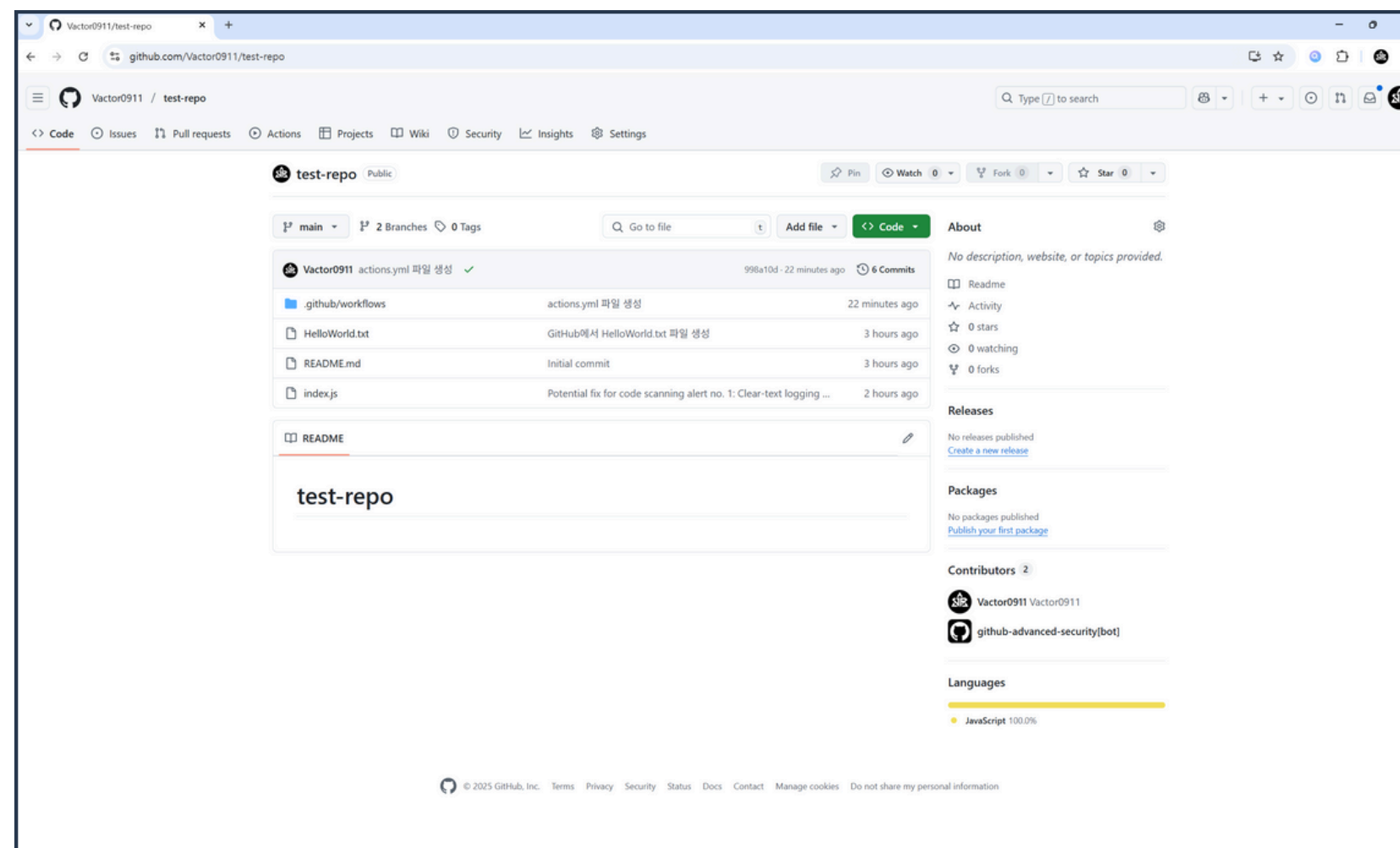
한 번 입력한 값은 열람이 불가

Secrets는 무적이 아님

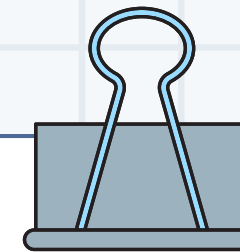
항상 다른 취약점이 없는지 검토할 것



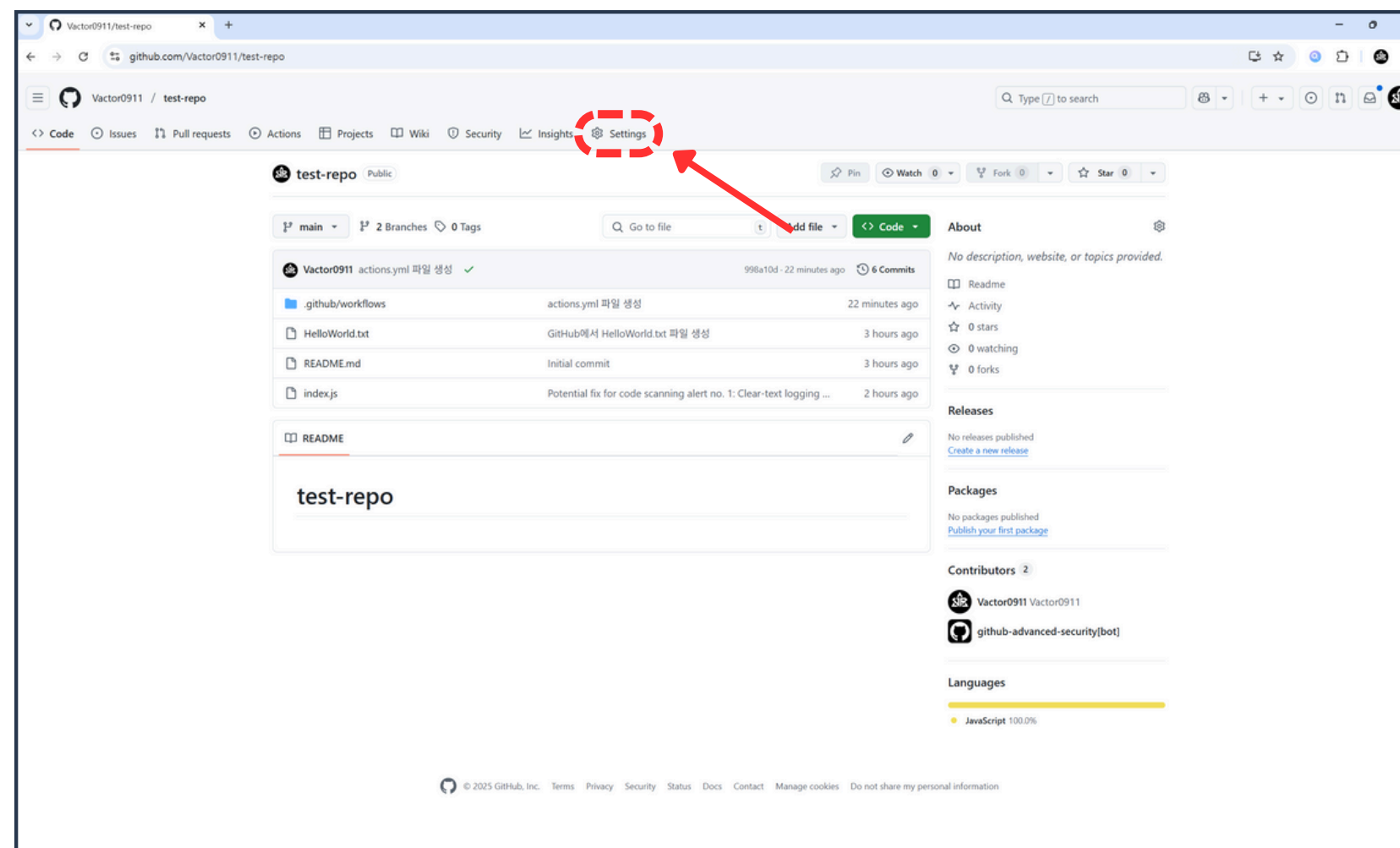
05 Secrets로 안전하게 보호하기



1. GitHub 리포지토리 접속



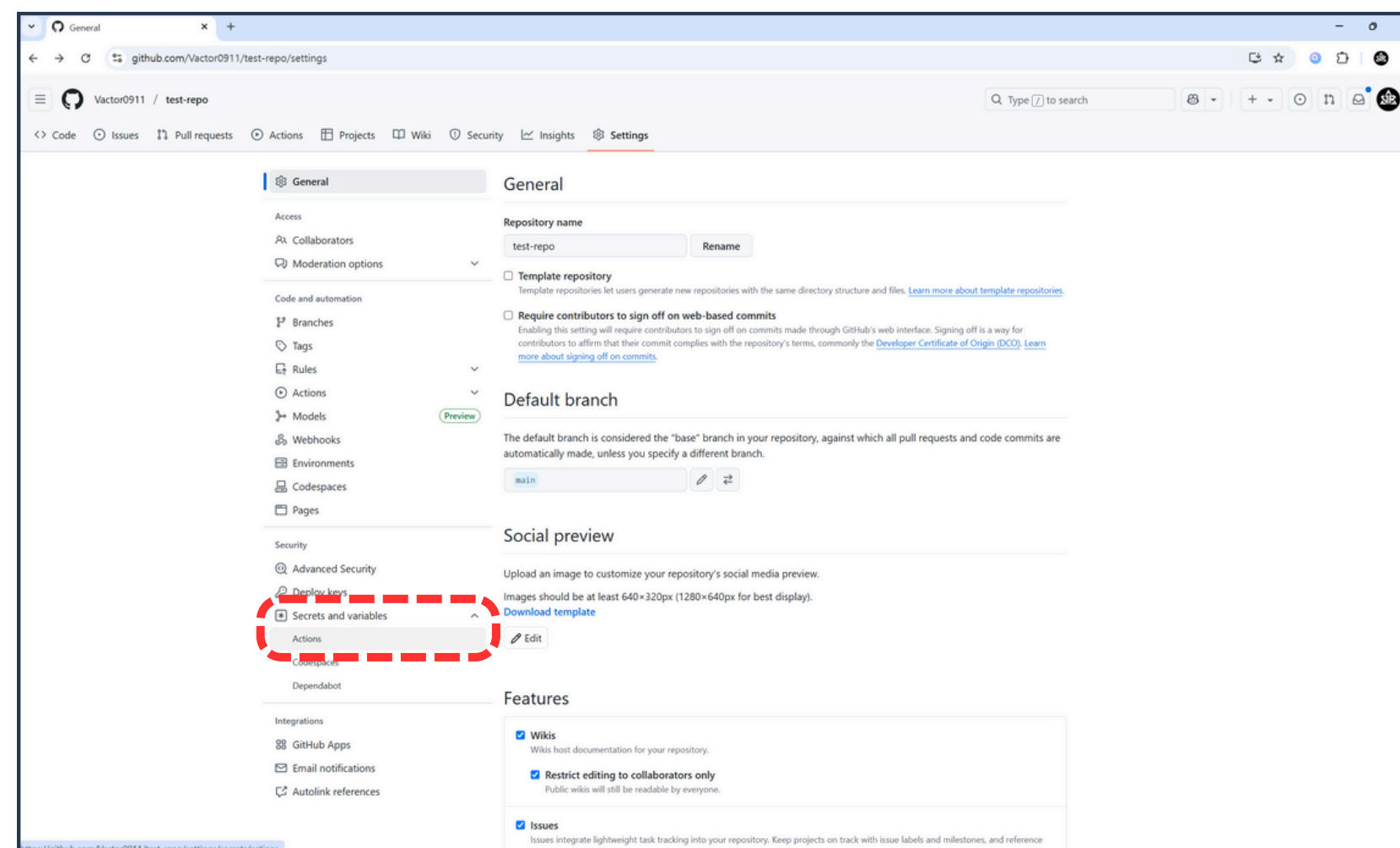
05 Secrets로 안전하게 보호하기



2. Settings 버튼 클릭



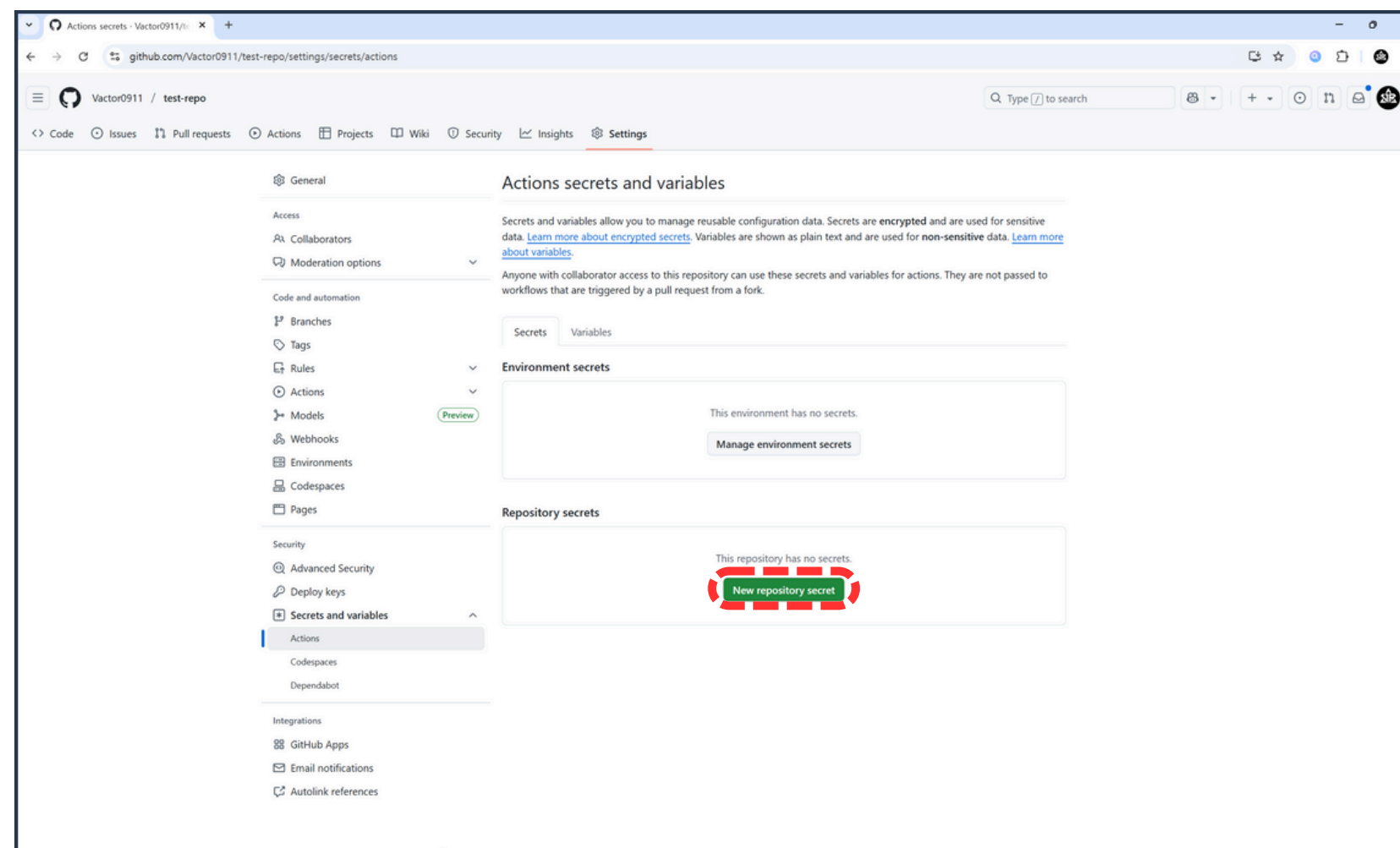
05 Secrets로 안전하게 보호하기



3. Secrets and variables > Actions 버튼 클릭



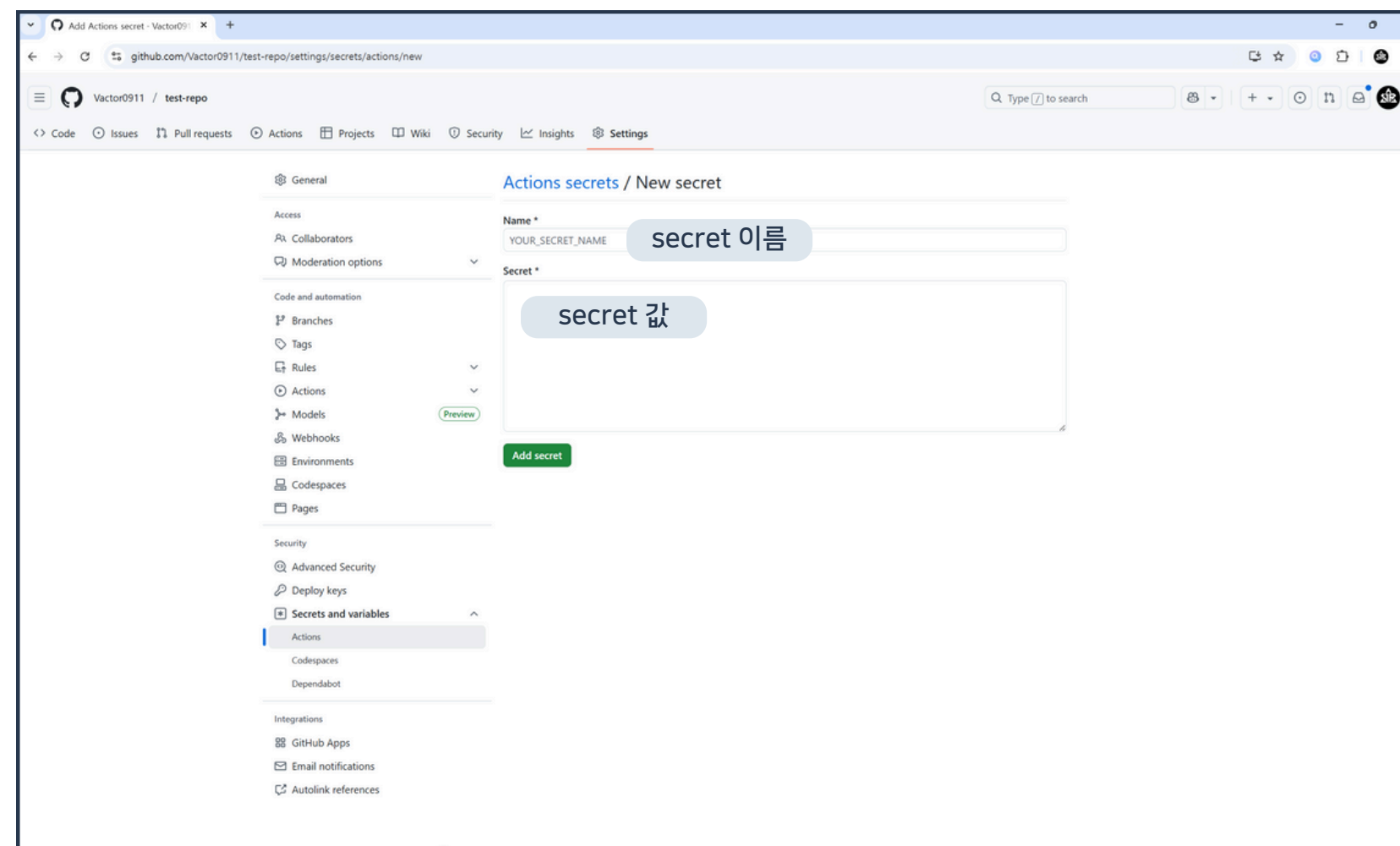
05 Secrets로 안전하게 보호하기



4. New repository secret 버튼 클릭

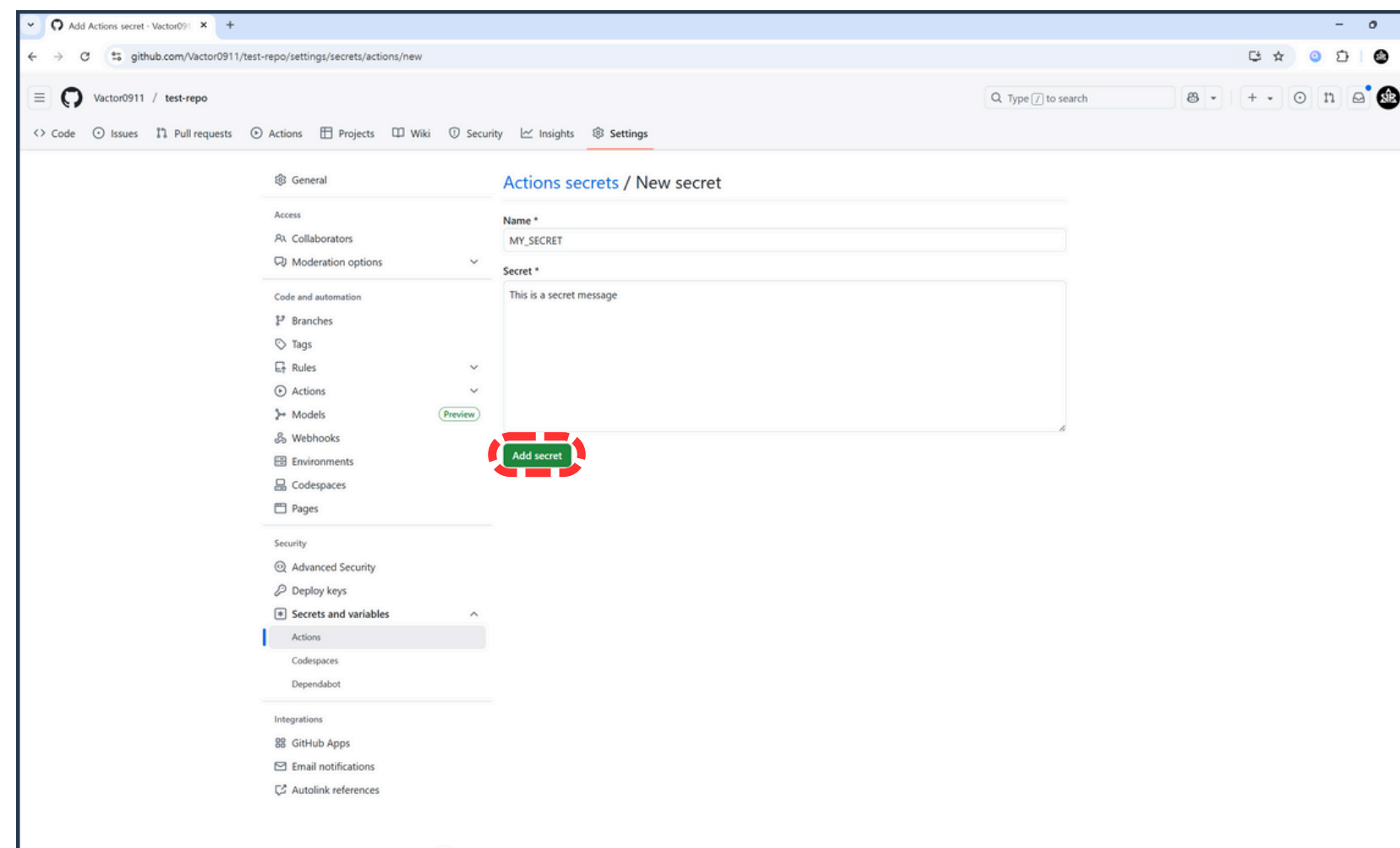


05 Secrets로 안전하게 보호하기





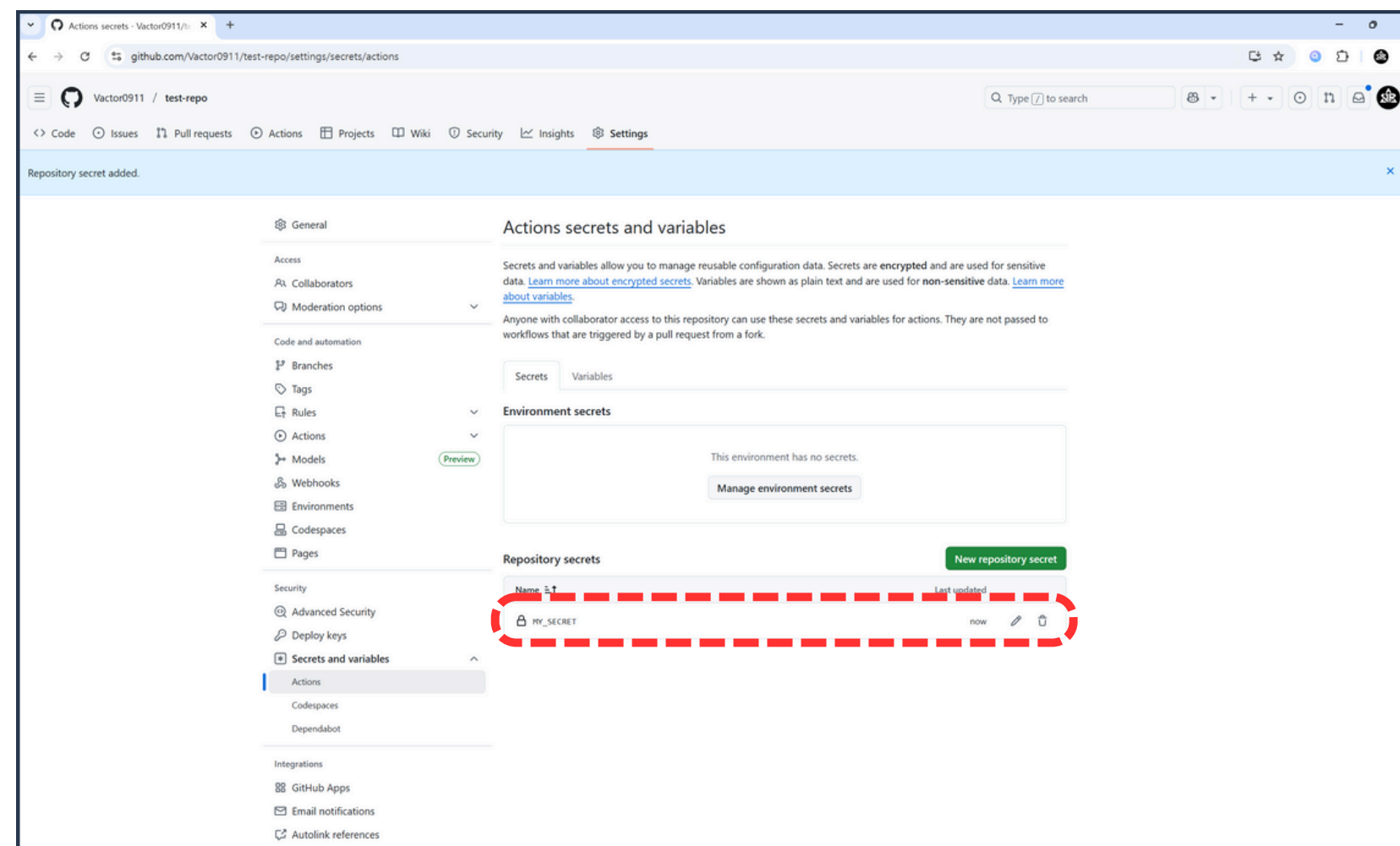
05 Secrets로 안전하게 보호하기



5. secret 이름, 값 입력 후 Add secret 버튼 클릭

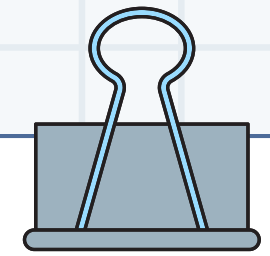


05 Secrets로 안전하게 보호하기



6. GitHub secret 생성 결과 확인

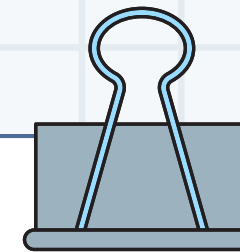
05 Secrets로 안전하게 보호하기



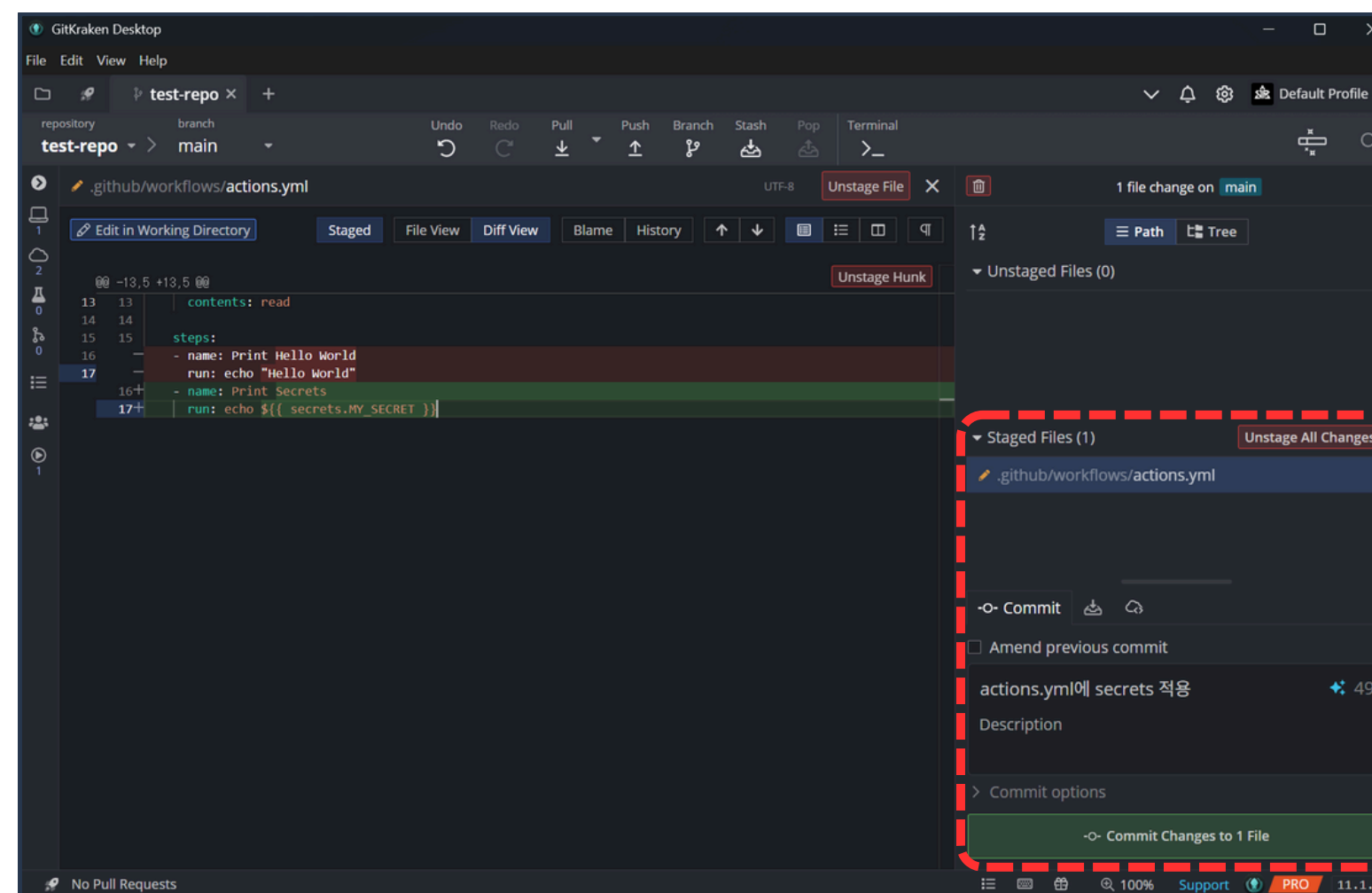
```
1 name: Testing Github Action
2
3 on:
4   push:
5     branches:
6       - main
7
8 jobs:
9   test-action:
10    runs-on: ubuntu-latest
11
12    permissions:
13      contents: read
14
15    steps:
16      - name: Print Secrets
17        run: echo ${{ secrets.MY_SECRET }}
```

GitHub secrets는 워크플로우 파일에서
\${{ secrets.이름 }} 형태로 참조 가능

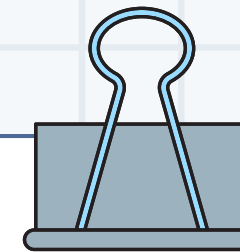
7. actions.yml 파일 수정



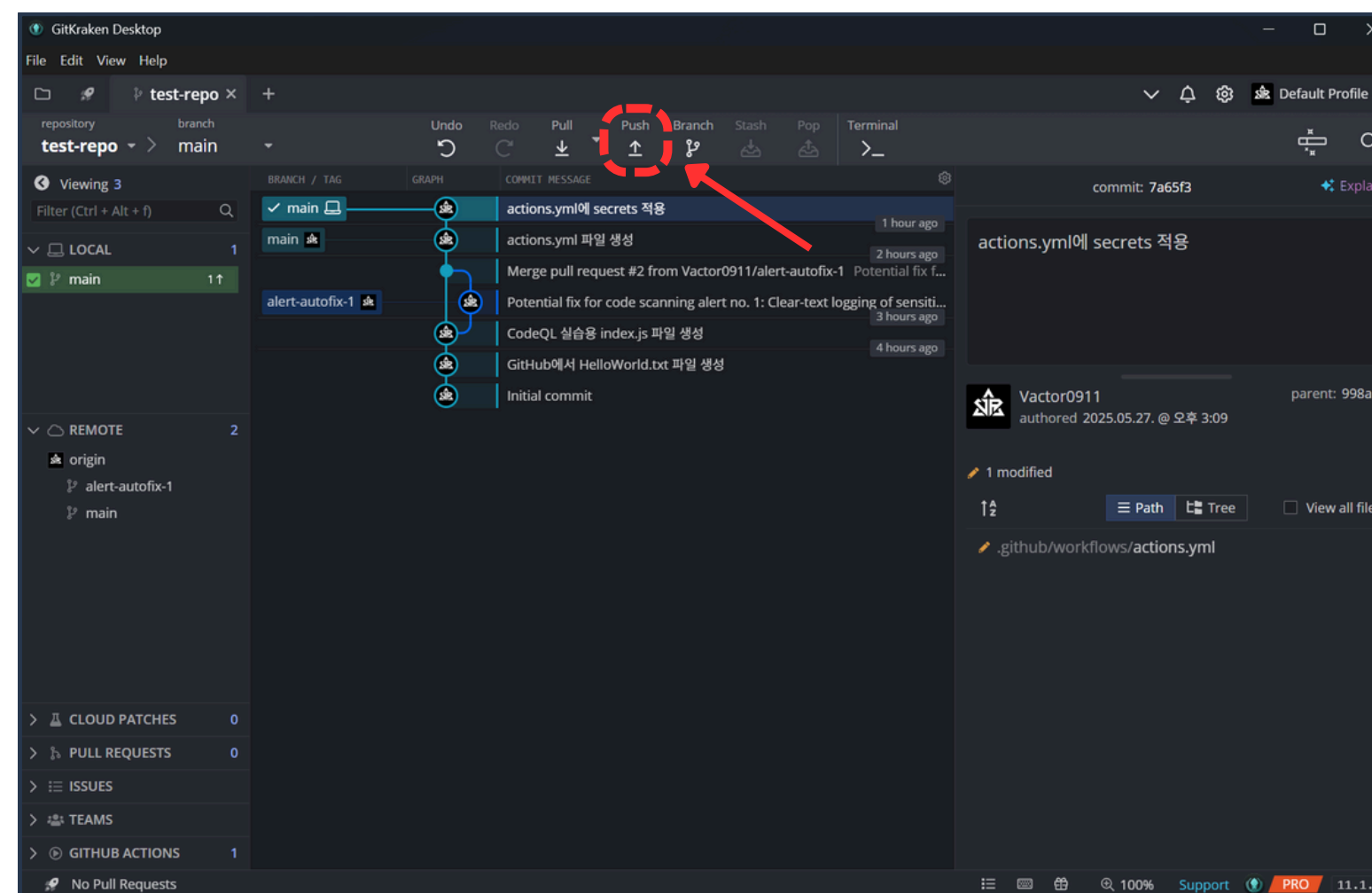
05 Secrets로 안전하게 보호하기



8. 변경점 커밋



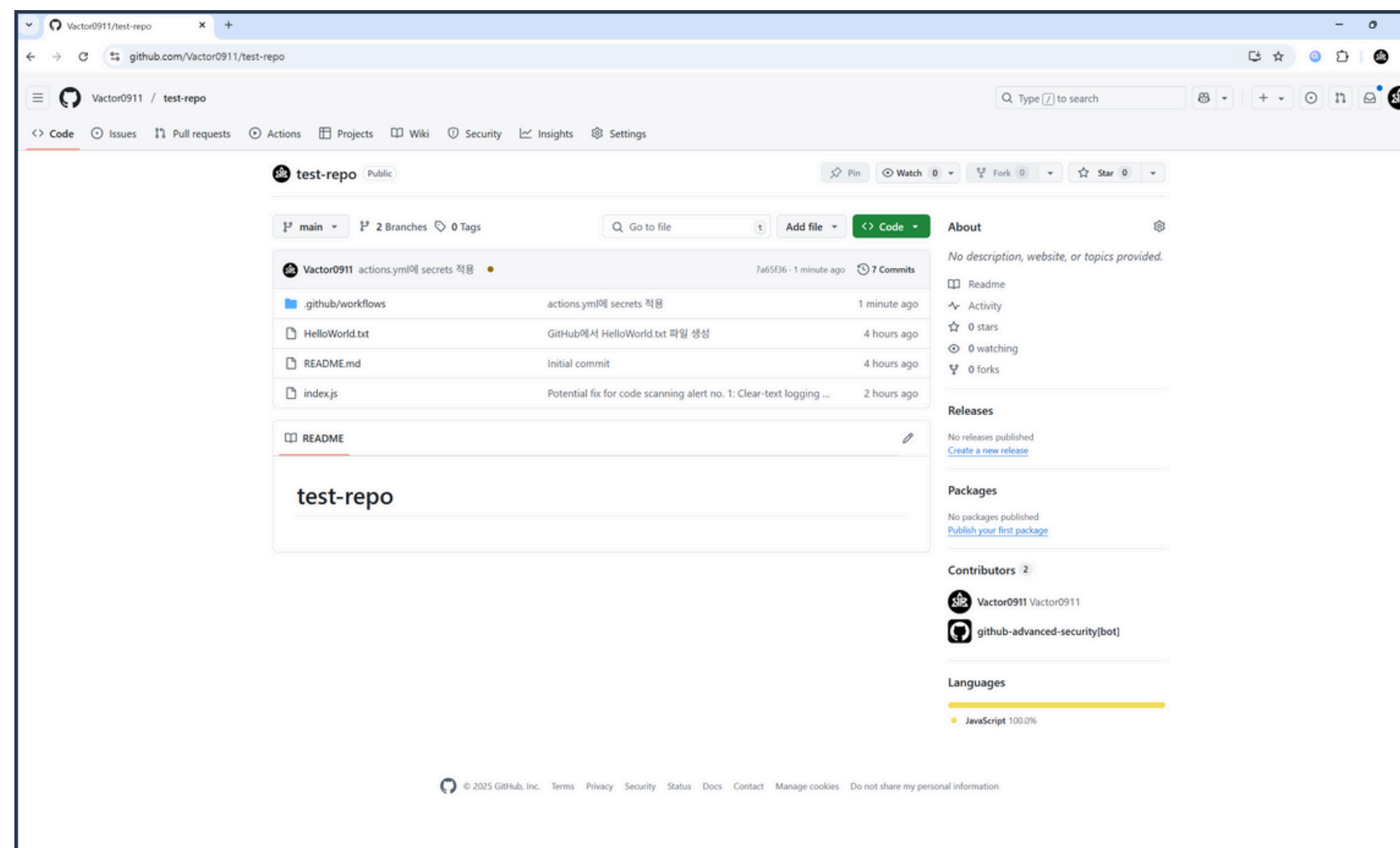
05 Secrets로 안전하게 보호하기



9. Push 버튼 클릭



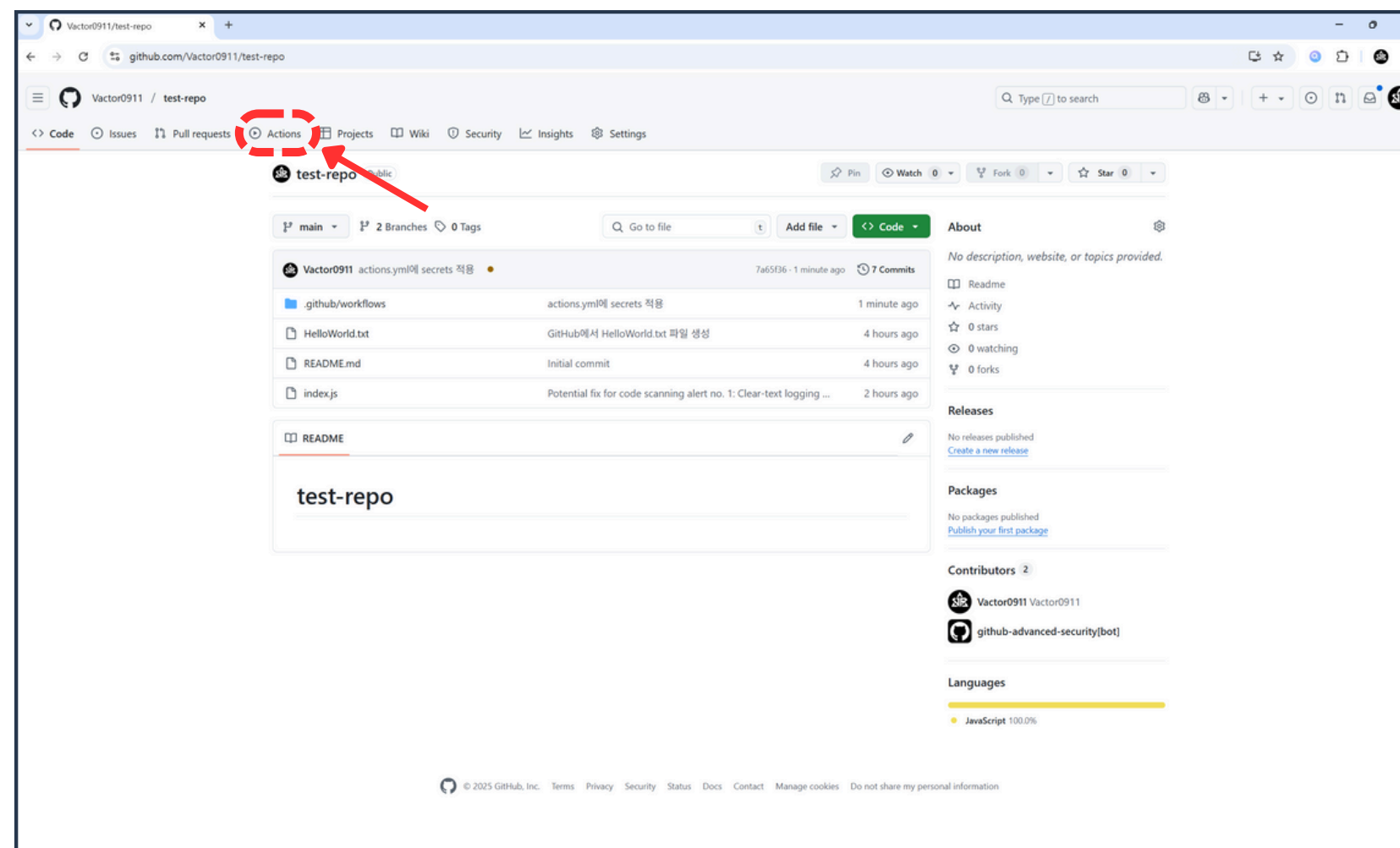
05 Secrets로 안전하게 보호하기



10. GitHub 리포지토리 접속



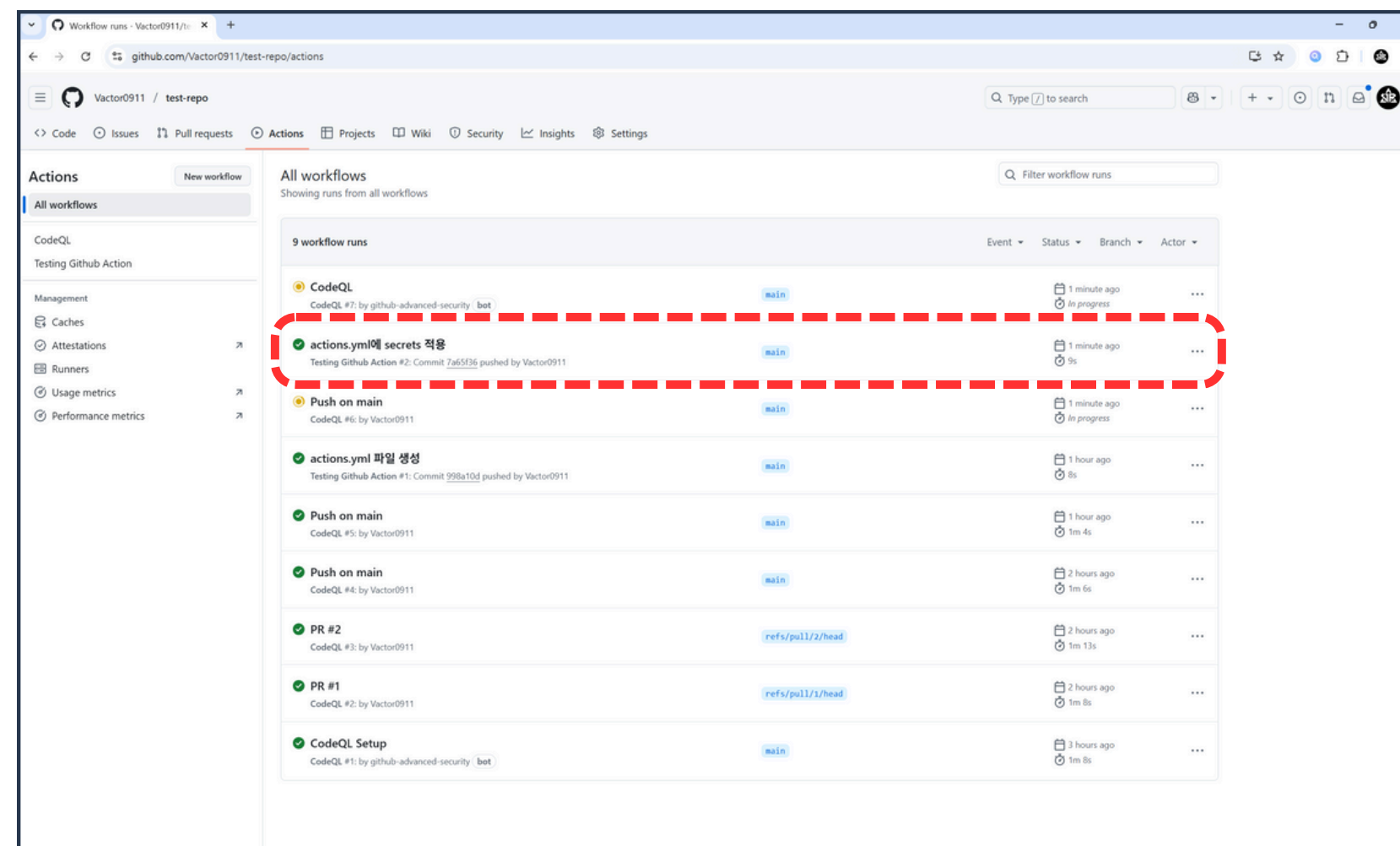
05 Secrets로 안전하게 보호하기



11. Actions 버튼 클릭



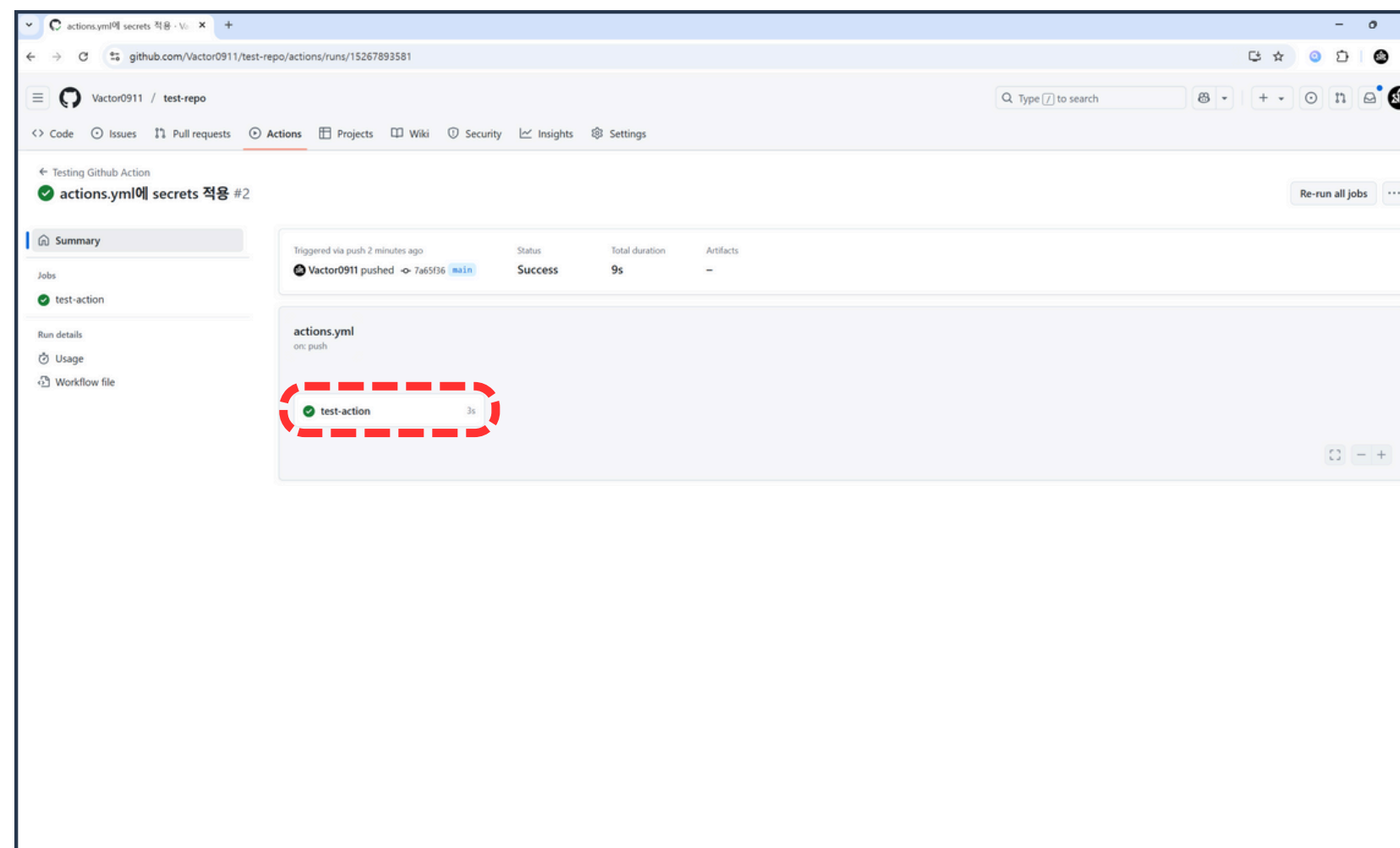
05 Secrets로 안전하게 보호하기



12. actions.yml 파일 생성 항목 클릭



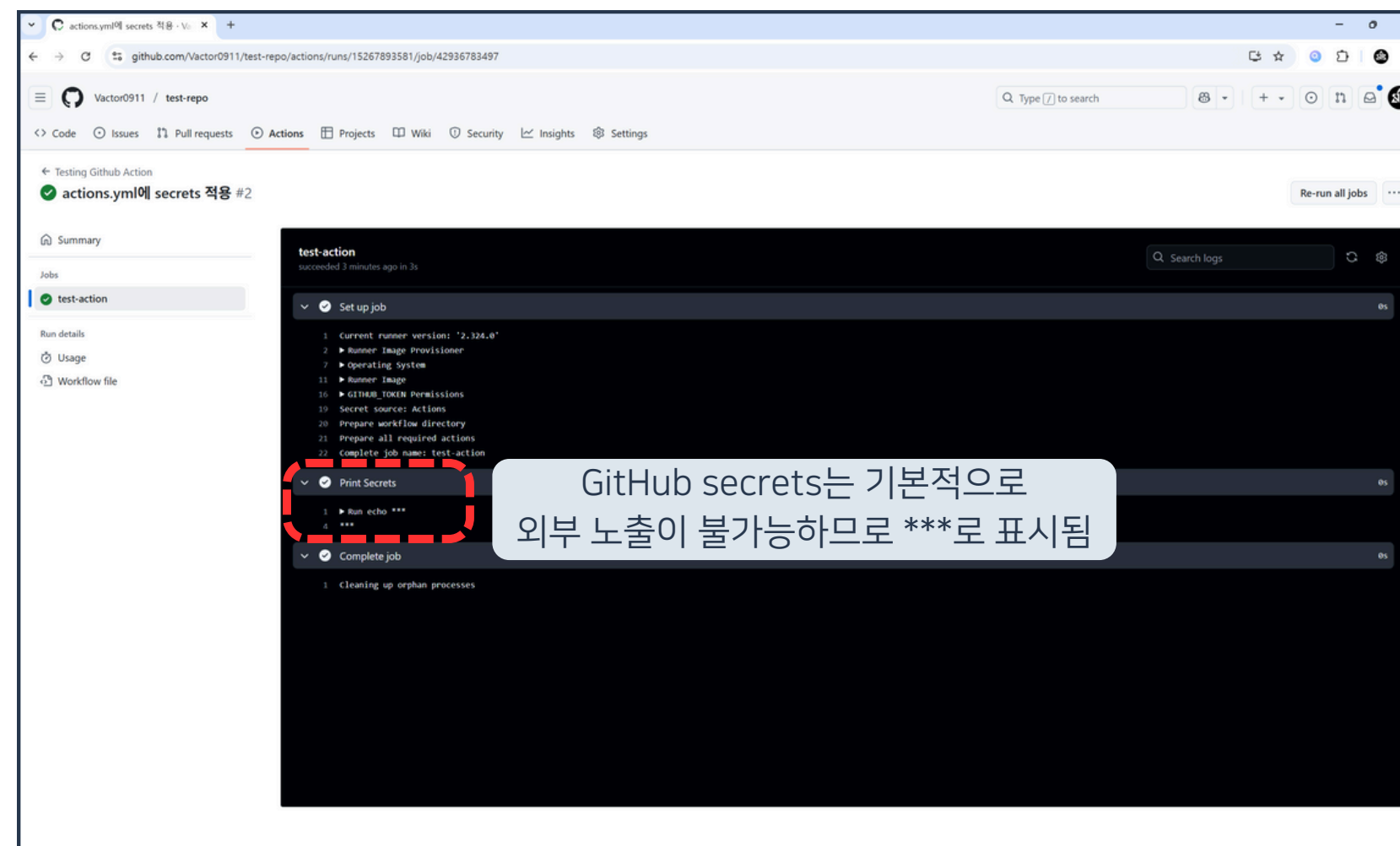
05 Secrets로 안전하게 보호하기



13. test-action 항목 클릭



05 Secrets로 안전하게 보호하기



14. test-action 단계 실행 결과 확인



05 Secrets로 안전하게 보호하기

```
deploy.yml X
.github > workflows > deploy.yml
1 name: Deploy to GitHub Pages
2
3 on:
4   push:
5     branches:
6       - main
7
8 jobs:
9   deploy:
10    runs-on: ubuntu-latest
11
12    permissions:
13      contents: write
14
15    steps:
16      - name: Checkout code
17        uses: actions/checkout@v3
18
19      - name: Set Git user
20        run: |
21          git config --global user.email [REDACTED]
22          git config --global user.name [REDACTED]
23
24      - name: Install dependencies
25        run: npm install
26
27      - name: Build the app
28        run: npm run build
29
30      - name: Set up GitHub token for authentication
31        run: |
32          git config --global url."https://${{ secrets.GH_TOKEN }}@github.com/".insteadOf "https://github.com/"
33
34      - name: Deploy to GitHub Pages
35        run: npm run deploy -- --repo https://github.com/${{ github.repository }}.git
36      env:
37        GH_TOKEN: ${{ secrets.GH_TOKEN }}
38        VITE_KAKAO_CLIENT_ID: ${{ secrets.VITE_KAKAO_CLIENT_ID }}
39        VITE_KAKAO_REDIRECT_URI: ${{ secrets.VITE_KAKAO_REDIRECT_URI }}
40        VITE_GOOGLE_CLIENT_ID: ${{ secrets.VITE_GOOGLE_CLIENT_ID }}
41        VITE_GOOGLE_REDIRECT_URI: ${{ secrets.VITE_GOOGLE_REDIRECT_URI }}
42
```



Q & A

